Evalation Evidence Pack

Evidence for repository: davidleberknight/footbag-platform

Pack name

SOC 2 Trust Services Criteria

Assessed	Edition	Criteria	Question version	Run
2026-11-10	2017 with revised points of focus 2022	61	1.98	run-8cb354a04d95

2	22	26	0	10	1
Gap	Partial	Covered	Environment	Org-level	Not applicable

The work done

We read the repository and answered 51 of the 61 criteria from its code and files. Each answer cites the lines it rests on, or, for something missing, the search that didn't find it. The other 10 criteria are about how the organisation runs. A repository doesn't record that, so the report marks each one for the organisation to answer. We read the code without running it and changed nothing.

This review shows how each control is designed and whether the code puts it in place. An auditor checking that a control worked over a period of months also needs the records kept over those months.

Evalation Evidence Pack

Evidence for repository: davidleberknight/footbag-platform

Executive summary

PURPOSE

Checks every SOC 2 Trust Services criterion: the common criteria in full, plus availability, confidentiality, processing integrity and privacy. A criterion about the board, a person or a contract is marked for the organisation to answer and never reported as a gap. The run reads the code at one commit, so it shows how each control is designed and whether the code puts it in place, the Type 1 half of an audit. Whether a control worked over a period, the Type 2 half, needs the records kept over that period. The criteria text belongs to the AICPA and isn't reproduced, and each entry gives the number an auditor cites with a question of ours.

WHAT THE FINDINGS SHOW

Risk shows where changes reach production: the saved rules for the main branch require no reviewer and no passing build, nothing raises dependency updates on its own, and known critical flaws sit in installed packages, including handlebars.

On privacy, the published notice leaves out birth date, gender, phone, WhatsApp and payment records that the platform stores, the outside services list leaves out Google, and reads of member records leave no trace.

Of the 61 criteria asked: 26 covered, 22 partly covered and 2 not covered.

11 more are for the organisation to answer, need a running system or don't apply.

BY SECTION

SECTION	GAP	PARTIAL	COVERED	ORG-LEVEL	NOT APPLICABLE	TOTAL
Security, the common criteria	0	13	13	7	0	33
Availability	0	2	1	0	0	3
Confidentiality	0	1	1	0	0	2
Processing integrity	0	0	5	0	0	5
Privacy	2	6	6	3	1	18
Total	**2**	**22**	**26**	**10**	**1**	**61**

MOST SERIOUS

P3.2	Explicit consent for sensitive information	GAP
P6.7	Accounting for disclosures on request	GAP
CC2.2	Communicating control responsibilities internally	PARTIAL
CC2.3	Communicating with external parties	PARTIAL
CC3.2	Identifying and analysing risk	PARTIAL
CC3.3	Considering the potential for fraud	PARTIAL
CC3.4	Identifying changes that affect internal control	PARTIAL
CC4.2	Communicating control deficiencies	PARTIAL
CC5.1	Selecting control activities that mitigate risk	PARTIAL
CC5.2	Controls over technology	PARTIAL
CC6.1	Logical access security over protected information	PARTIAL
CC7.1	Detecting configuration changes and vulnerabilities	PARTIAL

MOST SERIOUS, CONTINUED

CC7.3	Evaluating security events	PARTIAL
CC7.5	Recovering from identified incidents	PARTIAL
CC8.1	Authorising, designing and implementing changes	PARTIAL
A1.1	Capacity management	PARTIAL
A1.3	Testing recovery	PARTIAL
C1.1	Identifying and protecting confidential information	PARTIAL
P1.1	Notice about personal information practices	PARTIAL
P3.1	Collecting personal information lawfully	PARTIAL
P4.3	Disposing of personal information	PARTIAL

And 3 more in the sections that follow.

POINTS TO WEIGH

- Ask whether the live GitHub settings for the main branch demand a reviewer and a passing build, since the saved rules in the repository demand neither.
- Check whether the critical package flaws found in this run, handlebars among them, have been updated, and whether anything scans for new ones on a schedule.
- Ask to see the private risk register and dated restore drill records, since this repository points to them but cannot show them.
- Think about whether one administrator acting alone should be able to grant admin power or delete an account, and whether reads of member records should be logged.
- Check whether the privacy notice and the list of outside services will be brought in line with the data actually stored and with the Google link check.
- Ask whether deleting a member should also clear their photos from the web cache and their customer record at Stripe, since today the purge touches neither.
- Ask who owns each gap and whether the fix lands before the audit period starts, since the auditor tests controls across the whole period.
- Check which controls have their evidence outside the code, such as board minutes, training records and vendor reviews, and who will supply it.
- Weigh whether each missing control needs a fix or a written exception the auditor can accept, and what each path costs.
- Ask what availability the company promises customers, and whether its backups and capacity limits support that promise.
- Check for a dated record of a real restore test, since auditors usually ask for one.
- Weigh how much data and time the company could lose in an outage against what its contracts allow.
- Ask which data the company has promised customers to keep confidential, and where that list is written down.
- Check that confidential data is deleted when its retention period ends, and who would notice if the deletion job stopped.
- Ask which personal data the product collects, why it collects each kind, and whether the privacy notice says the same.
- Check how a person exports, corrects or deletes their data, and how long the company takes to answer such a request.
- Find out which outside services receive personal data, and whether each has signed privacy terms the auditor can see.

Reading a criterion

Each criterion below is laid out this way.

IDENTIFIER	The standard's number and short name for the criterion.
ASKED	The question we put to the repository, in italics.
ANSWER	What we found in the repository, and the reason for its status.
WHERE IT RESTS	The file and lines on the grey bar, the quoted line beneath, and the strength of the evidence on the right. For something missing, the search we made, so anyone can repeat it.
LOOKED FOR	Each thing the standard looks for, numbered and marked found, missing, environment or does not apply. The status comes from how many were found. A scanner run during the review settled each item marked scanned, and its results are listed at the end.
STATUS	Gap, Partial, Covered, Environment, Org-level or Not applicable, on the coloured tag. Not applicable means the system has none of what the question asks about. Org-level means the answer lies in what people or the organisation do, and no repository can show that. Environment means a technical control that can be set outside the repository, such as in the hosting platform, a cloud console or an identity provider, where this run saw nothing, so it isn't counted.
CHECKED	Beside the model that read it: verified where a second check confirmed the answer against the repository, and asserted where nothing did.
THE FIX	The fix, on the orange bar. For a criterion the organisation owns, why the code can't answer it.

Security, the common criteria (33): G 0 | P 13 | C 13 | E 0 | O 7 | N 0 MANDATORY

33 criteria assessed against this repository. Every SOC 2 report covers the common criteria, whichever other categories the customer elected.

CC1.1 Commitment to integrity and ethical values

answered from the pack ORG-LEVEL

Where does this repository show that the conduct expected of contributors is written down, and what enforces it on a change?

Commitment to integrity and ethical values is about how the organisation runs. A repository doesn't record that, so the report marks it for the organisation to answer.

REASON THE CODE CAN'T ANSWER IT

A board setting a tone, a code of conduct people sign, and what happens when somebody breaches it demonstrate a commitment to integrity. None of that leaves a trace in a codebase.

CC1.2 Board independence and oversight

answered from the pack ORG-LEVEL

Where does this repository evidence board oversight of internal control?

Board independence and oversight is about how the organisation runs. A repository doesn't record that, so the report marks it for the organisation to answer.

REASON THE CODE CAN'T ANSWER IT

Whether a board exists, is independent of management, and exercises oversight is a fact about the organisation's governance, and no code can evidence it.

SECURITY, THE COMMON CRITERIA, CONTINUED

CC1.3 Structures, reporting lines and authority

answered from the pack · ORG-LEVEL

Where does this repository evidence the reporting lines and authorities management established?

Structures, reporting lines and authority is about how the organisation runs. A repository doesn't record that, so the report marks it for the organisation to answer.

REASON THE CODE CAN'T ANSWER IT

People set organisational structure, reporting lines and delegated authority, and record them in the organisation's own records. A repository does not hold those records.

CC1.4 Attracting, developing and retaining competent people

answered from the pack · ORG-LEVEL

Where does this repository evidence that the people operating the system are competent for it?

Attracting, developing and retaining competent people is about how the organisation runs. A repository doesn't record that, so the report marks it for the organisation to answer.

REASON THE CODE CAN'T ANSWER IT

Hiring, screening, training and retaining people is a personnel duty. A codebase shows what was built and never who was competent to build it.

CC1.5 Holding people accountable for control responsibilities

answered from the pack · ORG-LEVEL

Where does this repository evidence that individuals are held accountable for their control responsibilities?

Holding people accountable for control responsibilities is about how the organisation runs. A repository doesn't record that, so the report marks it for the organisation to answer.

REASON THE CODE CAN'T ANSWER IT

Accountability is enforced through performance management and consequence, both decisions people make about people. A repository carries none of that.

CC2.1 Quality information for internal control

Claude Opus 5.5 · verified · COVERED

What does this repository record that shows whether its controls work, covering refused requests, security events, counts of control failures and changes to sensitive records?

The app writes a warning naming the action for each rate-limit refusal, and the login lockout writes an audit row with the bucket and limits that tripped. Successful sign-ins go to the log too, and CloudWatch counts the refusal lines into a metric with an alarm. Admin role changes land in an append-only audit table that names the actor, the target, the reason and the time. Each of the four items has code or configuration behind it, so the entry reads as Covered. Permission refusals from the admin gate and the origin check render a 403 page without a log line, so those refusals leave no trace.

Continued on page 6

SECURITY, THE COMMON CRITERIA, CC2.1, CONTINUED

CC2.1 Quality information for internal control, continued

1. Refused requests logged with the reason for refusal, such as a failed permission or validation check — FOUND

src/app.ts:35 — EXECUTABLE

```
onRateLimitRefusal((action) ⇒ logger.warn('rate_limit.refused', { action }));
```

src/services/identityAccessService.ts:698-709 — EXECUTABLE

```
      appendAuditEntry({
        actionType: 'auth.login_rate_limited',
        actorType: 'system', …
```

2. Security events logged, such as sign-ins, failed sign-ins or refused permissions — FOUND

src/controllers/authController.ts:96 — EXECUTABLE

```
      logger.warn('auth.login_success', { memberId: member.id });
```

src/services/identityAccessService.ts:694-711 — EXECUTABLE

```
  if (rl.crossed || accountRl.crossed) {
    const member = auth.findOnboardedMemberIdByEmail.get(normalized) as { id: string } | undefined;
    if (member) { …
```

3. A metric or log count of control failures, such as refused sign ins or blocked requests — FOUND

terraform/production/monitoring.tf:218-228 — CONFIGURATION

```
resource "aws_cloudwatch_log_metric_filter" "rate_limit_refused" {
  name           = "${local.prefix}-rate-limit-refused"
  log_group_name = aws_cloudwatch_log_group.app.name …
```

terraform/production/monitoring.tf:230-244 — CONFIGURATION

```
resource "aws_cloudwatch_metric_alarm" "rate_limit_refusals" {
  alarm_name                = "${local.prefix}-rate-limit-refusals"
  comparison_operator       = "GreaterThanThreshold" …
```

Continued on page 7

CC2.1 Quality information for internal control, continued

4. An audit trail of changes to sensitive records, naming who changed what and when — FOUND

src/services/membershipTieringService.ts:685-694 — EXECUTABLE

```
    const auditId = audit({
      actionType: 'admin.role_granted',
      actorType: 'admin', …
```

database/schema.sql:1043-1057 — CONFIGURATION

```
CREATE TABLE audit_entries (
  id         TEXT PRIMARY KEY,
  created_at TEXT NOT NULL, …
```

database/schema.sql:1084-1088 — CONFIGURATION

```
CREATE TRIGGER trg_audit_no_update
BEFORE UPDATE ON audit_entries
BEGIN …
```

CC2.2 Communicating control responsibilities internally

Claude Opus 5.5 · verified — PARTIAL

What does this repository tell contributors about the rules a change must follow, including handling secrets, dependencies and access, and does a pull request template ask them to confirm those rules?

CONTRIBUTING.md sets the rules a change follows, including a ban on new dependencies without discussion. A rule file for scripts forbids secrets on a command line, and the controller rule file says where sign-in and ownership checks belong. The pull request template asks the author to confirm the secrets rule alone, leaving out the dependency and access rules. Four of five checks hold, so the entry reads as Partial.

1. A written guide stating rules a change must follow, such as a contributing guide, README section or agent instructions file — FOUND

CONTRIBUTING.md:27-44 — ASSERTION

```
## Pull requests

1. Fork and branch from `main`. Until the platform launches, collaborators may also push to `main` directly; from launch, every change reaches `main` through a pull request. …
```

2. Written rules for handling secrets in this code — FOUND

.claude/rules/script-secret-safety.md:15-17 — ASSERTION

```
## Hard rule

A secret must never appear in any process's argv on any host: `ps -ef` (any reader) can capture it. Carry every secret over stdin (pipes) or a restricted `file://` temp file, never as a command-line argument or an inline `-e VAR=value`.
```

Continued on page 8

CC2.2 Communicating control responsibilities internally, continued

3. Written rules for handling dependencies in this code — FOUND

CONTRIBUTING.md:40-44 — ASSERTION

```
- TypeScript: no new type errors; follow existing patterns.
- Business logic belongs in services, not controllers or templates.
- Schema changes: follow conventions in `docs/DATA_MODEL.md` and `database/schema.sql`; what else a schema change updates in the same change is in `src/db/CLAUDE.md`. …
```

4. Written rules for handling access in this code — FOUND

.claude/rules/controller-conventions.md:52-54 — ASSERTION

```
## Auth gates

Authentication and membership are checked by middleware at the route layer, not in the controller body: `requireAuth` for a signed-in visitor, and `requireMember` for the member-capability routes, which additionally requires onboarding to be complete. Both live in `src/middleware/auth.ts`. Ownership and authorization within an authenticated request (for example, `:memberKey` matches `req.user.slug`) are checked in the controller and return 404 on mismatch (anti-enumeration), not 403.
```

5. A pull request template or checklist asking the author to confirm those rules — MISSING

Read .github/pull_request_template.md lines 18 to 23. Its checklist asks about sign-off, type errors, docs and "No secrets, real member data, or generated artifacts committed". It asks nothing about the dependency rule or the access rules.

THE FIX

Add checklist lines to .github/pull_request_template.md asking the author to confirm that any new dependency was discussed first and that sign-in and ownership checks sit where the controller rules place them.

Where this documentation is kept outside the code, include the folder that holds it when you start the next check with /ev-run. The check reads that folder as evidence, uses no extra pack credits, and counts each document it finds there.

CC2.3 Communicating with external parties

Claude Opus 5.5 · verified — PARTIAL

Which channels does this repository hold for outage notices, release notes, vulnerability reports from outsiders, account change notices and terms change notices?

CloudFront serves a maintenance page whenever the origin fails, SECURITY.md gives a private route for vulnerability reports, and the password change code emails the member. Nothing in the repository serves as a changelog or release notes. The terms say a change shows up in a date on the page, and no code tells members about it. Three of five items hold, so the entry reads as Partial, short of Covered.

Continued on page 9

CC2.3 Communicating with external parties, continued

1. A way to tell users the service is degraded or down, such as a status page, incident banner or status feed — FOUND

terraform/production/cloudfront.tf:471-476 — CONFIGURATION

```
  custom_error_response {
    error_code            = 500
    response_code         = 503 …
```

2. A changelog users can read, such as release notes — MISSING

Searched the whole tree for CHANGELOG, HISTORY.md, NEWS.md, RELEASES, release notes, version history and what's new, and found none.

3. A route for reporting a vulnerability, such as SECURITY.md or security.txt — FOUND

SECURITY.md:7-13 — ASSERTION

```
## Reporting a vulnerability

**Do not use public GitHub issues for security reports.** …
```

4. Code that tells a user when their account with this service changes, such as a changed password, sign in email or plan — FOUND

src/services/identityAccessService.ts:3053-3057 — EXECUTABLE

```
    const sent = emailService.send({
      template: 'password_changed',
      params: {}, …
```

5. Code that tells users when the service's terms change, such as an email when the terms or privacy notice are updated — MISSING

Searched src for legal, privacy or terms near notice, notify, email, version or updated, and listed the email templates under curated/email_templates. None covers a terms or privacy change. The terms in src/services/legalService.ts line 156 say only that the "Last updated" date changes, and src/views/legal/index.hbs line 12 shows that date.

THE FIX

Add a CHANGELOG.md or a release notes page and update it with each deploy. Write a job that emails members when the terms or privacy text in src/services/legalService.ts changes, keyed on a version stamp held with that text.

Where this documentation is kept outside the code, include the folder that holds it when you start the next check with /ev-run. The check reads that folder as evidence, uses no extra pack credits, and counts each document it finds there.

SECURITY, THE COMMON CRITERIA, CONTINUED

CC3.1 Objectives specified clearly enough to assess risk

Claude Opus 5.5 · verified **COVERED**

What does this repository state about what the system does, whom it serves and what it guarantees, and which tests check those guarantees?

docs/PROJECT_SUMMARY.md says what the platform does and README.md names the global footbag community it serves. The design decisions state a seven year floor on audit log retention, and an integration test checks that the database refuses to delete a younger row. Each item has its document or test, so the entry reads as Covered.

1. A document describing what the system does — FOUND

`docs/PROJECT_SUMMARY.md:5` — ASSERTION

```
The Footbag Website Modernization Project upgrades footbag.org into the global community hub for the sport of
footbag: a secure, open-source, low-cost platform built to be maintained by volunteers over decades. The
architecture deliberately prioritizes simplicity over sophisticated features, so that future volunteers can
contribute without deep specialist expertise. Its capabilities include secure voting, payment collection, and
member-maintained media galleries, hosted on AWS and built on well-understood, mainstream design patterns and
technologies.
```

2. A document describing who the system serves — FOUND

`README.md:8` — ASSERTION

```
This repository contains the open-source modernization project for the global footbag community.
```

3. Stated guarantees a change could be checked against, such as limits, response times or data rules — FOUND

`docs/DESIGN_DECISIONS.md:1195` — ASSERTION

```
- Retention: the daily cleanup deletes rows older than `audit_retention_days` (default 2555 days, seven years);
nothing else updates or deletes a row, and account erasure does not reach a row inside that window.
```

4. Tests written for those stated guarantees — FOUND

`tests/integration/operationsPlatform.auditRetentionPurge.test.ts:118-131` — EXECUTABLE

```
describe('the audit delete trigger', () => {
  it('refuses a delete of a row inside the window, and allows one past it', () => {
    auditAged('trg-young', 2000); …
```

CC3.2 Identifying and analysing risk

Claude Opus 5.5 · verified **PARTIAL**

What threat model, risk register or security review does this repository hold, and does it record a response and an owner for each risk?

docs/TESTING.md holds a risk rubric that grades each surface by blast radius, data sensitivity, reversibility and likelihood, and it rates sign-in, payment and admin surfaces as the most severe. The rubric sets how deep the tests go for each grade. It lists no single risks with a control, fix or accepted reason beside each, and it names nobody as owner. docs/PROJECT_SUMMARY.md says the maintainers keep risks and mitigations in private documents, and this repository cannot show them. One of three items holds, so the entry reads as Partial, above Gap.

Continued on page 11

SECURITY, THE COMMON CRITERIA, CC3.2, CONTINUED

CC3.2 Identifying and analysing risk, continued

1. A written assessment of the risks to this system, such as a threat model, risk register or security review — FOUND

docs/TESTING.md:73-88 — ASSERTION

```
## 3. Risk classification and OWASP ASVS levels

### 3.1 Why classify …
```

2. A response recorded for each risk listed there: a control, a fix or an accepted reason — MISSING

Read docs/TESTING.md sections 3 and 4.2 and searched docs for mitigated, accepted risk, residual risk and risk tables. The rubric grades surfaces and sets test depth, and records no control, fix or accepted reason against individual risks. docs/PROJECT_SUMMARY.md line 724 says risks and mitigations live in the maintainers' private documents.

3. An owner named for each risk listed there — MISSING

Searched docs/TESTING.md, docs/DESIGN_DECISIONS.md, docs/PROJECT_SUMMARY.md and GOVERNANCE.md for risk owner or an owner named against each risk, and found none.

THE FIX

Add a risk register to docs that lists each risk to the platform, the control or fix that answers it or the reason it stands accepted, and the person who owns it. Link each entry to the code or test that carries the control, or move the private register into the repository with personal details removed.

Where this documentation is kept outside the code, include the folder that holds it when you start the next check with /ev-run. The check reads that folder as evidence, uses no extra pack credits, and counts each document it finds there.

CC3.3 Considering the potential for fraud

Claude Opus 5.5 · verified — PARTIAL

What does this repository do about privileged users misusing their access, through audit logs of admin actions and second approvals where the product has admin functions, separated roles and a written insider risk?

Admin role grants and revokes write an audit row naming the acting admin and their reason. A router-level gate keeps non-admins off the admin screens, apart from the bootstrap claim, and the session reads the role from the database row on each request. One admin acting alone can grant the admin role or delete an account, with no second approval. The docs name admin compromise as a severity grade but never treat misuse by a trusted insider as a risk. Two of four items hold, so the entry reads as Partial.

1. Where the product has admin functions, admin screens or commands that record who acted, such as an audit log entry — FOUND

src/services/membershipTieringService.ts:685-694 — EXECUTABLE

```
    const auditId = audit({
      actionType: 'admin.role_granted',
      actorType: 'admin', …
```

Continued on page 12

SECURITY, THE COMMON CRITERIA, CC3.3, CONTINUED

CC3.3 Considering the potential for fraud, continued

2. Where the product has admin functions, a second approval required for sensitive admin actions, such as changing a role or exporting user data — MISSING

Searched src for second approval, two-person, four-eyes, dual control and approved_by, searched src/services/membershipTieringService.ts for approval and another admin, and read grantAdminRole and revokeAdminRole. One admin commits each change alone after a confirm page.

3. Roles separated so a user cannot grant themselves more access — FOUND

src/routes/adminRoutes.ts:42 — EXECUTABLE

```
adminRouter.use(requireMember, requireAdmin);
```

src/middleware/auth.ts:133-138 — EXECUTABLE

```
          // Authz role is derived strictly from the current DB row, never
          // from JWT claims. A stale admin-role JWT issued before demotion
          // must not grant admin privileges after `is_admin` is cleared. …
```

4. A document that treats misuse by an insider as a risk — MISSING

Searched docs and ifpa for insider, trusted admin, rogue admin, malicious admin, misuse, abuse and separation of duties. docs/TESTING.md names admin takeover and admin compromise as severity grades, and no document treats misuse by a trusted insider as a risk.

THE FIX

Require a second admin to approve an admin role grant, an account deletion and a bulk export before the change commits, and record both admins in the audit row. Add a section to docs/DESIGN_DECISIONS.md that treats a trusted admin misusing their access as a risk and names the controls against it.

Where this documentation is kept outside the code, include the folder that holds it when you start the next check with /ev-run. The check reads that folder as evidence, uses no extra pack credits, and counts each document it finds there.

CC3.4 Identifying changes that affect internal control

Claude Opus 5.5 · verified — PARTIAL

What in this repository notices changes to its dependencies, deployment or infrastructure files, requires review when they change, and runs a check on any infrastructure code it holds?

The CI workflow runs terraform fmt and terraform validate on each Terraform root at every push. Nothing in the repository configures Dependabot or Renovate, and it holds no code owners file, so nothing raises dependency updates or demands review of deploy and infrastructure changes. scripts/check-vulnerabilities.sh lists advisories when an operator runs it by hand. One of three items holds, so the entry reads as Partial.

1. Automated dependency alerts configured, such as Dependabot or Renovate — MISSING

Searched the whole tree for dependabot and renovate configuration files and mentions, and found none. The CI workflow audits dependencies at push time in warn-only mode, and scripts/check-vulnerabilities.sh reads advisory feeds when an operator runs it by hand, with no schedule.

Continued on page 13

SECURITY, THE COMMON CRITERIA, CC3.4, CONTINUED

CC3.4 Identifying changes that affect internal control, continued

2. Review required for changes to deployment and infrastructure files, such as a code owners file naming reviewers for them — MISSING

Searched the whole tree for a CODEOWNERS file or mention, and found none. GOVERNANCE.md asks for IFPA approval of policy changes and sets no review rule for deploy or infrastructure files.

3. Where the repository holds infrastructure code, a pipeline step that checks it when it changes — FOUND

.github/workflows/ci.yml:504-512 — CONFIGURATION

```
      - name: terraform fmt
        run: terraform fmt -check -recursive
        working-directory: terraform …
```

THE FIX

Add .github/dependabot.yml covering npm, GitHub Actions and Terraform. Create a CODEOWNERS file that names a reviewer for terraform/, docker/, deploy_to_aws.sh, scripts/ and .github/, and turn on required code owner review for main.

CC4.1 Evaluating whether controls are present and working

Claude Opus 5.5 · verified — COVERED

Which of this repository's controls do authorisation tests, invalid input tests and security scans exercise, and does the pipeline run them on every change?

Route tests sign in as a plain member and expect a 403 from admin pages, and form tests send a list the screen does not offer and expect a 422. CI runs a gitleaks secret scan, CodeQL and an npm audit, and it runs the unit and integration suite on each push and pull request. Each item has executable or configuration evidence, so the entry reads as Covered.

1. A test that calls a protected action without the needed permission and expects refusal — FOUND

tests/integration/admin-audit-log.routes.test.ts:79-83 — EXECUTABLE

```
  it('non-admin → 403', async () ⇒ {
    const app = createApp();
    const res = await request(app).get('/admin/audit-log').set('Cookie', memberCookie()); …
```

2. A test that sends invalid input and expects it refused — FOUND

tests/integration/member-email-preferences.routes.test.ts:321-328 — EXECUTABLE

```
  it('refuses a list the screen does not offer, and writes nothing', async () ⇒ {
    const res = await request(createApp())
      .post(PREFS).set('Cookie', memberCookie()).type('form') …
```

Continued on page 14

SECURITY, THE COMMON CRITERIA, CC4.1, CONTINUED

CC4.1 Evaluating whether controls are present and working, continued

3. A security scan in the pipeline, such as a dependency audit, static analysis or a secret scan — FOUND

.github/workflows/ci.yml:136-137 — CONFIGURATION

```
      - name: Run gitleaks
        uses: gitleaks/gitleaks-action@e0c47f4f8be36e29cdc102c57e68cb5cbf0e8d1e # v3.0.0
```

.github/workflows/ci.yml:426-433 — CONFIGURATION

```
      - name: Initialize CodeQL
        uses: github/codeql-action/init@e4fba868fa4b1b91e1fdab776edc8cfbe6e9fb81 # v4.37.3
        with: …
```

4. The pipeline running those tests on every change — FOUND

.github/workflows/ci.yml:3-9 — CONFIGURATION

```
on:
  push:
    branches: …
```

.github/workflows/ci.yml:248-252 — CONFIGURATION

```
      - name: Run the suite with coverage and enforce the thresholds
        # Without the one suite that drives the legacy club extractors through the
        # pipeline's Python environment, which the local bare run carries; the …
```

CC4.2 Communicating control deficiencies

Claude Opus 5.5 · verified — PARTIAL

How does this repository route a failing pipeline check, a monitoring alert or a security finding to a person who must act on it?

CloudWatch alarms publish to SNS topics with email subscriptions for the account mailbox and an on-call group, and IAM Access Analyzer findings go to the same alarm topic. The CI summary job fails when any job fails, and the production release gate refuses to deploy a commit whose CI went red. Nothing in the repository holds branch protection or a ruleset that stops a merge on that failure, and CONTRIBUTING.md lets collaborators push to main directly until launch. Two of three items hold, so the entry reads as Partial.

1. A failing pipeline check that blocks the merge — MISSING

Searched terraform and .github for branch protection, a ruleset or required status checks, and found none. The ci-complete job in .github/workflows/ci.yml exits non-zero on a failed job, and scripts/lib/production-release-gate.sh refuses a production deploy of a red commit, yet neither stops a merge. CONTRIBUTING.md line 29 allows direct pushes to main until launch.

Continued on page 15

SECURITY, THE COMMON CRITERIA, CC4.2, CONTINUED

CC4.2 Communicating control deficiencies, continued

2. Alerts sent to a named person, team or channel, such as monitoring alerts or failed scheduled checks — FOUND

terraform/production/sns.tf:328-343 — CONFIGURATION

```
locals {
  # Every alarm sends its warning and its return to normal to the main topic; a
  # critical one also sends both to the critical topic. …
```

terraform/production/sns.tf:270-273 — CONFIGURATION

```
resource "aws_sns_topic_subscription" "alarm_email" {
  topic_arn = aws_sns_topic.alarms.arn
  protocol  = "email" …
```

3. Security findings sent to a named owner, such as an issue the scanner assigns — FOUND

terraform/production/sns.tf:243-247 — CONFIGURATION

```
resource "aws_cloudwatch_event_target" "access_analyzer_findings_to_alarms" {
  rule      = aws_cloudwatch_event_rule.access_analyzer_findings.name
  target_id = "alarms-topic" …
```

terraform/production/sns.tf:182-186 — CONFIGURATION

```
resource "aws_sns_topic_subscription" "alarm_email_us_west_2" {
  provider  = aws.us_west_2
  topic_arn = aws_sns_topic.alarms_us_west_2.arn …
```

THE FIX

Protect main with a required status check on the "Type-check and test" job and block direct pushes, and hold that rule as code with the GitHub Terraform provider in terraform/.

CC5.1 Selecting control activities that mitigate risk

Claude Opus 5.5 · verified — PARTIAL

Which controls in this repository name the risk they answer, in a document mapping risks to controls or in their comments, test names or documents?

Controls in the code carry comments that name the threat they stop. The session middleware explains that a stale admin token must not grant admin power after demotion. No document in the repository maps a list of risks to the controls that answer them, and docs/PROJECT_SUMMARY.md places that record in the maintainers' private documents. One of two items holds, so the entry reads as Partial.

1. A document mapping each risk it lists to a control in the code — MISSING

Searched docs for a risk to control mapping, risk register, threat model table and mitigations. docs/TESTING.md holds a severity rubric and a STRIDE vocabulary, and neither maps a risk to a control in the code. docs/PROJECT_SUMMARY.md line 724 says the maintainers keep risks and mitigations in private documents.

Continued on page 16

SECURITY, THE COMMON CRITERIA, CC5.1, CONTINUED

CC5.1 Selecting control activities that mitigate risk, continued

2. A control in the code named with the risk it prevents, such as in its comment, test name or document — FOUND

src/middleware/auth.ts:133-138 — EXECUTABLE

```
// Authz role is derived strictly from the current DB row, never
// from JWT claims. A stale admin-role JWT issued before demotion
// must not grant admin privileges after `is_admin` is cleared. …
```

THE FIX

Add a table to docs that lists each risk the platform faces beside the file and test that hold its control, starting from the severity rubric in docs/TESTING.md.

Where this documentation is kept outside the code, include the folder that holds it when you start the next check with /ev-run. The check reads that folder as evidence, uses no extra pack credits, and counts each document it finds there.

CC5.2 Controls over technology

Claude Opus 5.5 · verified — PARTIAL

What in this repository defines the production infrastructure and deploy, limits deploys to named branches or tags, and has the pipeline supply deploy credentials?

Terraform under terraform/production defines the production hosting, CDN, firewall, alarms and keys. A release gate refuses a production deploy unless the tree is clean, the commit sits on the canonical main, and CI passed for it. The deploy itself runs from deploy_to_aws.sh on an operator's terminal with the operator's own credentials, and CI holds no deploy job. Two of four items hold, so the entry reads as Partial.

1. Production infrastructure defined as code in the repository — FOUND

terraform/production/lightsail.tf:109-142 — CONFIGURATION

```
resource "aws_lightsail_instance_public_ports" "web" {
  instance_name = aws_lightsail_instance.web.name
 …
```

2. The production deploy defined in a pipeline file — MISSING

Read .github/workflows/ci.yml, listed .github/workflows and searched .github for deploy_to_aws and deploy-code, and found no deploy job. Production deploys run from deploy_to_aws.sh, and lines 269 to 276 of it require a person at a terminal.

Continued on page 17

CC5.2 Controls over technology, continued

3. The production deploy limited to named branches or tags, such as the main branch or a tagged release — FOUND

scripts/lib/production-release-gate.sh:204-213 — EXECUTABLE

```
    main="$(git -C "$root" rev-parse refs/remotes/origin/main 2>/dev/null || true)"
    if [[ -z "$head" ]]; then
      blockers+=("HEAD could not be read") …
```

scripts/deploy-code.sh:216-220 — EXECUTABLE

```
if [[ "$REMOTE" == "footbag-production" ]]; then
  # shellcheck source=lib/production-release-gate.sh
  source "${REPO_ROOT}/scripts/lib/production-release-gate.sh" …
```

4. Deploy credentials supplied by the pipeline, such as from its secret store or as short-lived OpenID Connect (OIDC) tokens — MISSING

Searched .github for id-token, configure-aws-credentials, AWS_ACCESS_KEY and deploy secrets, and found none. The deploy script takes the operator's own credentials and a typed host password.

THE FIX

Add a deploy job to the CI workflow that runs on a push to main or a release tag, takes AWS access through GitHub OpenID Connect into a narrow deploy role, and calls the existing deploy script with its release gate.

CC5.3 Deploying controls through policies and procedures

Claude Opus 5.5 · verified — COVERED

Which written change rules does this repository hold, and which pipeline checks enforce them on every pull request or push?

CONTRIBUTING.md requires that a change adds no TypeScript type errors and follows the code conventions. CI enforces that rule with a type-check job and runs eslint as a lint job, and both run on each push to any branch and each pull request to main. Each item holds, so the entry reads as Covered.

1. A written rule for changes, such as a coding standard or a security rule — FOUND

CONTRIBUTING.md:38-44 — ASSERTION

```
## Code conventions

- TypeScript: no new type errors; follow existing patterns. …
```

Continued on page 18

SECURITY, THE COMMON CRITERIA, CC5.3, CONTINUED

CC5.3 Deploying controls through policies and procedures, continued

2. A pipeline check enforcing that rule, such as a linter, a formatter or a policy check — FOUND

.github/workflows/ci.yml:50-56 — CONFIGURATION

```
      - name: Type-check
        run: npm run build
 …
```

.github/workflows/ci.yml:76-77 — CONFIGURATION

```
      - name: Lint
        run: npm run lint
```

3. That check running on every pull request or push — FOUND

.github/workflows/ci.yml:3-9 — CONFIGURATION

```
on:
  push:
    branches: …
```

CC6.1 Logical access security over protected information

Claude Opus 5.5 · verified — PARTIAL

How does this repository restrict access to its data and functions, through shared authentication, record and database access rules, routes protected by default and refusal tests?

A session middleware runs on each request, and route guards send signed-out callers to sign in. Ownership rests on a shared helper that checks the member named in the path is the caller, and tests cover both the signed-out caller and another member. SQLite holds the data and offers no row level rules. Routes on the public router stay open unless each one carries a guard. A unit test fails a state-changing route with no guard, yet a new page view can ship open. Four of five applying items hold, so the entry reads as Partial.

1. A shared authentication check that protected routes pass through, such as middleware or a guard — FOUND

src/app.ts:421 — EXECUTABLE

```
  app.use(authMiddleware());
```

src/middleware/auth.ts:220-226 — EXECUTABLE

```
export function requireAuth(req: Request, res: Response, next: NextFunction): void {
  if (!req.isAuthenticated) {
    res.redirect(loginRedirectFor(req)); …
```

Continued on page 19

SECURITY, THE COMMON CRITERIA, CC6.1, CONTINUED

CC6.1 Logical access security over protected information, continued

2. A check that the caller may see or change the specific record, such as an ownership or tenant check — FOUND

src/lib/routeOwnership.ts:13-15 — EXECUTABLE

```
export function isOwnMemberRoute(req: Request): boolean {
  return req.user?.slug === req.params.memberKey;
}
```

3. Where the database supports row level rules, access rules in the database that limit rows to their owner, such as row level security — DOES NOT APPLY

The platform stores its data in SQLite, opened through src/db/openDatabase.ts, and SQLite has no row level security feature.

4. A default that protects every route not on a named list of public routes — MISSING

Searched src/routes for router-wide guards and found one, on the admin router at src/routes/adminRoutes.ts line 42. Each member route on the public router names its own guard, as at src/routes/publicRoutes.ts lines 218 to 220. tests/unit/route-auth-conformance.test.ts lines 174 to 184 fail an unguarded state-changing route, and nothing fails an unguarded GET route.

5. A test that calls a protected route signed out and expects refusal — FOUND

tests/integration/admin-audit-log.routes.test.ts:72-77 — EXECUTABLE

```
  it('unauthenticated → 302 to /login', async () => {
    const app = createApp();
    const res = await request(app).get('/admin/audit-log'); …
```

6. A test that calls a protected route as another user and expects refusal — FOUND

tests/integration/member-email-preferences.routes.test.ts:107-111 — EXECUTABLE

```
  it('404s a member reading another member\'s preferences', async () => {
    const res = await request(createApp())
      .get(`/members/${OTHER_SLUG}/email-preferences`).set('Cookie', memberCookie()); …
```

THE FIX

Make the public router refuse signed-out callers by default, with a named list of public paths that skip the guard. Or extend tests/unit/route-auth-conformance.test.ts so it fails any GET route that carries no guard and sits off a named public list.

CC6.2 Registering and authorising new users

Claude Opus 5.5 · verified — COVERED

How does this repository create a new user, set its default role, check who may grant more access, and verify the user before the account is active?

Registration inserts a new member with an empty email verified field, and the schema gives each new member the non-admin flag by default. Admin role grants sit behind a router gate that admits admins. Sign-in and session lookups both require a verified email, so an unverified account cannot sign in. Each item holds, so the entry reads as Covered.

Continued on page 20

SECURITY, THE COMMON CRITERIA, CC6.2, CONTINUED

CC6.2 Registering and authorising new users, continued

1. Code that creates a new user's identity, such as sign-up or invitation code — FOUND

src/services/identityAccessService.ts:1155-1160 — EXECUTABLE

```
      registration.insertMember.run(
        id,
        slug, …
```

2. A default role or permission set given to a new identity in code — FOUND

database/schema.sql:2356 — CONFIGURATION

```
  is_admin    INTEGER NOT NULL DEFAULT 0 CHECK (is_admin    IN (0,1)),
```

3. A check that a caller raising a role or permission is allowed to grant it — FOUND

src/routes/adminRoutes.ts:42 — EXECUTABLE

```
adminRouter.use(requireMember, requireAdmin);
```

4. Verification of a new user's email address or identity before the account is active — FOUND

src/db/db.ts:4500-4514 — EXECUTABLE

```
  get findMemberByEmail() { return db.prepare(`
    SELECT
      m.id, …
```

CC6.3 Modifying and removing access

Claude Opus 5.5 · verified — COVERED

How does this repository change or remove a user's access, end their sessions and tokens when access is removed, and expire sessions after a set time?

Admin role code sets and clears the admin flag, and the deletion service soft-deletes an account. The session middleware reloads the member row on each request from a view of live accounts, so a deleted account or a changed password ends existing sessions at once, and a demoted admin loses admin power on the next request. Session tokens carry a configured lifetime. Each item holds, so the entry reads as Covered.

1. Code that changes a user's role or permissions — FOUND

src/services/membershipTieringService.ts:923 — EXECUTABLE

```
    adminRole.setAdminFlag.run(0, now, 'admin_role_revoke', targetMemberId);
```

Continued on page 21

CC6.3 Modifying and removing access, continued

2. Code that disables or deletes a user account — FOUND

src/services/accountDeletionService.ts:256-258 — EXECUTABLE

```
      const res = account.softDeleteMember.run(
        nowIso, actorId, nowIso, graceExpiresAt, nowIso, byAdmin ? actorId : 'member', input.memberId,
      );
```

3. Existing sessions ended when access is removed, such as by revoking tokens — FOUND

src/middleware/auth.ts:121-124 — EXECUTABLE

```
    // An unknown member, or a token predating the current password_version,
    // is a revoked session: the request continues unauthenticated.
    if (row && row.password_version === claims.passwordVersion) { …
```

src/db/db.ts:4530-4541 — EXECUTABLE

```
  get findMemberForSession() { return db.prepare(`
    SELECT
      m.id, …
```

4. Sessions that expire after a set time, such as tokens with an expiry — FOUND

src/services/jwtService.ts:22-26 — EXECUTABLE

```
  return getJwtSigningAdapter().signJwt({
    sub: memberId,
    role, …
```

CC6.4 Restricting physical access

answered from the pack — ORG-LEVEL

Where does this repository evidence physical access controls over facilities?

Restricting physical access is about how the organisation runs. A repository doesn't record that, so the report marks it for the organisation to answer.

REASON THE CODE CAN'T ANSWER IT

Doors, badges, racks and who may enter a building are physical controls owned by whoever operates the premises. No code can evidence them.

SECURITY, THE COMMON CRITERIA, CONTINUED

CC6.5 Disposing of data and physical media

Claude Opus 5.5 · verified COVERED

How does this repository destroy data it no longer needs, covering account deletion, related tables, stored files where the system keeps them, scheduled deletion and what happens to backups?

A member can delete their own account through the deletion service. It removes each media object from storage before its row, deletes the tag links and galleries, and soft-deletes the account. A daily job purges personal data once the grace period ends. The design decisions say a restore from backup replays recorded erasures before the data goes live. Each item holds, so the entry reads as Covered.

1. Code that deletes an account when the account owner asks — FOUND

src/services/accountDeletionService.ts:162-168 — EXECUTABLE

```
    async requestAccountDeletion(input: {
      memberId: string;
      recurringDonationChoice: RecurringDonationChoice; …
```

2. Deletion that reaches related tables, such as cascading deletes — FOUND

src/services/accountDeletionService.ts:216-219 — EXECUTABLE

```
        transaction(() => {
          mediaTags.deleteMediaTagsByMediaId.run(item.id);
          media.deleteMediaItem.run(item.id); …
```

src/services/accountDeletionService.ts:261-263 — EXECUTABLE

```
        for (const galleryId of galleryIds) {
          media.deleteMemberGalleryById.run(galleryId);
        }
```

3. Where the system stores files, deletion that reaches those files, such as a storage cleanup step — FOUND

src/services/accountDeletionService.ts:200-205 — EXECUTABLE

```
      for (const item of mediaRows) {
        const keys = [item.s3_key_thumb, item.s3_key_display].filter((k): k is string => Boolean(k));
        try { …
```

4. A scheduled job that deletes data after a set time — FOUND

src/services/operationsPlatformService.ts:743-758 — EXECUTABLE

```
  async runPiiPurgeScan(opts: { now?: Date } = {}): Promise<PiiPurgeScanResult> {
    return this.recordJobRun('SYS_Cleanup_Soft_Deleted_Records', () => {
      const now = opts.now ?? new Date(); …
```

Continued on page 23

CC6.5 Disposing of data and physical media, continued

5. A written statement of what happens to backups and copies after a deletion — FOUND

docs/DESIGN_DECISIONS.md:245-248 — ASSERTION

```
- A host systemd backup timer writes the SQLite snapshot to the primary backup bucket on the documented cadence (default five minutes, per the backup-script description above). A dead timer or a failing upload stops the backup-age metric from refreshing, so the staleness alarm breaches and a silent backup gap cannot accrue.
- The DR replica bucket has S3 Object Lock enabled in GOVERNANCE mode for the configured retention window, so the application and every ordinary credential cannot delete or overwrite snapshots in the disaster-recovery target. The runtime role holds read access plus one write, scoped to a single prefix outside the replicated backup stream so it can add an object there but never overwrite a replicated one, and cannot delete an object, remove a version, or lift retention in any mode. The replica sits in the same account as the primary rather than a separate one: a second account would add a further layer of separation, but it costs an organisation member account, cross-account replication with destination ownership, IAM on both sides, and permanent operator access separation. That is ongoing complexity a volunteer-run association pays forever, so the single-account arrangement is an accepted trade-off rather than an omission.
- Retention windows are documented per artifact class (hot snapshot, DR replica, log archive). Each class has a single source of truth in DEVOPS_GUIDE.md (private GitHub repo) and matching S3 lifecycle rules; the lifecycle rules and the documented retention table cannot drift. …
```

CC6.6 Protecting against threats from outside the boundary

Claude Opus 5.5 · verified — COVERED

What protects this system at its boundary with the outside, covering rate limits, request limits, security headers, allowed origins where the system accepts cross origin requests, network exposure and signed webhooks?

Sign-in has per address and per account rate limits with a lockout, and public registration is limited per IP address. nginx caps request bodies, helmet sets a strict content security policy with framing blocked, and the Lightsail firewall opens the web port to CloudFront alone. The media bucket accepts cross origin uploads, and terraform/production/s3.tf limits them to PUT from the CloudFront address and the site's own named hosts. Stripe webhook code checks each delivery's signature. All seven checks hold, so the entry reads as Covered.

1. Rate limiting on sign-in routes, such as rate limit middleware or a gateway rule — FOUND

src/services/identityAccessService.ts:682-688 — EXECUTABLE

```
  const rl = rateLimitHit(`login:${normalized}:${ip}`, maxAttempts, windowMinutes, cooldownMinutes);
  // Per-account bucket independent of IP: caps distributed credential-stuffing of
  // a single account from many IPs, which the per-IP bucket cannot see. Always …
```

2. Rate limiting on public endpoints, such as rate limit middleware or a gateway rule — FOUND

src/services/identityAccessService.ts:1047-1055 — EXECUTABLE

```
  const maxAttempts = readIntConfig('register_rate_limit_max_attempts', 10);
  const windowMinutes = readIntConfig('register_rate_limit_window_minutes', 15);
  const rl = rateLimitHit(`register:${ip}`, maxAttempts, windowMinutes); …
```

Continued on page 24

SECURITY, THE COMMON CRITERIA, CC6.6, CONTINUED

CC6.6 Protecting against threats from outside the boundary, continued

3. Request size limits at the entry point, such as a maximum body size — FOUND

docker/nginx/nginx.conf.template:28 — CONFIGURATION

```
    client_max_body_size 160m;
```

4. Security headers set on responses, such as Content-Security-Policy and X-Frame-Options — FOUND

src/app.ts:163-197 — EXECUTABLE

```
  app.use(helmet({
    contentSecurityPolicy: {
      useDefaults: false, …
```

5. Where the system accepts cross origin requests, those requests limited to a named list of origins — FOUND

terraform/production/s3.tf:281-296 — CONFIGURATION

```
resource "aws_s3_bucket_cors_configuration" "media" {
  count  = var.enable_cloudfront ? 1 : 0
  bucket = aws_s3_bucket.media.id …
```

terraform/staging/s3.tf:280 — CONFIGURATION

```
resource "aws_s3_bucket_cors_configuration" "media" {
```

6. Network exposure limited in deployment configuration, such as only the web port being public — FOUND

terraform/production/lightsail.tf:137-142 — CONFIGURATION

```
  port_info {
    protocol  = "tcp"
    from_port = 80 …
```

7. Where the system receives webhooks from outside services, each webhook verified by signature — FOUND

src/adapters/stripeWebhook.ts:47-57 — EXECUTABLE

```
export function verifyStripeWebhook(
  rawBody: string | Buffer,
  signature: string, …
```

SECURITY, THE COMMON CRITERIA, CONTINUED

CC6.7 Restricting the movement of information

Claude Opus 5.5 · verified **COVERED**

How does this repository encrypt connections to the service and to its database, enforce HTTPS, and limit the fields sent in responses and to outside services?

CloudFront in terraform/production/cloudfront.tf sends plain web requests on to HTTPS and holds connections to TLS 1.2 or newer. Express also sets a Strict-Transport-Security header through helmet in src/app.ts. SQLite runs as a file inside the web process, so no network link to the database exists to encrypt. Pages and JSON replies come from shaping functions that copy named fields, and the Stripe checkout call sends a short named list of identifiers. Each item that applies holds, so this is Covered.

1. Encrypted connections to the service, such as Transport Layer Security (TLS) set on the load balancer or web server — FOUND

terraform/production/cloudfront.tf:519-525 — CONFIGURATION

```
  dynamic "viewer_certificate" {
    for_each = var.enable_platform_custom_domain ? [1] : []
    content { …
```

2. Encrypted connections to the database, such as sslmode=require in the connection settings or a forced encryption setting on a managed database — DOES NOT APPLY

The database is a SQLite file that src/db/openDatabase.ts opens inside the web process with better-sqlite3, so no network connection to the database exists.

3. Encrypted web traffic (HTTPS) enforced, such as by a redirect or a Strict-Transport-Security header — FOUND

terraform/production/cloudfront.tf:317-319 — CONFIGURATION

```
  default_cache_behavior {
    target_origin_id       = var.enable_planned_maintenance ? "s3-maintenance" : "lightsail-origin"
    viewer_protocol_policy = "redirect-to-https"
```

src/app.ts:195 — EXECUTABLE

```
    hsts: { maxAge: 15552000, includeSubDomains: true, preload: false },
```

4. Responses built from a named list of fields, so a new database column is not sent by default — FOUND

src/services/auditLogService.ts:295-310 — EXECUTABLE

```
function shapeRow(row: AuditLogQueryRow): AuditEntryViewModel {
  return {
    // Stored timestamps are UTC. The ledger's purpose is establishing a …
```

src/controllers/adminCuratorController.ts:600-601 — EXECUTABLE

```
      const { jobId, videoUrl, posterUrl, expiresAtIso } = result;
      res.json({ jobId, videoUrl, posterUrl, expiresAtIso });
```

Continued on page 26

CC6.7 Restricting the movement of information, continued

5. Where the system sends data to outside services, the fields sent limited to a named list in code — FOUND

src/services/paymentService.ts:1108-1120 — EXECUTABLE

```
  const result = await adapter.createCheckoutSession({
    memberId,
    paymentId, …
```

src/adapters/paymentAdapter.ts:1609-1636 — EXECUTABLE

```
        const metadata = truncateMetadataValues({
          ...(opts.metadata ?? {}),
          paymentId: opts.paymentId, …
```

CC6.8 Preventing and detecting unauthorised software

Claude Opus 5.5 · verified — COVERED

How does this repository install dependencies from a frozen lockfile, pin its container images, pipeline actions and build tools, and alert on new or changed dependencies?

In .github/workflows/ci.yml, CI installs packages with npm ci, pins each outside action to a commit hash and pins Terraform to 1.14.7. Dockerfiles and the nginx image in docker/docker-compose.yml carry sha256 digests. Node comes from .nvmrc and the other tools from ops/tool-versions.env, each at one exact version. Pull requests run a dependency review step and each push runs npm audit, both as warnings. Each item holds, so this is Covered.

1. Dependencies installed in the pipeline with a frozen lockfile, such as npm ci or pnpm install --frozen-lockfile — FOUND

.github/workflows/ci.yml:47-48 — CONFIGURATION

```
      - name: Install dependencies
        run: npm ci
```

2. Where the build uses container images, base images pinned by digest — FOUND

docker/web/Dockerfile:12 — CONFIGURATION

```
FROM node:22-alpine@sha256:fe4f6d74e20370acb04ad889077d14d0f64a9c8ea6a42bc60cddf1e844699914 AS builder
```

docker/docker-compose.yml:39 — CONFIGURATION

```
    image: nginx:1.30-alpine@sha256:0e52bd054126cdc040b1276c0af347aeb02a41b9cfe305d6094767ac30e97949
```

3. Where the pipeline uses third party actions, those actions pinned by commit hash — FOUND

.github/workflows/ci.yml:37 — CONFIGURATION

```
      - uses: actions/checkout@3d3c42e5aac5ba805825da76410c181273ba90b1 # v7.0.1
```

.github/workflows/ci.yml:137 — CONFIGURATION

```
        uses: gitleaks/gitleaks-action@e0c47f4f8be36e29cdc102c57e68cb5cbf0e8d1e # v3.0.0
```

Continued on page 27

SECURITY, THE COMMON CRITERIA, CC6.8, CONTINUED

CC6.8 Preventing and detecting unauthorised software, continued

4. Build tools pinned to exact versions — FOUND

.nvmrc:1 — CONFIGURATION

```
22.23.4
```

.github/workflows/ci.yml:492-502 — CONFIGURATION

```
      - name: Setup Terraform
        uses: hashicorp/setup-terraform@dfe3c3f87815947d99a8997f908cb6525fc44e9e # v4.0.1
        with: …
```

5. Automated alerts for new or changed dependencies, such as Dependabot or an audit step — FOUND

.github/workflows/ci.yml:117-122 — CONFIGURATION

```
      - name: Review changed dependencies (report-only)
        # Advisories, including on a dependency this change adds, are reported and
        # never block: patching is the maintainer's call on the operational cadence. …
```

.github/workflows/ci.yml:97-101 — CONFIGURATION

```
      - name: Audit dependencies (moderate+, report-only)
        # An advisory is published upstream on its own schedule and can land on a
        # commit that changed nothing; patching is the maintainer's call on the …
```

CC7.1 Detecting configuration changes and vulnerabilities

Claude Opus 5.5 · verified — PARTIAL

What runs on a schedule in this repository to detect dependency advisories, code weaknesses, image weaknesses where the system builds container images, infrastructure misconfiguration where the repository holds infrastructure code, and configuration drift, and what do the scans find?

CI in .github/workflows/ci.yml runs on pushes and pull requests and holds no schedule trigger. CodeQL, npm audit and the dependency review run on those events alone. According to ops/tool-versions.env, the Trivy scanner runs on request, and scripts/bringup-status.sh checks Terraform drift on request too. This run's scan shows critical advisories in package-lock.json and legacy_data/requirements.txt, including handlebars 4.7.9. Static analysis in the same scan holds nothing at high or above. One of seven items holds, so this is Partial.

1. A scheduled dependency advisory check, such as Dependabot alerts or a scheduled audit job — MISSING

Searched the whole tree for schedule:, cron:, workflow_dispatch and OnCalendar, and for a Dependabot or Renovate file. The workflow runs on push and pull_request events, the two systemd timers in ops/systemd drive backups and container checks, and ops/tool-versions.env says Trivy runs on request and never on a schedule.

2. A scheduled security scan of the code — MISSING

Looked in .github/workflows/ci.yml, ops/systemd and the scripts for a timed code scan. CodeQL runs on push and pull request events, and scripts/pentest/deps-scan.sh runs when an operator starts it.

Continued on page 28

SECURITY, THE COMMON CRITERIA, CC7.1, CONTINUED

CC7.1 Detecting configuration changes and vulnerabilities, continued

3. Where the system builds container images, a scheduled security scan of those images — MISSING

Dockerfiles in docker/web, docker/worker and docker/image build container images. A search of the CI workflow, ops/systemd, Terraform and scripts for a timed image scan turned up scripts/check-vulnerabilities.sh, and ops/tool-versions.env says that script runs on request.

4. Where the repository holds infrastructure code, a scheduled scan of it for misconfiguration, such as Checkov or tfsec run on a timer — MISSING

The repository holds Terraform code for staging, production and shared settings, and a search of the whole tree for Checkov, tfsec, KICS, Terrascan, AWS Config or Security Hub found nothing. CI runs terraform fmt and validate on each push.

5. A scheduled check comparing the running configuration with the committed one — MISSING

Looked for a timed comparison of live settings with the committed Terraform. scripts/bringup-status.sh and scripts/internal/bootstrap-host-steps.sh run terraform plan with detailed exit codes, and an operator starts both by hand.

6. No known critical or high advisories in the pinned dependencies — SCANNED MISSING

The dependency advisories found 87 at high or above, of 130 in all. The scanner results at the end of this pack list each one.

7. No critical or high code weaknesses found by static analysis — SCANNED FOUND

The static analysis ran over this repository and found nothing at high or above, and 580 below that. The scanner results at the end of this pack list each one.

THE FIX

Add a schedule trigger to .github/workflows/ci.yml, or a separate timed workflow, that runs npm audit, CodeQL, a Trivy image scan and a Terraform scan such as Checkov each week. A .github/dependabot.yml for npm, pip, Docker and GitHub Actions would raise alerts between runs. Run the scripts/bringup-status.sh drift check on a timer and alert on a non-empty plan. Upgrade handlebars to 4.7.10 or later and update certifi and pillow in legacy_data/requirements.txt.

CC7.2 Monitoring for anomalies

Claude Opus 5.5 · verified — COVERED

What in this repository watches for unexpected behaviour, covering error tracking, alert rules and who receives them, and alerts on repeated failed sign ins and refused requests?

CloudWatch metric filters in terraform/production/cloudwatch.tf count each error line the app logs, and an alarm fires within a minute of one. Alarms reach an email subscription and a second critical topic set up in terraform/production/sns.tf. In terraform/production/cloudtrail.tf, an alarm fires on repeated failed AWS console sign-ins. Bursts of rate limit refusals, login lockouts among them, raise another alarm from terraform/production/monitoring.tf. Each item holds, so this is Covered.

Continued on page 29

SECURITY, THE COMMON CRITERIA, CC7.2, CONTINUED

CC7.2 Monitoring for anomalies, continued

1. Error tracking configured, such as Sentry or an application performance monitoring (APM) agent — FOUND

terraform/production/cloudwatch.tf:30-40 — CONFIGURATION

```
resource "aws_cloudwatch_log_metric_filter" "app_errors" {
  name           = "${local.prefix}-app-errors"
  log_group_name = aws_cloudwatch_log_group.app.name …
```

2. Alerts defined on errors, latency or unusual volume — FOUND

terraform/production/cloudwatch.tf:42-58 — CONFIGURATION

```
resource "aws_cloudwatch_metric_alarm" "app_errors" {
  alarm_name          = "${local.prefix}-app-errors"
  comparison_operator = "GreaterThanOrEqualToThreshold" …
```

3. Those alerts sent to a named person, team or channel — FOUND

terraform/production/sns.tf:270-273 — CONFIGURATION

```
resource "aws_sns_topic_subscription" "alarm_email" {
  topic_arn = aws_sns_topic.alarms.arn
  protocol  = "email" …
```

terraform/production/sns.tf:331-332 — CONFIGURATION

```
  warning_alarm_actions  = [aws_sns_topic.alarms.arn]
  critical_alarm_actions = [aws_sns_topic.alarms.arn, aws_sns_topic.alarms_critical.arn]
```

4. An alert on repeated failed sign-ins — FOUND

terraform/production/cloudtrail.tf:439-452 — CONFIGURATION

```
resource "aws_cloudwatch_metric_alarm" "console_auth_failure" {
  count               = var.enable_cloudtrail ? 1 : 0
  alarm_name          = "${local.prefix}-console-auth-failure" …
```

terraform/production/monitoring.tf:213-216 — CONFIGURATION

```
# ── Rate-limit refusals ──────────────────────────────────────
# The application logs one line per refused attempt, naming only the action.
# A sustained burst is a campaign against a form (most often the login form's …
```

5. An alert on repeated refused requests — FOUND

terraform/production/monitoring.tf:230-243 — CONFIGURATION

```
resource "aws_cloudwatch_metric_alarm" "rate_limit_refusals" {
  alarm_name                = "${local.prefix}-rate-limit-refusals"
  comparison_operator       = "GreaterThanThreshold" …
```

src/app.ts:35 — EXECUTABLE

```
onRateLimitRefusal((action) ⇒ logger.warn('rate_limit.refused', { action }));
```

SECURITY, THE COMMON CRITERIA, CONTINUED

CC7.3 Evaluating security events

Claude Opus 5.5 · verified **PARTIAL**

What does this repository say about deciding whether an event is an incident, closing an event that is not one, and labelling alerts with one of the written incident severity levels?

docs/DESIGN_DECISIONS.md defines warning and critical alert levels, each with its examples and expected response. terraform/production/sns.tf routes each alarm to a warning or a critical topic. The admin alarm page lets an admin acknowledge an alarm with a note, yet nothing written says how to judge an event harmless and close it. Two of three items hold, so this is Partial.

1. Written criteria for what counts as an incident, such as severity levels — FOUND

docs/DESIGN_DECISIONS.md:5451 — ASSERTION

```
Critical-level: Email to the primary maintainer, handled as soon as the maintainer is reachable, indicates service disruption or imminent failure. Examples: host CPU, memory or disk \>85% for 3 minutes, 5xx rate \>5% for 2 minutes. Database: backup age \>15 minutes, 3 consecutive backup failures, generation promotion failing on every run for an hour, hourly snapshot replication silent for three hours. Database file growth is watched through host disk rather than as a signal of its own, and the engine's internal health (lock contention, write-ahead log size, checkpoint latency) is not instrumented: on a single instance those surface as host pressure or as application errors, both of which are alarmed.
```

2. Written steps for an event judged to be no incident, such as logging and closing it — MISSING

Searched docs/USER_STORIES.md, docs/DESIGN_DECISIONS.md, docs/DATA_GOVERNANCE.md and the other Markdown files for triage, false positives, benign events and closing or dismissing an alarm. The alarm story records who acknowledged an alarm with an optional note, the monitoring section says thresholds get adjusted when an alert proves noisy, and recovery steps live in a DEVOPS_GUIDE.md held in a private repository outside this tree.

3. Alerts labelled with one of the written incident severity levels — FOUND

terraform/production/sns.tf:331-332 — CONFIGURATION

```
  warning_alarm_actions  = [aws_sns_topic.alarms.arn]
  critical_alarm_actions = [aws_sns_topic.alarms.arn, aws_sns_topic.alarms_critical.arn]
```

terraform/production/cloudwatch.tf:105-107 — CONFIGURATION

```
  alarm_actions             = local.critical_alarm_actions
  ok_actions                = local.critical_alarm_actions
  insufficient_data_actions = local.warning_alarm_actions
```

THE FIX

Add a short triage section to docs/DESIGN_DECISIONS.md beside the two alert levels. Say what makes an alarm an incident, and say that an alarm judged harmless gets acknowledged on the admin alarm page with a note giving the reason.

Where this documentation is kept outside the code, include the folder that holds it when you start the next check with /ev-run. The check reads that folder as evidence, uses no extra pack credits, and counts each document it finds there.

SECURITY, THE COMMON CRITERIA, CONTINUED

CC7.4 Responding to security incidents

Claude Opus 5.5 · verified COVERED

What does this repository give a person responding to an incident, covering containment, who is told, replacing a leaked key or secret and restoring data from backup?

docs/USER_STORIES.md sets out the fast and full stops for live payments and outbound mail. docs/DATA_GOVERNANCE.md names the IFPA Secretary, the CTO and the Board as the people told of a suspected data exposure. Scripts such as scripts/rotate-origin-verify-secret.sh describe how to replace a leaked secret step by step. docs/DESIGN_DECISIONS.md gives the database recovery steps. Each item holds in writing, so this is Covered.

1. Steps for containing an incident, such as cutting off access or isolating a service — FOUND

docs/USER_STORIES.md:4081-4083 — ASSERTION

```
The fast stop is the payments-pause script, which sets the platform's runtime pause switch in seconds. New
purchases and donations are refused immediately, before any eligibility check or provider call, while webhooks
keep processing so money already in flight still settles and still grants what it paid for. Stopping that too
would take a member's money and give them nothing. The switch is append-only in the configuration table, so every
pause and resume stays on the record with the reason given. It is a System Administrator action rather than an
application-administrator control: the application has no write path to that flag and none is planned.

The full stop is disarming, for when the provider integration itself is the problem: disable the Stripe webhook
endpoint in the Dashboard, then run the arming script to dark, which rewrites the environment values file, applies
Terraform and deploys. It swaps the live adapter out entirely, takes a few minutes, and the order matters — a dark
host verifies webhook signatures against the stub secret, so an endpoint left enabled fails every delivery and the
provider retries for days before disabling it itself. The same two-level arrangement applies to halting outbound
mail.
```

2. Who is told when an incident happens, by name, role or channel — FOUND

docs/DATA_GOVERNANCE.md:23-31 — ASSERTION

```
- **Lawful basis.** Account, membership, event and payment data are processed to perform the membership agreement;
financial records are kept to meet legal obligations; official competition results are published in IFPA's
legitimate interest in the sport's historical record; optional profile visibility and announcement mail rest on
the member's own opt-in.
- **Purposes.** Running memberships, events, payments, clubs and member communications, and preserving the sport's
official record. Data is not used for advertising, analytics or profiling, and member addresses are never shared
or sold.
- **Processors.** Amazon Web Services hosts the platform, its storage and backups, and sends its email; Stripe
processes payments, and card details never reach the platform; Cloudflare runs the human-verification check on
sign-in and registration pages. Production member data stays in AWS, except the copies the design decisions admit
once production is live: staging, and the developer machines invited to receive copies, which keep their disks
encrypted. …
```

3. Steps for revoking and replacing a leaked key or secret — FOUND

scripts/rotate-origin-verify-secret.sh:16-26 — ASSERTION

```
# Rotation is for cause, never on a clock: a suspected exposure of a state file,
# a saved plan or the host env file.
# …
```

Continued on page 32

CC7.4 Responding to security incidents, continued

4. Steps for restoring data from backup — FOUND

docs/DESIGN_DECISIONS.md:5243 — ASSERTION

```
Recovery procedure: Download the latest S3 snapshot, run PRAGMA integrity_check to validate database integrity,
replace local database file, re-apply the recorded erasures while the application is stopped (a replay that does
not complete leaves it stopped), restart application containers, verify health endpoints return OK. Target RTO
(Recovery Time Objective): ~5 minutes from failure detection to service restoration.
```

CC7.5 Recovering from identified incidents

Claude Opus 5.5 · verified — PARTIAL

What shows this system can be restored, covering written restore steps, a way to redeploy an earlier version, and a record of a restore performed with its date and duration?

docs/DESIGN_DECISIONS.md writes out the database restore, and scripts/restore-bucket.sh explains how to bring lost files back from the backup copy or earlier versions. The production release gate in scripts/lib/production-release-gate.sh lets an earlier commit of main redeploy as a rollback. Drill results go to a cutover log in a private repository, so this tree holds no record of a restore with its date or duration. Three of five items hold, so this is Partial.

1. Written restore steps for the database — FOUND

docs/DESIGN_DECISIONS.md:5243 — ASSERTION

```
Recovery procedure: Download the latest S3 snapshot, run PRAGMA integrity_check to validate database integrity,
replace local database file, re-apply the recorded erasures while the application is stopped (a replay that does
not complete leaves it stopped), restart application containers, verify health endpoints return OK. Target RTO
(Recovery Time Objective): ~5 minutes from failure detection to service restoration.
```

2. Where the system stores files, written restore steps for those files — FOUND

scripts/restore-bucket.sh:5-10 — ASSERTION

```
# Every main bucket that holds what members cannot re-create is versioned, and
# the photo and archive buckets are replicated to a -dr bucket in us-west-2.
# Neither protection returns anything by itself: an object lost from the main …
```

3. A way to redeploy a previous version, such as a rollback command or kept releases — FOUND

scripts/lib/production-release-gate.sh:209-210 — EXECUTABLE

```
    elif git -C "$root" merge-base --is-ancestor "$head" refs/remotes/origin/main </dev/null 2>/dev/null; then
      warnings+=("HEAD (${head:0:12}) is an earlier commit of main, not its tip (${main:0:12}); this deploy rolls
production back to it. ${PRODUCTION_STAGING_FIRST_REMINDER}")
```

4. A record of a restore actually performed, with its date — MISSING

Searched docs, scripts, ops and the other Markdown files for a dated record of a restore or drill, and for committed log files. Dates near the words restore or drill appear in test fixtures alone. scripts/production-readiness-sitting.sh writes its log to footbag_private_repo/cutover/CUTOVER_LOG.md, a private checkout absent from this tree.

Continued on page 33

CC7.5 Recovering from identified incidents, continued

5. The time that restore took, measured — MISSING

Looked for a written duration of a past restore. scripts/internal/restore-db-remote.sh prints the elapsed seconds of a drill to the terminal, and the readiness sitting log that might keep it sits in a private checkout outside this tree.

THE FIX

After each run of scripts/restore-db.sh --drill, save its closing summary with the date, the operator and the elapsed seconds to a file under docs or ops in this repository, and commit it.

Where this documentation is kept outside the code, include the folder that holds it when you start the next check with /ev-run. The check reads that folder as evidence, uses no extra pack credits, and counts each document it finds there.

CC8.1 Authorising, designing and implementing changes

Claude Opus 5.5 · verified — PARTIAL

What reviews and tests a change before production in this repository, covering tests on every pull request, failures that block, review by another person and deploys only after a merge to main?

CI runs the test suite on each pull request to main. Before a production deploy, scripts/lib/production-release-gate.sh checks that the commit sits on main and that the aggregate CI check passed. The committed GitHub ruleset in scripts/github-ruleset-protect-main.json requires a pull request, yet it sets zero required approvals and names no required status check. A red build can therefore merge, and an author can merge their own change. Three of five items hold, so this is Partial.

1. Tests run automatically on every pull request — FOUND

.github/workflows/ci.yml:3-9 — CONFIGURATION

```
on:
  push:
    branches: …
```

.github/workflows/ci.yml:248-252 — CONFIGURATION

```
      - name: Run the suite with coverage and enforce the thresholds
        # Without the one suite that drives the legacy club extractors through the
        # pipeline's Python environment, which the local bare run carries; the …
```

2. A failing test that stops the deploy — FOUND

scripts/lib/production-release-gate.sh:224-229 — EXECUTABLE

```
  if [[ -z "$runs" ]]; then
    blockers+=("the CI check \"${PRODUCTION_RELEASE_CI_CHECK}\" for ${head:0:12} could not be read (gh not signed
in, or no run for this commit, such as an unpushed one)")
  elif grep -qvxE 'success|in_progress' <<< "$runs"; then …
```

Continued on page 34

SECURITY, THE COMMON CRITERIA, CC8.1, CONTINUED

CC8.1 Authorising, designing and implementing changes, continued

3. A failing test that stops the merge — MISSING

Looked in scripts/github-ruleset-protect-main.json, scripts/github-ruleset.sh, the .github folder and the docs for a required status check on main. The ruleset holds deletion, non_fast_forward and pull_request rules, and the script header says it carries no required status check.

4. Review by someone other than the author required before merge — MISSING

Looked in scripts/github-ruleset-protect-main.json, for a CODEOWNERS file anywhere in the tree and in the docs for a review rule. The ruleset sets required_approving_review_count to 0 and require_code_owner_review to false, and the tree holds no CODEOWNERS file.

5. Deployment run only after a merge to the main branch — FOUND

scripts/lib/production-release-gate.sh:211-212 — EXECUTABLE

```
    else
      blockers+=("HEAD (${head:0:12}) is not on main (${main:0:12}); push the change to main, let CI pass, and deploy that commit")
```

THE FIX

In scripts/github-ruleset-protect-main.json, add a required_status_checks rule naming the "Type-check and test" check, and set required_approving_review_count to 1. Apply it with scripts/github-ruleset.sh --apply.

CC9.1 Mitigating risks from business disruption

Claude Opus 5.5 · verified — COVERED

What does this system do when something it depends on is unavailable, covering timeouts, limited retries or circuit breakers, stored data left unchanged and tests of a failing service?

Outbound calls carry deadlines, such as the 10 second budget in src/adapters/captchaAdapter.ts and the worker dispatch timeouts. The SQLite connection waits five seconds on a lock before failing. Captcha retries stop at three, and outbox retries stop at a configured cap with backoff. The membership checkout calls Stripe before any write and then writes the payment row and its audit row in one transaction. A route test fakes a captcha outage and checks that no session appears. Each item holds, so this is Covered.

1. Where the system calls outside services, timeouts set on those calls — FOUND

src/adapters/captchaAdapter.ts:138-139 — EXECUTABLE

```
      const controller = new AbortController();
      const deadline = setTimeout(() => controller.abort(), TOTAL_BUDGET_MS);
```

2. Timeouts set on calls to the database — FOUND

src/db/openDatabase.ts:27 — EXECUTABLE

```
  db.pragma('busy_timeout = 5000');
```

Continued on page 35

SECURITY, THE COMMON CRITERIA, CC9.1, CONTINUED

CC9.1 Mitigating risks from business disruption, continued

3. Retries on calls to outside services limited in number, such as a retry cap or a circuit breaker — FOUND

src/adapters/captchaAdapter.ts:43 — EXECUTABLE

```
const MAX_ATTEMPTS = 3;
```

src/services/communicationService.ts:1066-1068 — EXECUTABLE

```
            const nextRetryCount = row.retry_count + 1;
            if (nextRetryCount ≥ maxRetries) {
              outbox.markDeadLetter.run(message, new Date().toISOString(), row.id);
```

4. Stored data left unchanged by a failed outside call, such as by a transaction around the write — FOUND

src/services/paymentService.ts:1122-1125 — EXECUTABLE

```
  // The row and its audit row commit together: a failed audit write leaves no
  // pending row behind, so the retry opens a fresh checkout and records both.
  try { …
```

5. A test that simulates an outside service failing — FOUND

tests/integration/auth-captcha.routes.test.ts:268-275 — EXECUTABLE

```
  it('every gated form answers 503 with Retry-After and changes nothing', async () ⇒ {
    const { STUB_CAPTCHA_UNAVAILABLE_TOKEN } = await import('../../src/adapters/captchaAdapter');
    for (const { path, res } of await postEach(STUB_CAPTCHA_UNAVAILABLE_TOKEN)) { …
```

CC9.2 Managing vendor and business partner risk

answered from the pack — ORG-LEVEL

Where does this repository evidence the assessment and management of its vendors?

Managing vendor and business partner risk is about how the organisation runs. A repository doesn't record that, so the report marks it for the organisation to answer.

REASON THE CODE CAN'T ANSWER IT

Assessing a vendor, holding them to a contract and reviewing them periodically are commercial and legal activities. A repository can name what it depends on and can never evidence the diligence done on whoever supplies it.

Availability (3): G 0 | P 2 | C 1 | E 0 | O 0 | N 0 OPTIONAL

3 criteria assessed against this repository. Covered only where the customer's report includes availability.

A1.1 Capacity management

Claude Opus 5.5 · verified PARTIAL

How does this repository measure and limit what the system consumes, through resource limits, limits per caller, resource metrics, alerts on resource use and autoscaling?

docker/docker-compose.prod.yml caps the memory of each container. Login, registration and password reset use per-caller rate limits in src/services/identityAccessService.ts. The CloudWatch agent set up in scripts/internal/install-cwagent-remote.sh collects processor, memory and disk use, and CloudWatch alarms fire on high use once their switch is on. Production runs on one Lightsail instance in terraform/production/lightsail.tf with no scaling. Four of five items hold, so this is Partial.

1. Resource limits set in deployment configuration, such as memory or processor limits — FOUND

docker/docker-compose.prod.yml:223-232 — CONFIGURATION

```
    deploy:
      resources:
        limits: …
```

2. Limits on the work one caller can ask for, such as rate limits or quotas — FOUND

src/services/identityAccessService.ts:682 — EXECUTABLE

```
  const rl = rateLimitHit(`login:${normalized}:${ip}`, maxAttempts, windowMinutes, cooldownMinutes);
```

3. Metrics collected on resource use — FOUND

scripts/internal/install-cwagent-remote.sh:243-249 — EXECUTABLE

```
      "cpu": {
        "measurement": ["usage_active"],
        "totalcpu": true …
```

4. Alerts on resource use — FOUND

terraform/production/cloudwatch.tf:93-104 — CONFIGURATION

```
resource "aws_cloudwatch_metric_alarm" "high_cpu" {
  count                     = var.enable_cwagent_alarms ? 1 : 0
  alarm_name                = "${local.prefix}-high-cpu" …
```

5. Autoscaling configured — MISSING

Searched terraform/ and the compose files in docker/ for autoscaling, scaling policies, Lightsail load balancers, replicas or a second instance, and found none. Production defines one aws_lightsail_instance named web in terraform/production/lightsail.tf.

THE FIX

Write down in docs/DESIGN_DECISIONS.md the load at which the single Lightsail instance gets resized, and add a script under scripts that moves the instance to a larger bundle from a snapshot. Autoscaling would need the SQLite database moved off the host first.

AVAILABILITY, CONTINUED

A1.2 Backup, recovery and environmental protection

Claude Opus 5.5 · verified **COVERED**

What does this repository show about backing up its database and, where the system stores files, those files, the written restore steps, and how much data losing the host would cost?

A systemd timer in ops/systemd runs the SQLite backup every five minutes. Terraform in terraform/production/s3.tf copies the media bucket to a backup bucket in a second region. docs/DESIGN_DECISIONS.md gives the restore steps and says up to five minutes of data would go if the host failed. Each item holds, so this is Covered.

1. Database backups configured or scripted — FOUND

`ops/systemd/footbag-backup.timer:14-18` — CONFIGURATION

```
[Timer]
OnBootSec=2min
OnUnitActiveSec=5min …
```

2. Where the system stores files, backups of those files configured or scripted — FOUND

`terraform/production/s3.tf:243-251` — CONFIGURATION

```
  rule {
    id     = "replicate-all-to-media-dr"
    status = "Enabled" …
```

3. Written restore steps — FOUND

`docs/DESIGN_DECISIONS.md:5243` — ASSERTION

```
Recovery procedure: Download the latest S3 snapshot, run PRAGMA integrity_check to validate database integrity, replace local database file, re-apply the recorded erasures while the application is stopped (a replay that does not complete leaves it stopped), restart application containers, verify health endpoints return OK. Target RTO (Recovery Time Objective): ~5 minutes from failure detection to service restoration.
```

4. A written statement of what data would be lost if the host were gone, such as the backup interval — FOUND

`docs/DESIGN_DECISIONS.md:5257` — ASSERTION

```
- Data loss of up to 5 minutes if instance fails between backups.
```

A1.3 Testing recovery

Claude Opus 5.5 · verified **PARTIAL**

What record does this repository hold of a recovery actually performed, naming its date, who ran it and how long it took, and which script or job tests restoring a backup?

scripts/restore-db.sh --drill restores a snapshot into a scratch copy on the host, checks it, counts members and payments, prints the elapsed time and shreds the copy. Drill results go to a cutover log in a private checkout, so this tree holds no saved record of a drill with its date, operator or duration. One of four items holds, so this is Partial.

Continued on page 38

A1.3 Testing recovery, continued

1. A dated record of a restore or recovery test — MISSING

Searched docs, scripts, ops and the other Markdown files for a dated drill or restore record, and for committed log files. Dates beside the words restore or drill occur in test fixtures alone. scripts/production-readiness-sitting.sh writes its log to footbag_private_repo/cutover/CUTOVER_LOG.md, a private checkout absent from this tree.

2. The person who ran it, named in that record — MISSING

With no drill record in this tree, no record here names the person who ran a drill.

3. How long it took, stated in that record — MISSING

With no drill record in this tree, no record here states how long a drill took. scripts/internal/restore-db-remote.sh prints the elapsed seconds to the terminal and saves nothing in the repository.

4. A script or job that tests restoring a backup — FOUND

scripts/internal/restore-db-remote.sh:374-393 — EXECUTABLE

```
if [[ "$DRILL" == "1" ]]; then
  drill_row="$(sqlite3 -readonly "${work}/snapshot.db" "
    SELECT (SELECT COUNT(*) FROM members) || '|' …
```

THE FIX

Have scripts/restore-db.sh --drill append a line with the date, the operator, the snapshot key and the elapsed seconds to a drill log file in this repository, and commit that log after each drill.

Where this documentation is kept outside the code, include the folder that holds it when you start the next check with /ev-run. The check reads that folder as evidence, uses no extra pack credits, and counts each document it finds there.

Confidentiality (2): G 0 | P 1 | C 1 | E 0 | O 0 | N 0 OPTIONAL

2 criteria assessed against this repository. Covered only where the customer's report includes confidentiality.

C1.1 Identifying and protecting confidential information

Claude Opus 5.5 · verified — PARTIAL

How does this repository identify confidential data and protect it through encryption or a separate store, access checks, log redaction and keeping credentials out of the code?

docs/DATA_GOVERNANCE.md ranks member data into five sensitivity levels and sets stricter rules for birth date, contact fields and payment records. Passwords pass through argon2 hashing in src/lib/passwordHash.ts before storage. A role check in src/middleware/requireAdmin.ts guards the admin pages for payments and the audit log. Before logging, src/lib/redactTokenPaths.ts strips tokens and search terms from request URLs, and this run's secret scan found nothing. Birth date, contact fields and payment records sit in ordinary database columns without encryption or a separate store, so one of five checks

Continued on page 39

CONFIDENTIALITY, C1.1, CONTINUED

C1.1 Identifying and protecting confidential information, continued

fails and the entry reads as Partial.

1. A written list or classification of which data is confidential — FOUND

docs/DATA_GOVERNANCE.md:37-49 — ASSERTION

```
| Sensitivity | Label | Examples | Auth required |
|-------------|-------|----------|---------------|
| 1 | Public official historical record | Event results, year archives, HoF/BAP, world records, minimal
historical-person pages | None | …
```

2. Confidential fields protected apart from ordinary data, such as by encryption in the application or a separate store — MISSING

Searched src for encryption of member fields and found the word only in comments about encrypted ballots. Birth date, contact fields and payment records sit in ordinary database columns, guarded by access checks alone. Password hashing in src/lib/passwordHash.ts protects a sign-in secret and leaves the fields the governance document ranks highest unprotected.

3. A role or permission check guarding the fields or tables named as confidential — FOUND

src/middleware/requireAdmin.ts:9-14 — EXECUTABLE

```
export function requireAdmin(req: Request, res: Response, next: NextFunction): void {
  if (req.user?.role !== 'admin') {
    renderForbidden(res); …
```

src/routes/adminRoutes.ts:42 — EXECUTABLE

```
adminRouter.use(requireMember, requireAdmin);
```

4. Confidential values kept out of logs, such as by redaction — FOUND

src/lib/redactTokenPaths.ts:20-33 — EXECUTABLE

```
const PII_QUERY_PARAMS = ['q', 'key', 't'] as const;

export function redactTokenPaths(url: string): string { …
```

src/app.ts:594 — EXECUTABLE

```
        url: redactTokenPaths(req.url),
```

5. No credentials committed to the repository — SCANNED — FOUND

The secret scan ran over this repository and found nothing at any severity.

THE FIX

Encrypt birth date and contact fields in the application before they reach the database, with the key held in Parameter Store, or move them to a separate store with its own access rules.

CONFIDENTIALITY, CONTINUED

C1.2 Disposing of confidential information

Claude Opus 5.5 · verified **COVERED**

What sets a retention period for confidential data in this repository, and what deletes it when that period ends, when its account closes and from stored files where the system keeps them?

docs/DESIGN_DECISIONS.md sets retention periods, such as a 90 day grace after an account closes. A daily job in src/services/jobRegistry.ts runs the purge scan once that grace ends. The purge in src/services/memberService.ts clears contact data and free text and logs the erasure in one transaction. Account deletion in src/services/accountDeletionService.ts removes the member's stored photo files from S3. Each item holds, so this is Covered.

1. A written retention period for confidential data — FOUND

docs/DESIGN_DECISIONS.md:1111 — ASSERTION

```
Member personal data: retained for a configurable grace period (Administrator-configurable default 90 days, parameter key: member_cleanup_grace_days) after soft delete, then purged from primary storage. Purge sets credential and contact fields (email, phone, passwordHash) to NULL. For non-nullable identity/location columns retained for referential integrity, the application overwrites values with anonymized placeholders (not original data). Exception: members with HoF or BAP flags keep the record the honor publishes after purge: slug, `displayName`, `bio`, country, both archival identity links, and their claim on the legacy account. Credential and contact fields are still nulled, the legal name is still replaced with a placeholder, and other required retained identity/location fields are anonymized as needed. The member row is retained as an anonymized record for referential integrity and audit history.
```

2. A scheduled job or trigger that deletes it when that period ends — FOUND

src/services/jobRegistry.ts:110-114 — EXECUTABLE

```
  {
    name: 'SYS_Cleanup_Soft_Deleted_Records',
    cadence: { kind: 'daily' }, …
```

3. Deletion of it when the owning account is closed — FOUND

src/services/memberService.ts:1111-1161 — EXECUTABLE

```
  return transaction(() => {
    const res = memberPurge.purgeRow.run(
      preserveFlag, preserveFlag, preserveFlag, preserveFlag, …
```

4. Where the system stores files, deletion of confidential data that reaches those files — FOUND

src/services/accountDeletionService.ts:197-205 — EXECUTABLE

```
      const mediaRows = account.listOwnedMediaForDeletion.all(input.memberId) as DeletionMediaRow[];
      const deletedTagIds: string[] = [];
      let mediaDeleted = 0; …
```

Processing integrity (5): G 0 | P 0 | C 5 | E 0 | O 0 | N 0 OPTIONAL

5 criteria assessed against this repository. Covered only where the customer's report includes processing integrity.

PI1.1 Information about processing objectives

Claude Opus 5.5 · verified COVERED

What does this repository state each main process must produce? Which rules for a correct result are stated precisely enough to test, and which tests check them?

docs/USER_STORIES.md describes each main flow with success criteria, such as the Tier 1 membership purchase. That story states testable rules: the tier changes after a confirmed payment and stays put when payment fails. Integration tests such as tests/integration/paymentWebhook.state-machine.test.ts check the stored payment status and tier against expected values. Each item holds, so this is Covered.

1. A written description of what each main process produces, such as bookings, invoices or reports — FOUND

docs/USER_STORIES.md:1417 — ASSERTION

```
Story: As a Tier 0 Member, I can upgrade to Tier 1 IFPA Member lifetime membership by paying the configured Tier 1
price through Stripe Checkout so that my account reflects my lifetime IFPA membership.
```

2. Rules for a correct result stated precisely enough to test, such as calculations or allowed states — FOUND

docs/USER_STORIES.md:1421-1432 — ASSERTION

```
- Member must be logged in (Tier 0 members can purchase, visitors must register first).
- Member sees a clear "Upgrade to Tier 1" option from their account/dashboard when eligible.
- The configured Tier 1 price is shown beside that option, so the member knows the amount before being handed to
the payment page. …
```

3. Tests that check results against expected values — FOUND

tests/integration/paymentWebhook.state-machine.test.ts:195-203 — EXECUTABLE

```
      const payment = db2.prepare('SELECT status FROM payments WHERE id = ?').get(paymentId) as
        { status: string };
      expect(payment.status).toBe('succeeded'); …
```

PI1.2 Inputs are complete and accurate

Claude Opus 5.5 · verified COVERED

How does this repository validate input before acting on it, through schemas at the entry point, validation before any write, database constraints and tests of invalid input?

Each form's input passes through a hand-written validator in its service, such as validateRecordInput in src/services/freestyleRecordCurationService.ts. Club edits in src/services/clubService.ts collect field errors and throw before any write. database/schema.sql uses NOT NULL, UNIQUE and CHECK constraints, such as the allowed payment states. Route tests post bad input and expect a 422 with nothing written. Each item holds, so this is Covered. The validators live in the services with no shared schema library at the route.

Continued on page 42

PROCESSING INTEGRITY, PI1.2, CONTINUED

PI1.2 Inputs are complete and accurate, continued

1. Request bodies checked against a schema or validator at the entry point — FOUND

src/services/freestyleRecordCurationService.ts:576-584 — EXECUTABLE

```
function validateRecordInput(input: FreestyleRecordScalarInput, selfId: string): ValidatedRecord {
  const fieldErrors: Record<string, string> = {};
 …
```

2. Input validated before any write, such as a schema check ahead of the database call — FOUND

src/services/clubService.ts:3219-3220 — EXECUTABLE

```
    if (Object.keys(fieldErrors).length > 0) {
      throw new ValidationError('Please fix the errors below.', { fieldErrors });
```

3. Database constraints refusing invalid values, such as not-null, unique or check constraints — FOUND

database/schema.sql:1576-1577 — CONFIGURATION

```
  status TEXT NOT NULL
    CHECK (status IN ('pending','succeeded','failed','canceled','refunded')),
```

4. Tests that send invalid input and expect it refused — FOUND

tests/integration/admin-freestyle-edit.routes.test.ts:522-528 — EXECUTABLE

```
  it('rejects an empty canonical name with 422 and writes nothing', async () ⇒ {
    const before = trickRow('save_guard');
    const res = await post('/admin/freestyle/tricks/save_guard/edit', admin(), validBody({ canonicalName: '   '
}));  …
```

PI1.3 Processing is complete, accurate and timely

Claude Opus 5.5 · verified — COVERED

How does this repository keep a unit of work from being left half done, through transactions, limited job retries where the system runs background jobs, handlers safe to run twice and a record of failed jobs?

Writes that belong together go through the transaction helper in src/db/db.ts, as the payment row and its audit row do in src/services/paymentService.ts. Outbox sends retry with backoff up to a cap and then move to a dead letter state. Stripe checkout calls carry idempotency keys tied to the payment id. Failed sends keep their error and a scheduled retry time on the row. Each item holds, so this is Covered.

1. Writes to several records that make up one operation, such as an order and its payment, grouped in one database transaction — FOUND

src/services/paymentService.ts:1122-1157 — EXECUTABLE

```
  // The row and its audit row commit together: a failed audit write leaves no
  // pending row behind, so the retry opens a fresh checkout and records both.
  try { …
```

Continued on page 43

PI1.3 Processing is complete, accurate and timely, continued

2. Where the system runs background jobs, those jobs retried on failure, with a limit — FOUND

src/services/communicationService.ts:1066-1068 — EXECUTABLE

```
            const nextRetryCount = row.retry_count + 1;
            if (nextRetryCount ⩾ maxRetries) {
              outbox.markDeadLetter.run(message, new Date().toISOString(), row.id);
```

3. Handlers or jobs safe to run twice, such as by idempotency keys — FOUND

src/adapters/paymentAdapter.ts:1637-1643 — EXECUTABLE

```
        }, {
          // Keyed on the platform-side payment id, which is minted before this
          // call and is stable across any retry of it, so a retried create returns …
```

4. Where the system runs background jobs, a record of failed jobs that can be retried — FOUND

src/services/communicationService.ts:1081-1088 — EXECUTABLE

```
              const baseSeconds = readIntConfig('outbox_retry_base_seconds', 60);
              const delaySeconds = Math.min(baseSeconds * 2 ** row.retry_count, 3600);
              outbox.markFailedRetry.run( …
```

PI1.4 Outputs are delivered to the right place

Claude Opus 5.5 · verified — COVERED

How does this repository make sure results reach only the people they are meant for, through filtered queries, notices sent to the stored address, expiring links to private files and refusal tests?

The member data download reads rows for the signed-in member, and the owner pages check that the address in the link belongs to that member. Notices go to the email stored on the account, and the members-only legacy archive opens through signed cookies that expire with the session. An integration test asks for another member's download and expects a 404. All four checks hold, so this is Covered, and a missing refusal test would have made it Partial.

1. Queries returning records filtered by the signed-in user or tenant — FOUND

src/controllers/memberController.ts:152-155 — EXECUTABLE

```
  getDataExportDownload(req: Request, res: Response, next: NextFunction): void {
    if (!isOwnMemberRoute(req)) { renderNotFound(res); return; }
    try { …
```

src/lib/routeOwnership.ts:13-15 — EXECUTABLE

```
export function isOwnMemberRoute(req: Request): boolean {
  return req.user?.slug ⩵ req.params.memberKey;
}
```

Continued on page 44

PI1.4 Outputs are delivered to the right place, continued

2. Emails and notifications addressed to the address stored on the account — FOUND

src/services/emailService.ts:226-239 — EXECUTABLE

```
    const row = account.findNotificationContactById.get(input.memberId) as
      | { login_email: string | null }
      | undefined; …
```

3. Where the system serves private files, links to them that expire, such as signed links with an expiry time — FOUND

src/lib/sessionCookie.ts:72-89 — EXECUTABLE

```
  if (opts.archiveAccess && signer && config.archiveUrl) {
    const expiresEpochSeconds = Math.floor(
      (Date.now() + maxAgeMs) / 1000, …
```

src/adapters/mediaStorageAdapter.ts:275-283 — EXECUTABLE

```
    async generatePresignedGetUrl(
      key: string,
      expirationSeconds: number, …
```

4. A test that asks for another user's result and expects refusal — FOUND

tests/integration/member-data-export.routes.test.ts:109-115 — EXECUTABLE

```
  it('answers not-found when one member asks for another member's data', async () => {
    makeMember('exp_target');
    const nosy = makeMember('exp_nosy'); …
```

PI1.5 Stored inputs and outputs are retained completely

Claude Opus 5.5 · verified — COVERED

How does this repository keep stored data matching what it received, through length checks, integrity checks, read back tests, and documenting and reporting input it drops?

Profile edits refuse a bio, phone, WhatsApp number or city longer than its limit with an error. The backup script runs a database integrity check on each snapshot, and a test saves a city and reads the same value back. Registration folds a typed profile address and shows the member the changed form before creating anything, and a code comment records the 5000 row cap on each section of the data download. All five checks hold, so this is Covered. Two places shorten input without telling anyone: the data download drops rows past the cap with no notice to the member, and Stripe metadata values are cut at the provider's byte limit.

Continued on page 45

PROCESSING INTEGRITY, PI1.5, CONTINUED

PI1.5 Stored inputs and outputs are retained completely, continued

1. Input longer than its stored field allows refused with an error — FOUND

src/services/memberService.ts:1727-1735 — EXECUTABLE

```
    if (bio.length > MAX_BIO) {
      throw new ValidationError(`Bio must be ${MAX_BIO} characters or fewer.`);
    } …
```

tests/integration/member-location-rules.test.ts:175-181 — EXECUTABLE

```
  it('refuses an over-long city', async () => {
    const { id, slug } = seedMember({ country: 'United States', region: 'OR', city: 'Portland' });
    await expect( …
```

2. Stored data checked for integrity, such as by checksums or authenticated encryption — FOUND

scripts/backup-db.sh:150-151 — EXECUTABLE

```
integrity=$(sqlite3 "${SNAP}" "PRAGMA integrity_check;" 2>/dev/null || echo "unreadable")
[[ "${integrity}" == "ok" ]] || record_failure "snapshot integrity check failed: ${integrity}"
```

3. Tests that write a record and read it back unchanged — FOUND

tests/integration/member-location-rules.test.ts:183-188 — EXECUTABLE

```
  it('accepts a city at exactly the cap', async () => {
    const { id, slug } = seedMember({ country: 'United States', region: 'OR', city: 'Portland' });
    const atCap = 'Y'.repeat(64); …
```

4. Where the code drops or shortens input on purpose, that behaviour documented — FOUND

src/services/memberDataExportService.ts:56-60 — ASSERTION

```
/**
 * The ceiling on any one repeating section. A member's own data is small, so
 * this is a guard against a pathological row count rather than a page size. …
```

5. Where the code drops or shortens input on purpose, a warning returned to the caller — FOUND

src/services/identityAccessService.ts:1110-1120 — EXECUTABLE

```
  if (userProvidedSlug && trimmedSlug !== typedSlug.toLowerCase()) {
    // Every refusal comes before the notice, so a member is never asked to
    // confirm a URL the next submit would refuse. …
```

Privacy (18): G 2 | P 6 | C 6 | E 0 | O 3 | N 1 OPTIONAL

18 criteria assessed against this repository. Covered only where the customer's report includes privacy.

P1.1 Notice about personal information practices

Claude Opus 5.5 · verified **PARTIAL**

How does this repository tell people what personal data it collects and why, through a privacy notice linked where data is collected that names each kind and its purpose?

The Legal page carries a privacy section, and the footer of the main layout links to it from pages built on that layout, sign-up among them. Its list names name, email, password, location, bio, competition history and photos. It leaves out birth date, gender, phone, WhatsApp and payment records, though the platform stores them, and it gives a use for email and for the address Cloudflare sees and for nothing else. Two of four checks hold, so this is Partial, and Covered needs the full list with a use for each kind.

1. A privacy notice in the product or the repository — FOUND

src/services/legalService.ts:63-66 — ASSERTION

```
    {
      subheading: 'What we collect',
      body: prose( …
```

2. That notice shown or linked where personal data is collected, such as on sign-up or booking forms — FOUND

src/views/layouts/main.hbs:102-108 — EXECUTABLE

```
      <div class="footer-legal">
        <div class="footer-legal-links">
          <a href="/legal#privacy">Privacy</a> …
```

src/app.ts:322-328 — CONFIGURATION

```
  app.engine(
    'hbs',
    engine({ …
```

3. The notice naming the personal data collected — MISSING

Compared the paragraph on collected data in src/services/legalService.ts with the `members` table in database/schema.sql, and searched the templates for wording on birth date, phone and WhatsApp. The table holds `birth_date`, `gender`, `phone`, `whatsapp`, `street_address` and `postal_code`, and the notice names none of them.

4. The notice stating the purpose of each kind of personal data — MISSING

Read each paragraph of the privacy section in src/services/legalService.ts and searched the templates for purpose wording. The Email and Human verification paragraphs say what email and the IP address are for, and a hint on the onboarding form explains birth date. Name, location, bio, competition history, photos and the other stored fields carry no stated use in the notice.

THE FIX

Extend the privacy section in src/services/legalService.ts to name birth date, gender, phone, WhatsApp, payment records and donation comments, and add a line for each kind saying what the platform uses it for.

Where this documentation is kept outside the code, include the folder that holds it when you start the next check with /ev-run. The check reads that folder as evidence, uses no extra pack credits, and counts each document it finds there.

PRIVACY, CONTINUED

P2.1 Choice and consent

Claude Opus 5.5 · verified COVERED

Where the system relies on consent, how does this repository record consent with the time it was given, check it before processing that depends on it, and let a person withdraw it?

Announcement mail rests on the member's opt-in, held on a subscription row with its status and the time it changed. The audience query for a mailing reads that status before any message goes out. A member withdraws from the preferences screen, where setOwnSubscription runs `memberUnsubscribe`, or from a one-click link, where unsubscribeByToken runs `markUnsubscribed`. Both writes set the row to unsubscribed with a fresh time. All three checks hold, so this is Covered. A separate query, `upsertSubscribed`, puts a member on the admin alerts list when an administrator role is provisioned or granted, without a choice from the member.

1. Where the system relies on consent, code that records consent with the time it was given — FOUND

src/db/db.ts:9356-9368 — EXECUTABLE

```
  get memberSubscribe() { return db.prepare(`
    INSERT INTO mailing_list_subscriptions (
      id, created_at, created_by, updated_at, updated_by, version, …
```

2. Where the system relies on consent, processing that depends on it, such as marketing email, reading that record first — FOUND

src/db/db.ts:9232-9246 — EXECUTABLE

```
  get listActiveSubscribersBySlug() { return db.prepare(`
    SELECT
      s.member_id, …
```

3. Where the system relies on consent, a way to withdraw it that updates the record — FOUND

src/db/db.ts:9374-9380 — EXECUTABLE

```
  get memberUnsubscribe() { return db.prepare(`
    UPDATE mailing_list_subscriptions
    SET status = 'unsubscribed', status_updated_at = ?, …
```

src/services/emailSubscriptionService.ts:413 — EXECUTABLE

```
        : mailingListSubscriptions.memberUnsubscribe.run(nowIso, nowIso, memberId, slug, memberId);
```

src/db/db.ts:9209-9214 — EXECUTABLE

```
  get markUnsubscribed() { return db.prepare(`
    UPDATE mailing_list_subscriptions
    SET status = 'unsubscribed', status_updated_at = ?, …
```

src/services/emailSubscriptionService.ts:256-269 — EXECUTABLE

```
  unsubscribeByToken(token: string): UnsubscribeOutcome {
    const read = readUnsubscribeToken(token);
    if (!read) return { status: 'rejected' }; …
```

PRIVACY, CONTINUED

P3.1 Collecting personal information lawfully

Claude Opus 5.5 · verified **PARTIAL**

Which personal data does this repository list as collected, what purpose does it state for each kind, and do its forms and tables match that list?

The privacy section lists name, email, password, location, bio, competition history and photos, and docs/DATA_GOVERNANCE.md states purposes by category, covering memberships, events, payments, clubs, opt-in profile visibility and announcement mail. Beyond that list, the `members` table stores birth date, gender, phone, WhatsApp, street address and postcode, and the profile and onboarding forms collect several of these. Two of three checks hold, so this is Partial.

1. A written list of the personal data collected — FOUND

src/services/legalService.ts:63-66 — ASSERTION

```
    {
      subheading: 'What we collect',
      body: prose( …
```

2. A stated purpose for each kind on that list — FOUND

docs/DATA_GOVERNANCE.md:23-31 — ASSERTION

```
- **Lawful basis.** Account, membership, event and payment data are processed to perform the membership agreement; financial records are kept to meet legal obligations; official competition results are published in IFPA's legitimate interest in the sport's historical record; optional profile visibility and announcement mail rest on the member's own opt-in.
- **Purposes.** Running memberships, events, payments, clubs and member communications, and preserving the sport's official record. Data is not used for advertising, analytics or profiling, and member addresses are never shared or sold.
- **Processors.** Amazon Web Services hosts the platform, its storage and backups, and sends its email; Stripe processes payments, and card details never reach the platform; Cloudflare runs the human-verification check on sign-in and registration pages. Production member data stays in AWS, except the copies the design decisions admit once production is live: staging, and the developer machines invited to receive copies, which keep their disks encrypted. …
```

3. The forms and tables collecting personal data matching that list — MISSING

Compared the list in src/services/legalService.ts with the personal columns of `members` in database/schema.sql, the fields `postProfileEdit` reads in src/controllers/memberController.ts and the onboarding form in src/views/register/wizard/personal-details.hbs. Birth date, gender, phone and WhatsApp reach the table through those forms, and the list names none of them.

THE FIX

Bring the written list in src/services/legalService.ts and docs/DATA_GOVERNANCE.md into line with the `members` table, adding birth date, gender, phone, WhatsApp, street address and postcode with a purpose for each, or stop collecting a field the list leaves out.

PRIVACY, CONTINUED

P3.2 Explicit consent for sensitive information

Claude Opus 5.5 · verified GAP

How does this repository handle sensitive personal data such as health or biometrics, covering a written statement, explicit consent, protection apart from ordinary data and the same protection for free text fields?

The schema holds no health, biometric, religious or similar fields, so the three checks about handling sensitive data do not apply here. One check remains, asking for a written statement on whether sensitive data is collected, and docs/DATA_GOVERNANCE.md and the privacy section say nothing on it. With that single check missing, this is a Gap.

1. A written statement of whether sensitive data is collected — MISSING

Searched the whole repository for 'special category', 'health data', 'biometric' and 'Article 9', and the docs for 'sensitive'. The docs call birth date the most sensitive member field and say logs hold no sensitive personal data, and none of them says whether special category data such as health or biometrics is collected.

2. Where the system collects sensitive data, explicit consent recorded before it is collected — DOES NOT APPLY

Searched database/schema.sql for medical, disability, injury, ethnic, religious and fingerprint fields and found none, so the platform collects no sensitive data needing consent.

3. Where the system collects sensitive data, that data protected apart from ordinary data, such as by encryption or a separate store — DOES NOT APPLY

Searched database/schema.sql for medical, disability, injury, ethnic, religious and fingerprint fields and found none, so the platform holds no sensitive data to store apart.

4. Where the system collects sensitive data, free text fields such as notes or messages protected the same way as that data — DOES NOT APPLY

Searched database/schema.sql for medical, disability, injury, ethnic, religious and fingerprint fields and found none, so no sensitive data exists for free text fields to match.

THE FIX

Add a sentence to the privacy section in src/services/legalService.ts and to docs/DATA_GOVERNANCE.md stating that the platform collects no health, biometric or other special category data, and asking members to keep such details out of free text fields.

Where this documentation is kept outside the code, include the folder that holds it when you start the next check with /ev-run. The check reads that folder as evidence, uses no extra pack credits, and counts each document it finds there.

P4.1 Using personal information for stated purposes

Claude Opus 5.5 · verified COVERED

How does this repository keep personal data to its stated purposes, through a written statement of use, named fields sent to outside services and one data access module?

docs/DATA_GOVERNANCE.md states the purposes of account, membership, event and payment data and rules out advertising, analytics and profiling. The code calls no analytics, marketing or artificial intelligence service, so that check does not apply. Personal tables go through named statement groups in src/db/db.ts, such as `memberExport` and `account`. Both applicable checks hold, so this is Covered.

Continued on page 50

PRIVACY, P4.1, CONTINUED

P4.1 Using personal information for stated purposes, continued

1. A written statement of what each kind of personal data is used for — FOUND

docs/DATA_GOVERNANCE.md:23-31 — ASSERTION

```
- **Lawful basis.** Account, membership, event and payment data are processed to perform the membership agreement; financial records are kept to meet legal obligations; official competition results are published in IFPA's legitimate interest in the sport's historical record; optional profile visibility and announcement mail rest on the member's own opt-in.
- **Purposes.** Running memberships, events, payments, clubs and member communications, and preserving the sport's official record. Data is not used for advertising, analytics or profiling, and member addresses are never shared or sold.
- **Processors.** Amazon Web Services hosts the platform, its storage and backups, and sends its email; Stripe processes payments, and card details never reach the platform; Cloudflare runs the human-verification check on sign-in and registration pages. Production member data stays in AWS, except the copies the design decisions admit once production is live: staging, and the developer machines invited to receive copies, which keep their disks encrypted. …
```

2. Where the system sends personal data to analytics, marketing or artificial intelligence (AI) services, those fields limited to a named list — DOES NOT APPLY

Searched src for analytics, tag manager, marketing and artificial intelligence clients and found none. The privacy section states the site uses no third-party analytics.

3. A named data access module for personal data tables — FOUND

src/db/db.ts:10851-10865 — EXECUTABLE

```
export const memberExport = {
  get profile() { return db.prepare(`
    SELECT …
```

P4.2 Retaining personal information

Claude Opus 5.5 · verified — COVERED

How long does this repository keep personal data, and what job, trigger or log expiry deletes it when that period ends?

docs/DESIGN_DECISIONS.md sets a 90 day grace period after deletion before purge, with periods for unfinished accounts, audit rows and logs. A daily job, `runPiiPurgeScan`, purges each soft-deleted account past that grace period. The Terraform log groups expire application logs after 90 days and nginx logs after 30. All three checks hold, so this is Covered.

Continued on page 51

PRIVACY, P4.2, CONTINUED

P4.2 Retaining personal information, continued

1. A written retention period for personal data — FOUND

docs/DESIGN_DECISIONS.md:1111 — ASSERTION

Member personal data: retained for a configurable grace period (Administrator-configurable default 90 days, parameter key: member_cleanup_grace_days) after soft delete, then purged from primary storage. Purge sets credential and contact fields (email, phone, passwordHash) to NULL. For non-nullable identity/location columns retained for referential integrity, the application overwrites values with anonymized placeholders (not original data). Exception: members with HoF or BAP flags keep the record the honor publishes after purge: slug, `displayName`, `bio`, country, both archival identity links, and their claim on the legacy account. Credential and contact fields are still nulled, the legal name is still replaced with a placeholder, and other required retained identity/location fields are anonymized as needed. The member row is retained as an anonymized record for referential integrity and audit history.

2. A job or trigger that deletes personal data when that period ends — FOUND

src/services/operationsPlatformService.ts:743-758 — EXECUTABLE

```
  async runPiiPurgeScan(opts: { now?: Date } = {}): Promise<PiiPurgeScanResult> {
    return this.recordJobRun('SYS_Cleanup_Soft_Deleted_Records', () => {
      const now = opts.now ?? new Date(); …
```

3. Logs holding personal data expiring after a set time — FOUND

terraform/production/cloudwatch.tf:10-18 — CONFIGURATION

```
resource "aws_cloudwatch_log_group" "app" {
  name              = "/footbag/${var.environment}/app"
  retention_in_days = 90 …
```

P4.3 Disposing of personal information

Claude Opus 5.5 · verified — PARTIAL

How does this repository delete one person's account and data from related tables, and from stored files, caches, search indexes and outside services where the system uses them, and how long do backups keep it?

A member deletes their account from their own tools, and the service removes their photos from storage. After the grace period the purge clears the member row and deletes or scrubs subscriptions, anchors, messages, outbox copies and notes. A written statement gives backup windows of two, thirty and four hundred days. Member photos sit in the CloudFront edge cache for up to a week by default, and deletion sends that cache nothing. Stripe holds a customer record for donors, and the purge clears the local customer id without asking Stripe to erase the customer. Four of the six checks that apply hold, so this is Partial.

Continued on page 52

P4.3 Disposing of personal information, continued

1. Code that deletes a person's account and records on request — FOUND

src/services/accountDeletionService.ts:256-258 — EXECUTABLE

```
        const res = account.softDeleteMember.run(
          nowIso, actorId, nowIso, graceExpiresAt, nowIso, byAdmin ? actorId : 'member', input.memberId,
        );
```

src/controllers/memberController.ts:186-190 — EXECUTABLE

```
    try {
      const result = await getDefaultAccountDeletionService().requestAccountDeletion({
        memberId: req.user!.userId, …
```

2. That deletion reaching related tables — FOUND

src/services/memberService.ts:1129-1139 — EXECUTABLE

```
    const anchors = declaredAnchors.deleteAllForMember.run(memberId);
    // Their mailing-list subscriptions, bounce and complaint state included, are
    // personal data with nothing a record needs to keep, so the rows go. …
```

3. Where the system stores files, that deletion reaching those files — FOUND

src/services/accountDeletionService.ts:200-205 — EXECUTABLE

```
      for (const item of mediaRows) {
        const keys = [item.s3_key_thumb, item.s3_key_display].filter((k): k is string => Boolean(k));
        try { …
```

4. Where the system caches personal data, that deletion clearing the person's entries from caches — MISSING

Read the media cache policy in terraform/production/cloudfront.tf. It keeps member photos under `/media-store/*` at the edge for 7 days by default and up to a year. Searched the whole repository for CloudFront invalidation and found it in scripts/publish-archive.sh for the legacy archive alone, with nothing in the deletion or purge code.

5. Where the system keeps search indexes, that deletion removing the person's data from them — DOES NOT APPLY

Searched src and database for full text tables and search engines and found none. Member search runs as plain queries on the live tables, so purging the rows removes the person from search.

6. Where the system sends personal data to outside services, that deletion asking each of them to delete its copy, such as a call to its deletion interface — MISSING

Read `requestAccountDeletion` and `purgeAccountPII`, and searched the whole repository for Stripe customer deletion and SES suppression removal. Deletion cancels recurring gifts at Stripe and the purge sets `stripe_customer_id` to NULL locally, and nothing asks Stripe, SES or Cloudflare to drop their copies. The SES suppression call serves a member's own bounce recovery.

Continued on page 53

P4.3 Disposing of personal information, continued

7. A written statement of how long backups keep deleted data — FOUND

docs/DESIGN_DECISIONS.md:5273 — ASSERTION

```
Backup retention windows support data deletion policy. On the primary snapshot bucket the recovery window is set by the per-generation lifecycle rules: in production, two days of the fine-grained stream, thirty days of the hourly generation, four hundred days of the daily one; staging keeps deliberately shorter windows. The Object Lock retention on the cross-region disaster-recovery bucket is 90 days, set in Terraform beside the bucket it governs rather than in the configuration store, because nothing in the application reads or changes it.
```

docs/DATA_GOVERNANCE.md:23-31 — ASSERTION

```
- **Lawful basis.** Account, membership, event and payment data are processed to perform the membership agreement; financial records are kept to meet legal obligations; official competition results are published in IFPA's legitimate interest in the sport's historical record; optional profile visibility and announcement mail rest on the member's own opt-in.
- **Purposes.** Running memberships, events, payments, clubs and member communications, and preserving the sport's official record. Data is not used for advertising, analytics or profiling, and member addresses are never shared or sold.
- **Processors.** Amazon Web Services hosts the platform, its storage and backups, and sends its email; Stripe processes payments, and card details never reach the platform; Cloudflare runs the human-verification check on sign-in and registration pages. Production member data stays in AWS, except the copies the design decisions admit once production is live: staging, and the developer machines invited to receive copies, which keep their disks encrypted. …
```

THE FIX

Add a CloudFront invalidation for each deleted photo path to `requestAccountDeletion` in src/services/accountDeletionService.ts. In `purgeAccountPII` in src/services/memberService.ts, ask Stripe to delete the member's customer record and remove their address from the SES suppression list, where the law on financial records allows.

P5.1 Access to personal information by its subject

Claude Opus 5.5 · verified — PARTIAL

How can a person export their own data from this system while signed in as themselves, with their records from each table that holds them?

A signed-in member downloads a JSON file of their own data from their profile, and the route answers 404 to anyone else. The file carries the member row, clubs, registrations, media, payments, subscriptions and more. It leaves out tables the purge treats as the member's own, such as their questions and answers with administrators, their reports on media, their club notes and their contact requests. Two of three checks hold, so this is Partial.

1. A feature or endpoint that exports a person's own data — FOUND

src/services/memberDataExportService.ts:173-180 — EXECUTABLE

```
  getExportBody(memberId: string): { contentType: string; filename: string; body: string; truncated: boolean } {
    const { document, truncated } = this.buildExport(memberId);
    return { …
```

Continued on page 54

PRIVACY, P5.1, CONTINUED

P5.1 Access to personal information by its subject, continued

2. The export requiring the person to be signed in as themselves — FOUND

src/controllers/memberController.ts:152-155 — EXECUTABLE

```
  getDataExportDownload(req: Request, res: Response, next: NextFunction): void {
    if (!isOwnMemberRoute(req)) { renderNotFound(res); return; }
    try { …
```

3. The export including their records from each table that holds them — MISSING

Read every query in the `memberExport` group in src/db/db.ts and the other reads `buildExport` makes, and compared them with the tables `purgeAccountPII` in src/services/memberService.ts scrubs as the member's own words. Member messages, media flags, club insight notes and work queue contact text appear in the purge and nowhere in the export.

THE FIX

Add sections to `buildExport` in src/services/memberDataExportService.ts for the member's own rows in member messages, media flags, club insight notes and work queue contact requests, keyed on the member id like the existing sections.

P5.2 Correcting personal information

Claude Opus 5.5 · verified — COVERED

How can a person correct their own data in this system while signed in as themselves, and, where the system holds copies elsewhere, does the correction reach them?

A member edits bio, location, phone, WhatsApp, birth date, gender, links and visibility settings on their own edit page. The route answers 404 to a session for another member, and a test checks that refusal. Those fields live on the member row and its links table with no copy kept elsewhere, so the copies check does not apply. Both applicable checks hold, so this is Covered.

1. A feature or endpoint for a person to edit their own personal data — FOUND

src/controllers/memberController.ts:250-253 — EXECUTABLE

```
        links,
      };
      try { …
```

2. Edits requiring the person to be signed in as themselves — FOUND

src/controllers/memberController.ts:217-221 — EXECUTABLE

```
  async postProfileEdit(req: Request, res: Response, next: NextFunction): Promise<void> {
    if (!isOwnMemberRoute(req)) {
      renderNotFound(res); …
```

tests/integration/member.routes.test.ts:459-467 — EXECUTABLE

```
  it("another member's profile edit → 404 (cross-member write guard)", async () => {
    const app = createApp();
    const res = await request(app) …
```

Continued on page 55

P5.2 Correcting personal information, continued

3. Where the system holds copies of personal data elsewhere, a corrected value updating those copies, such as in outside services or copied fields	DOES NOT APPLY

The edited fields sit in `members` and `member_links` alone. Stripe receives a member id and payment id from the platform and no profile field, so no outside copy needs correcting.

P6.1 Disclosing personal information to third parties

Claude Opus 5.5 · verified — COVERED

Where does this repository send personal data to outside services? Which fields does it send, and is each destination on a written list?

docs/DATA_GOVERNANCE.md names Amazon Web Services, Stripe and Cloudflare as the services that receive personal data. In code, Stripe checkout gets a named payment id, member id and optional donation comment, and Cloudflare Turnstile gets the challenge token and the visitor's IP address. Amazon's mail service gets the recipient address. Each destination appears on the written list, so all three checks hold and this is Covered.

1. A written list of outside services that receive personal data	FOUND

docs/DATA_GOVERNANCE.md:23-31 — ASSERTION

```
- **Lawful basis.** Account, membership, event and payment data are processed to perform the membership agreement; financial records are kept to meet legal obligations; official competition results are published in IFPA's legitimate interest in the sport's historical record; optional profile visibility and announcement mail rest on the member's own opt-in.
- **Purposes.** Running memberships, events, payments, clubs and member communications, and preserving the sport's official record. Data is not used for advertising, analytics or profiling, and member addresses are never shared or sold.
- **Processors.** Amazon Web Services hosts the platform, its storage and backups, and sends its email; Stripe processes payments, and card details never reach the platform; Cloudflare runs the human-verification check on sign-in and registration pages. Production member data stays in AWS, except the copies the design decisions admit once production is live: staging, and the developer machines invited to receive copies, which keep their disks encrypted. …
```

2. Where the system sends personal data to outside services, the fields sent named in code	FOUND

src/adapters/paymentAdapter.ts:1609-1613 — EXECUTABLE

```
        const metadata = truncateMetadataValues({
          ...(opts.metadata ?? {}),
          paymentId: opts.paymentId, …
```

src/adapters/captchaAdapter.ts:133-136 — EXECUTABLE

```
      const form = new URLSearchParams();
      form.set('secret', secret);
      form.set('response', token); …
```

Continued on page 56

PRIVACY, P6.1, CONTINUED

P6.1 Disclosing personal information to third parties, continued

3. Where the system sends personal data to outside services, each destination in the code appearing on the written list — FOUND

src/adapters/captchaAdapter.ts:33-34 — EXECUTABLE

```
const TURNSTILE_SITEVERIFY_ENDPOINT =
  'https://challenges.cloudflare.com/turnstile/v0/siteverify';
```

docs/DATA_GOVERNANCE.md:23-31 — ASSERTION

```
- **Lawful basis.** Account, membership, event and payment data are processed to perform the membership agreement; financial records are kept to meet legal obligations; official competition results are published in IFPA's legitimate interest in the sport's historical record; optional profile visibility and announcement mail rest on the member's own opt-in.
- **Purposes.** Running memberships, events, payments, clubs and member communications, and preserving the sport's official record. Data is not used for advertising, analytics or profiling, and member addresses are never shared or sold.
- **Processors.** Amazon Web Services hosts the platform, its storage and backups, and sends its email; Stripe processes payments, and card details never reach the platform; Cloudflare runs the human-verification check on sign-in and registration pages. Production member data stays in AWS, except the copies the design decisions admit once production is live: staging, and the developer machines invited to receive copies, which keep their disks encrypted. …
```

P6.2 Recording authorised disclosures

Claude Opus 5.5 · verified — NOT APPLICABLE

What record does this repository keep when personal data is disclosed to an outside organisation, naming whose data, the recipient and the time, and can it be retrieved for one person?

Personal data leaves the platform for Amazon Web Services, Stripe and Cloudflare, each acting for IFPA as a processor. The code hands member data to no independent organisation, and docs/DATA_GOVERNANCE.md states member addresses are never shared or sold. Each check here concerns disclosures to outside organisations, so none applies and this is Not applicable. Should IFPA start sharing data with a partner, this entry would apply in full.

1. Where the system discloses personal data to outside organisations, a disclosure log entry written when personal data is sent to an outside organisation — DOES NOT APPLY

The code sends personal data to processors acting for IFPA, namely Amazon Web Services, Stripe and Cloudflare, and to no independent organisation, so no disclosure log is owed.

2. Where the system discloses personal data to outside organisations, the person whose data was disclosed named in that record — DOES NOT APPLY

The code sends personal data to processors acting for IFPA, namely Amazon Web Services, Stripe and Cloudflare, and to no independent organisation, so no disclosure record names a person.

3. Where the system discloses personal data to outside organisations, the recipient named in that record — DOES NOT APPLY

The code sends personal data to processors acting for IFPA, namely Amazon Web Services, Stripe and Cloudflare, and to no independent organisation, so no disclosure record names a recipient.

Continued on page 57

PRIVACY, P6.2, CONTINUED

P6.2 Recording authorised disclosures, continued

4. Where the system discloses personal data to outside organisations, the time held in that record — DOES NOT APPLY

The code sends personal data to processors acting for IFPA, namely Amazon Web Services, Stripe and Cloudflare, and to no independent organisation, so no disclosure record holds a time.

5. Where the system discloses personal data to outside organisations, those records retrievable for one person, by a query, a script or a feature — DOES NOT APPLY

The code sends personal data to processors acting for IFPA, namely Amazon Web Services, Stripe and Cloudflare, and to no independent organisation, so there are no disclosure records to retrieve.

THE FIX

Before any feature shares member data with an outside organisation, add a disclosure table naming the member, the recipient and the time, with a lookup by member.

P6.3 Recording unauthorised disclosures

Claude Opus 5.5 · verified — PARTIAL

What would detect and raise an unintended disclosure of personal data, covering logged reads, alerts on bulk access, written reporting steps and scans of logs or exports for personal data?

Refused rate-limited attempts, member search among them, feed an alarm that fires on bursts, and docs/DATA_GOVERNANCE.md sets out who hears of a suspected exposure. A check in the legacy archive pipeline scans files before publication for member rosters and phone numbers. Reads of member records leave no trace, since the administrator member service writes nothing when a record is opened. Three of four checks hold, so this is Partial.

1. Access to personal data logged, naming who read it — MISSING

Searched src for audit actions recording a view, read, access or export, for log lines on member profile or roster reads, and read the header of src/services/adminMemberService.ts. It states that reading a record writes nothing, and the debug request log in src/app.ts records method and path with no reader.

2. Alerts on unusual access, such as bulk reads or exports — FOUND

terraform/production/monitoring.tf:218-244 — CONFIGURATION

```
resource "aws_cloudwatch_log_metric_filter" "rate_limit_refused" {
  name           = "${local.prefix}-rate-limit-refused"
  log_group_name = aws_cloudwatch_log_group.app.name …
```

src/services/memberService.ts:2076-2079 — EXECUTABLE

```
    const windowMinutes = readIntConfig('member_search_rate_limit_window_minutes', 1);
    const ipRl = rateLimitHit(`member-search-ip:${ctx.ip}`, readIntConfig('member_search_rate_limit_max_per_ip',
60), windowMinutes);
    const memberRl = ipRl.allowed …
```

Continued on page 58

P6.3 Recording unauthorised disclosures, continued

3. Written steps for recording and raising a suspected disclosure — FOUND

docs/DATA_GOVERNANCE.md:23-31 — ASSERTION

```
- **Lawful basis.** Account, membership, event and payment data are processed to perform the membership agreement; financial records are kept to meet legal obligations; official competition results are published in IFPA's legitimate interest in the sport's historical record; optional profile visibility and announcement mail rest on the member's own opt-in.
- **Purposes.** Running memberships, events, payments, clubs and member communications, and preserving the sport's official record. Data is not used for advertising, analytics or profiling, and member addresses are never shared or sold.
- **Processors.** Amazon Web Services hosts the platform, its storage and backups, and sends its email; Stripe processes payments, and card details never reach the platform; Cloudflare runs the human-verification check on sign-in and registration pages. Production member data stays in AWS, except the copies the design decisions admit once production is live: staging, and the developer machines invited to receive copies, which keep their disks encrypted. …
```

4. A scan of logs or exports for personal data, such as a check for email addresses or card numbers in log output — FOUND

legacy_data/legacy_mirror/scripts/fetch_group_files.py:127-142 — EXECUTABLE

```
def looks_like_member_roster(body, rel):
    """A content-level catch the scope and committee metadata cannot see.
 …
```

THE FIX

Write an audit row naming the administrator and the member each time an administrator opens a member record or roster export.

P6.4 Third parties' commitments to privacy

answered from the pack — ORG-LEVEL

Where does this repository evidence that its third parties are bound to equivalent privacy obligations?

Third parties' commitments to privacy is about how the organisation runs. A repository doesn't record that, so the report marks it for the organisation to answer.

REASON THE CODE CAN'T ANSWER IT

What a third party has committed to is settled in a contract between two organisations. A repository can show what it sends where, and never what the receiver undertook.

PRIVACY, CONTINUED

P6.5 Notification of third-party breaches

answered from the pack ORG-LEVEL

Where does this repository evidence that it is told when a third party suffers a breach?

Notification of third-party breaches is about how the organisation runs. A repository doesn't record that, so the report marks it for the organisation to answer.

REASON THE CODE CAN'T ANSWER IT

Being notified of somebody else's breach depends on their obligation to notify and on a relationship between two organisations, neither of which a codebase carries.

P6.6 Notifying affected people of a breach

Claude Opus 5.5 · verified PARTIAL

How would this repository find whose data an incident affected, list those people with their contact details, and follow written steps to notify them?

The audit ledger ties each change to the member it concerns, yet reads of member records leave no row, so nobody could trace an incident involving reads to the people affected. Mailing queries list the addresses on one mailing list or for one event, and no script lists the contact details of everyone in a named table. docs/DATA_GOVERNANCE.md sets out who decides on notifying affected members and the deadline. One of three checks holds, so this is Partial.

1. Records or logs tying each access to or change of personal data to the person it belongs to — MISSING

Read the audit writes in the deletion and purge paths, searched src for logged reads of member data, and read the header of src/services/adminMemberService.ts. Changes write audit rows naming the member, and opening a record writes nothing, so access leaves no record.

2. A query or script that lists the contact details of every person whose data sits in a named table or tenant — MISSING

Searched scripts for queries selecting `login_email`, and src for CSV and contact exports. Found diagnostics, a linking audit, an audit log CSV and mailing queries for one list or one event. None lists contact details for everyone in a named table.

3. Written steps for notifying affected people — FOUND

docs/DATA_GOVERNANCE.md:23-31 — ASSERTION

```
- **Lawful basis.** Account, membership, event and payment data are processed to perform the membership agreement; financial records are kept to meet legal obligations; official competition results are published in IFPA's legitimate interest in the sport's historical record; optional profile visibility and announcement mail rest on the member's own opt-in.
- **Purposes.** Running memberships, events, payments, clubs and member communications, and preserving the sport's official record. Data is not used for advertising, analytics or profiling, and member addresses are never shared or sold.
- **Processors.** Amazon Web Services hosts the platform, its storage and backups, and sends its email; Stripe processes payments, and card details never reach the platform; Cloudflare runs the human-verification check on sign-in and registration pages. Production member data stays in AWS, except the copies the design decisions admit once production is live: staging, and the developer machines invited to receive copies, which keep their disks encrypted. …
```

THE FIX

Record administrator reads of member records in the audit ledger. Add a script under scripts/ that takes a table name and prints the id, name and login email of each member with rows in it.

PRIVACY, CONTINUED

P6.7 Accounting for disclosures on request

Claude Opus 5.5 · verified GAP

How could this repository list, for one person, every disclosure of their data, and which outside services receive personal data by default?

docs/DATA_GOVERNANCE.md lists Amazon Web Services, Stripe and Cloudflare as the services receiving personal data. src/lib/externalUrlValidator.ts also sends the links members submit, such as a personal site, to Google Safe Browsing, and the list leaves Google out. Staging runs that check live, and production turns it on through the url_screening_armed setting. Each outside service performs a task for the platform, so the two checks about disclosure records do not apply. The one applicable check fails, so the entry reads as Gap.

1. Where the system discloses personal data to outside organisations, records of each disclosure naming the person whose data was sent — DOES NOT APPLY

Each outside service the code sends personal data to performs a task for the platform: hosting and email, payments, the human-verification check and the link check. The code holds no feature that hands member data to another organisation for that organisation's own use.

2. Where the system discloses personal data to outside organisations, a query, script or feature listing those records for one person — DOES NOT APPLY

Each outside service the code sends personal data to performs a task for the platform: hosting and email, payments, the human-verification check and the link check. With no disclosures to an organisation acting for itself, there are no disclosure records to list.

3. A written list of outside services that receive personal data by default — MISSING

Read the processors line in docs/DATA_GOVERNANCE.md lines 23 to 31 and searched the document for Google, finding nothing. src/lib/externalUrlValidator.ts line 103 passes each member-submitted link to the Safe Browsing adapter, and src/adapters/safeBrowsingAdapter.ts posts it to safebrowsing.googleapis.com, so the written list misses one service.

THE FIX

Add Google Safe Browsing to the processors line of docs/DATA_GOVERNANCE.md, saying it receives the links members put on their profiles and other forms.

Where this documentation is kept outside the code, include the folder that holds it when you start the next check with /ev-run. The check reads that folder as evidence, uses no extra pack credits, and counts each document it finds there.

P7.1 Accuracy and completeness of personal information

Claude Opus 5.5 · verified COVERED

How does this repository check personal data when it is entered, through format checks and, where it relies on a contact address, verification, and let a person fix it afterwards?

The profile form refuses a WhatsApp number that does not reduce to seven to fifteen digits. A new account cannot sign in until the member opens the verification link sent to the address, and mailings skip unverified addresses. The member can review and fix their profile on their own edit page. All three checks hold, so this is Covered.

Continued on page 61

P7.1 Accuracy and completeness of personal information, continued

1. Format checks on personal fields such as email address or phone number — FOUND

src/services/memberService.ts:1754-1756 — EXECUTABLE

```
    if (whatsapp && whatsappDigits(whatsapp) === null) {
      throw new ValidationError(WHATSAPP_MESSAGE);
    }
```

2. Where the system relies on a contact address, that address verified before it is relied on, such as by an emailed or texted code — FOUND

src/db/db.ts:4500-4514 — EXECUTABLE

```
  get findMemberByEmail() { return db.prepare(`
    SELECT
      m.id, …
```

src/services/identityAccessService.ts:1322-1332 — EXECUTABLE

```
  const consumed = transaction(() => {
    const c = accountTokenService.consumeIfUnusedInTx(rawToken, 'email_verify');
    if (!c) return null; …
```

3. A way for the person to review and fix their data after entry — FOUND

src/controllers/memberController.ts:250-253 — EXECUTABLE

```
        links,
      };
      try { …
```

P8.1 Handling privacy complaints and disputes

answered from the pack — ORG-LEVEL

Where does this repository evidence a process for receiving and resolving privacy complaints?

Handling privacy complaints and disputes is about how the organisation runs. A repository doesn't record that, so the report marks it for the organisation to answer.

REASON THE CODE CAN'T ANSWER IT

Receiving a complaint, investigating it and answering the person are activities carried out by people against a published process. Nothing in a codebase evidences that they happen.

Scanner results (19)

Each card is a package or rule the scanners flagged, most severe first. An item counts only the severities it names, so a card can bear on an item without changing its result.

pillow **106 advisories in versions 10.3.0 and 12.2.0, dependency advisories** Bears on CC7.1 CRITICAL

Installed: 10.3.0, the repository's own dependency · 12.2.0, the repository's own dependency

RISK IF LEFT

A crafted input can make the software write outside its memory and let an attacker run code.

An attacker can run operating system commands on the server.

A crafted input can make the software read memory it shouldn't, leaking data or crashing it.

A crafted input can send the code into a loop it never leaves, stalling the service.

A missing value can crash the software.

A crafted input can make the software reserve a huge amount of memory and stop the service.

A crafted request can use enough resources to slow or stop the service.

Nothing limits how much a request can allocate, so a crafted one can exhaust memory and stop the service.

The code uses memory after freeing it, so it can crash or let an attacker run code.

A crafted input can make an algorithm run far longer than expected, slowing or stopping the service.

A number can overflow and corrupt memory or get past a size check.

A crafted input can make a pattern match run for a very long time, stalling the service.

THE FIX

Bring both copies of pillow, 10.3.0 and 12.2.0, up to 13.0.0 to fix all 106. Upgrade the repository's own copy, 10.3.0. Moving from 10.3.0 to 13.0.0 is a breaking step under semantic versioning, so check the release notes before shipping it. Upgrade the repository's own copy, 12.2.0. Moving from 12.2.0 to 13.0.0 is a breaking step under semantic versioning, so check the release notes before shipping it.

CVE-2026-112393, in 10.3.0, fixed in 13.0.0 CRITICAL

pillow: Heap buffer overflow in _tiffWriteProc when saving TIFF to BytesIO. Pillow is a Python imaging library. From 2.0.0 until 13.0.0, Pillow has a heap buffer overflow and stale-heap disclosure in tiffWriteProc when saving compressed TIFF data through libtiff to a target without a usable fileno(), such as BytesIO.

CVE-2026-112393, in 12.2.0, fixed in 13.0.0 CRITICAL

pillow: Heap buffer overflow in _tiffWriteProc when saving TIFF to BytesIO. Pillow is a Python imaging library. From 2.0.0 until 13.0.0, Pillow has a heap buffer overflow and stale-heap disclosure in tiffWriteProc when saving compressed TIFF data through libtiff to a target without a usable fileno(), such as BytesIO.

CVE-2026-112398, in 10.3.0, fixed in 13.0.0 CRITICAL

pillow: Heap buffer overflow in FlashPix (FPX) JPEG decoding leads to code execution. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's FlashPix JPEG-tile decoder can write decoded scanlines beyond the allocated tile buffer.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112398, in 12.2.0, fixed in 13.0.0 — CRITICAL

pillow: Heap buffer overflow in FlashPix (FPX) JPEG decoding leads to code execution. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's FlashPix JPEG-tile decoder can write decoded scanlines beyond the allocated tile buffer.

CVE-2026-112403, in 10.3.0, fixed in 13.0.0 — CRITICAL

pillow: Heap buffer overflow in ImagingJpegDecode. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's JPEG decoder can write a full-width scanline into a buffer sized for a requested draft scale.

CVE-2026-112403, in 12.2.0, fixed in 13.0.0 — CRITICAL

pillow: Heap buffer overflow in ImagingJpegDecode. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's JPEG decoder can write a full-width scanline into a buffer sized for a requested draft scale.

CVE-2026-112900, in 10.3.0, fixed in 13.0.0 — CRITICAL

pillow: Argument Injection in Ghostscript call, potentially leading into RCE. Pillow is a Python imaging library. From 2.6.0 until 13.0.0, Pillow is vulnerable to argument injection when invoking Ghostscript for EPS input.

CVE-2026-112900, in 12.2.0, fixed in 13.0.0 — CRITICAL

pillow: Argument Injection in Ghostscript call, potentially leading into RCE. Pillow is a Python imaging library. From 2.6.0 until 13.0.0, Pillow is vulnerable to argument injection when invoking Ghostscript for EPS input.

CVE-2026-96639, in 12.2.0, fixed in 13.0.0 — CRITICAL

pillow: Pillow multi-frame loaders can reuse stale native image storage after mode transitions. Pillow is a Python imaging library. From 11.0.0 until 13.0.0, multi-frame loaders can retain an ImagingCore allocation created for a narrow frame mode while a later frame of the same dimensions changes the logical mode and decoder tiles to wider RGB or CMYK data.

CVE-2026-112390, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via infinite loop during crafted MIC image parsing. Pillow is a Python imaging library. From 7.2.0 until 13.0.0, Pillow can enter an infinite loop while determining the frame count of a MIC image.

CVE-2026-112390, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via infinite loop during crafted MIC image parsing. Pillow is a Python imaging library. From 7.2.0 until 13.0.0, Pillow can enter an infinite loop while determining the frame count of a MIC image.

CVE-2026-112392, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via zero-size images in rank filters. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's rank-based filters can dereference invalid image storage for a zero-size image.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112392, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via zero-size images in rank filters. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's rank-based filters can dereference invalid image storage for a zero-size image.

CVE-2026-112397, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via out-of-bounds memory access on zero-width images. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's ImageMorph.MorphOp.apply() can access memory before a row buffer for a zero-width image. PPM and PGM input can create an image with width zero, and the native morphology routine indexes outrow[width - 1] without rejecting that geometry.

CVE-2026-112397, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via out-of-bounds memory access on zero-width images. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's ImageMorph.MorphOp.apply() can access memory before a row buffer for a zero-width image. PPM and PGM input can create an image with width zero, and the native morphology routine indexes outrow[width - 1] without rejecting that geometry.

CVE-2026-112399, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of service via crafted APNG image. Pillow is a Python imaging library. From 8.1.0 until 13.0.0, Pillow can allocate an APNG disposal background at the full canvas size before applying the decompression-bomb check.

CVE-2026-112399, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of service via crafted APNG image. Pillow is a Python imaging library. From 8.1.0 until 13.0.0, Pillow can allocate an APNG disposal background at the full canvas size before applying the decompression-bomb check.

CVE-2026-112400, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via memory exhaustion from crafted GIF image. Pillow is a Python imaging library. From 9.2.0 until 13.0.0, Pillow can retain a rejected GIF frame size after a decompression-bomb exception.

CVE-2026-112400, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via memory exhaustion from crafted GIF image. Pillow is a Python imaging library. From 9.2.0 until 13.0.0, Pillow can retain a rejected GIF frame size after a decompression-bomb exception.

CVE-2026-112402, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of service via double free during image transformation. Pillow is a Python imaging library. Prior to 13.0.0, Pillow can double free image memory when ImagingScaleAffine encounters a selective allocation failure. The affected fast path handles Transform.EXTENT or pure scale-and-translate Transform.AFFINE operations with the default NEAREST resampling.

CVE-2026-112402, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of service via double free during image transformation. Pillow is a Python imaging library. Prior to 13.0.0, Pillow can double free image memory when ImagingScaleAffine encounters a selective allocation failure. The affected fast path handles Transform.EXTENT or pure scale-and-translate Transform.AFFINE operations with the default NEAREST resampling.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112404, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via out-of-bounds read in TIFF decoding. Pillow is a Python imaging library. From 8.1.0 until 13.0.0, Pillow's TIFF tile and RGBA decode paths can read beyond row data produced by libtiff.

CVE-2026-112404, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via out-of-bounds read in TIFF decoding. Pillow is a Python imaging library. From 8.1.0 until 13.0.0, Pillow's TIFF tile and RGBA decode paths can read beyond row data produced by libtiff.

CVE-2026-112405, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via null pointer dereference in Image.merge(). Pillow is a Python imaging library. From 12.0.0 until 13.0.0, Pillow's Image.merge() can dereference a null image8 plane. Validation skips the first input band, allowing a 32-bit integer or floating-point image backed by image32 storage to be merged as a narrower multiband image.

CVE-2026-112406, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via infinite loop during PDF page rewriting. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow can enter an infinite loop while rewriting PDF pages. PdfParser.rewritepages() follows Parent relationships without detecting a cycle in the page tree.

CVE-2026-112406, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via infinite loop during PDF page rewriting. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow can enter an infinite loop while rewriting PDF pages. PdfParser.rewritepages() follows Parent relationships without detecting a cycle in the page tree.

CVE-2026-112892, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via unbounded memory expansion in MSP image decoder. Pillow is a Python imaging library. From 4.1.0 until 13.0.0, Pillow's MSP RLE decoder can expand a small file into an unbounded in-memory buffer. The decoder writes run-length output to BytesIO without limiting expansion to the declared image size.

CVE-2026-112892, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via unbounded memory expansion in MSP image decoder. Pillow is a Python imaging library. From 4.1.0 until 13.0.0, Pillow's MSP RLE decoder can expand a small file into an unbounded in-memory buffer. The decoder writes run-length output to BytesIO without limiting expansion to the declared image size.

CVE-2026-112893, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via invalid pointer free during font rendering. Pillow is a Python imaging library. From 10.0.0 until 13.0.0, Pillow can free an invalid glyph pointer during FreeType rendering with an active stroker. If FTLoadGlyph fails, cleanup may call FTDoneGlyph on an uninitialized or stale glyph variable.

CVE-2026-112893, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via invalid pointer free during font rendering. Pillow is a Python imaging library. From 10.0.0 until 13.0.0, Pillow can free an invalid glyph pointer during FreeType rendering with an active stroker. If FTLoadGlyph fails, cleanup may call FTDoneGlyph on an uninitialized or stale glyph variable.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112894, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via crafted multi-frame image conversion. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow takes quadratic time to reserve PDF object identifiers when saving many frames with saveall enabled. PdfParser.nextobjectid() repeatedly rebuilds and scans all previously reserved identifiers for every object.

CVE-2026-112894, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via crafted multi-frame image conversion. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow takes quadratic time to reserve PDF object identifiers when saving many frames with saveall enabled. PdfParser.nextobjectid() repeatedly rebuilds and scans all previously reserved identifiers for every object.

CVE-2026-112895, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of service via crafted PDF during append operations. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow can exhaust resources while parsing an existing PDF during an append operation.

CVE-2026-112895, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of service via crafted PDF during append operations. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow can exhaust resources while parsing an existing PDF during an append operation.

CVE-2026-112896, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via out-of-bounds read in TIFF encoder. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's TIFF encoder can read beyond a ColorMap buffer when retained TIFF metadata has a plane size inconsistent with BitsPerSample. A small TIFF can be opened normally and then retain a crafted ColorMap that is reused when the image is saved.

CVE-2026-112896, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via out-of-bounds read in TIFF encoder. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's TIFF encoder can read beyond a ColorMap buffer when retained TIFF metadata has a plane size inconsistent with BitsPerSample. A small TIFF can be opened normally and then retain a crafted ColorMap that is reused when the image is saved.

CVE-2026-112897, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Information disclosure via uninitialized buffer in TIFF decoding. Pillow is a Python imaging library. From 5.3.0 until 13.0.0, Pillow can return uninitialized memory as pixels when libtiff performs a short decode of JPEG-compressed or Group 4 fax TIFF data.

CVE-2026-112897, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Information disclosure via uninitialized buffer in TIFF decoding. Pillow is a Python imaging library. From 5.3.0 until 13.0.0, Pillow can return uninitialized memory as pixels when libtiff performs a short decode of JPEG-compressed or Group 4 fax TIFF data.

CVE-2026-112902, in 10.3.0, fixed in 13.0.0 — HIGH

Pillow: Memory disclosure and segfault in libtiff encoder via crafted TIFF tags. Pillow is a Python imaging library. In versions through 12.3.0, the libtiff TIFF encoder can pass arguments to TIFFSetField() that do not match libtiff's definition of the corresponding tag.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112902, in 12.2.0, fixed in 13.0.0 — HIGH

Pillow: Memory disclosure and segfault in libtiff encoder via crafted TIFF tags. Pillow is a Python imaging library. In versions through 12.3.0, the libtiff TIFF encoder can pass arguments to TIFFSetField() that do not match libtiff's definition of the corresponding tag.

CVE-2026-25990, in 10.3.0, fixed in 12.1.1 — HIGH

pillow: Out-of-bounds Write via Specially Crafted PSD Image. Pillow is a Python imaging library. From 10.3.0 to before 12.1.1, an out-of-bounds write may be triggered when loading a specially crafted PSD image. This vulnerability is fixed in 12.1.1.

CVE-2026-40192, in 10.3.0, fixed in 12.2.0 — HIGH

Pillow: Denial of Service via decompression bomb in FITS image processing. Pillow is a Python imaging library. Versions 10.3.0 through 12.1.1 did not limit the amount of GZIP-compressed data read when decoding a FITS image, making them vulnerable to decompression bomb attacks.

CVE-2026-42311, in 10.3.0, fixed in 12.2.0 — HIGH

Pillow: python-pillow: Pillow: Arbitrary code execution via malicious PSD file processing. Pillow is a Python imaging library. From version 10.3.0 to before version 12.2.0, processing a malicious PSD file could lead to memory corruption, potentially resulting in a crash or arbitrary code execution. This issue has been patched in version 12.2.0.

CVE-2026-54058, in 10.3.0, fixed in 12.3.0 — HIGH

Pillow: Memory disclosure or denial of service via crafted McIdas AREA image. Pillow is a Python imaging library. Prior to 12.3.0, when Pillow loads an uncompressed McIdas AREA image from a filename through the mmap raw codec path, attacker-controlled header words can set a row stride smaller than the natural row width, causing pixel access such as Image.tobytes(), getpixel,...

CVE-2026-54058, in 12.2.0, fixed in 12.3.0 — HIGH

Pillow: Memory disclosure or denial of service via crafted McIdas AREA image. Pillow is a Python imaging library. Prior to 12.3.0, when Pillow loads an uncompressed McIdas AREA image from a filename through the mmap raw codec path, attacker-controlled header words can set a row stride smaller than the natural row width, causing pixel access such as Image.tobytes(), getpixel,...

CVE-2026-54059, in 10.3.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via crafted PCF font data. Pillow is a Python imaging library. Prior to 12.3.0, PIL/PcfFontFile.py loadbitmaps() read glyph dimensions from the PCF METRICS section and passed them directly to Image.frombytes() without calling Image.decompressionbombcheck(), allowing crafted PCF font data to cause excessive memory allocation.

CVE-2026-54059, in 12.2.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via crafted PCF font data. Pillow is a Python imaging library. Prior to 12.3.0, PIL/PcfFontFile.py loadbitmaps() read glyph dimensions from the PCF METRICS section and passed them directly to Image.frombytes() without calling Image.decompressionbombcheck(), allowing crafted PCF font data to cause excessive memory allocation.

CVE-2026-54060, in 10.3.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via excessive memory allocation when processing font files. Pillow is a Python imaging library. Prior to 12.3.0, PIL/FontFile.py FontFile.compile() assembled per-glyph images into a combined bitmap with Image.new("1", (xsize, ysize)) without calling Image.decompressionbombcheck(), allowing a font to trigger excessive allocation during conversion or saving.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-54060, in 12.2.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via excessive memory allocation when processing font files. Pillow is a Python imaging library. Prior to 12.3.0, PIL/FontFile.py FontFile.compile() assembled per-glyph images into a combined bitmap with Image.new("1", (xsize, ysize)) without calling Image.decompressionbombcheck(), allowing a font to trigger excessive allocation during conversion or saving.

CVE-2026-55379, in 10.3.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via crafted BDF font file. Pillow is a Python imaging library. Prior to 12.3.0, PIL/BdfFontFile.py bdfchar() read the BBX width and height field from a BDF font file and passed attacker-controlled dimensions to Image.new() without calling Image.decompressionbombcheck(), bypassing Pillow's documented decompression bomb...

CVE-2026-55379, in 12.2.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via crafted BDF font file. Pillow is a Python imaging library. Prior to 12.3.0, PIL/BdfFontFile.py bdfchar() read the BBX width and height field from a BDF font file and passed attacker-controlled dimensions to Image.new() without calling Image.decompressionbombcheck(), bypassing Pillow's documented decompression bomb...

CVE-2026-55380, in 10.3.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via crafted GD 2.x image file. Pillow is a Python imaging library. Prior to 12.3.0, PIL/GdImageFile.py GdImageFile.open() read image dimensions from the GD 2.x header and stored them in self.size without calling Image.decompressionbombcheck(), allowing a crafted .gd file to trigger excessive C-heap allocation when loaded.

CVE-2026-55380, in 12.2.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via crafted GD 2.x image file. Pillow is a Python imaging library. Prior to 12.3.0, PIL/GdImageFile.py GdImageFile.open() read image dimensions from the GD 2.x header and stored them in self.size without calling Image.decompressionbombcheck(), allowing a crafted .gd file to trigger excessive C-heap allocation when loaded.

CVE-2026-59197, in 10.3.0, fixed in 12.3.0 — HIGH

Pillow: Native heap out-of-bounds write. Pillow is a Python imaging library. Prior to 12.3.0, Pillow's public rank-filter API can trigger a native heap out-of-bounds write when given a very large odd filter size because ImageFilter.RankFilter.filter() calls image.expand(size // 2, size // 2) before rank-filter size validation and...

CVE-2026-59197, in 12.2.0, fixed in 12.3.0 — HIGH

Pillow: Native heap out-of-bounds write. Pillow is a Python imaging library. Prior to 12.3.0, Pillow's public rank-filter API can trigger a native heap out-of-bounds write when given a very large odd filter size because ImageFilter.RankFilter.filter() calls image.expand(size // 2, size // 2) before rank-filter size validation and...

CVE-2026-59199, in 10.3.0, fixed in 12.3.0 — HIGH

Pillow: Denial of Service via out-of-bounds write in image processing. Pillow is a Python imaging library. Prior to 12.3.0, Pillow public image coordinate APIs can trigger a native heap out-of-bounds write when given coordinates near the signed 32-bit integer limits in Image.paste(), Image.crop(), or Image.alphacomposite(). This issue is fixed in version 12.3.0.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-59199, in 12.2.0, fixed in 12.3.0 — HIGH

Pillow: Denial of Service via out-of-bounds write in image processing. Pillow is a Python imaging library. Prior to 12.3.0, Pillow public image coordinate APIs can trigger a native heap out-of-bounds write when given coordinates near the signed 32-bit integer limits in Image.paste(), Image.crop(), or Image.alphacomposite(). This issue is fixed in version 12.3.0.

CVE-2026-59200, in 10.3.0, fixed in 12.3.0 — HIGH

Pillow: Denial of service via crafted PDF stream. Pillow is a Python imaging library. From 5.1.0 until 12.3.0, PdfParser.PdfStream.decode() in PIL/PdfParser.py calls zlib.decompress() with bufsize set to the PDF stream Length field without bounding the decompressed output size, allowing a crafted FlateDecode PDF stream to exhaust memory from a...

CVE-2026-59200, in 12.2.0, fixed in 12.3.0 — HIGH

Pillow: Denial of service via crafted PDF stream. Pillow is a Python imaging library. From 5.1.0 until 12.3.0, PdfParser.PdfStream.decode() in PIL/PdfParser.py calls zlib.decompress() with bufsize set to the PDF stream Length field without bounding the decompressed output size, allowing a crafted FlateDecode PDF stream to exhaust memory from a...

CVE-2026-59204, in 10.3.0, fixed in 12.3.0 — HIGH

Pillow: Denial of Service via crafted JPEG2000 image. Pillow is a Python imaging library. From 8.2.0 through 12.2.0, src/libImaging/Jpeg2KDecode.c accumulates totalcomponentwidth across every tile in a JPEG2000 image instead of recomputing it per tile, allowing a crafted tiled JPEG2000 file to force substantially higher transient memory usage and...

CVE-2026-59204, in 12.2.0, fixed in 12.3.0 — HIGH

Pillow: Denial of Service via crafted JPEG2000 image. Pillow is a Python imaging library. From 8.2.0 through 12.2.0, src/libImaging/Jpeg2KDecode.c accumulates totalcomponentwidth across every tile in a JPEG2000 image instead of recomputing it per tile, allowing a crafted tiled JPEG2000 file to force substantially higher transient memory usage and...

CVE-2026-59205, in 10.3.0, fixed in 12.3.0 — HIGH

Pillow: Controlled native heap corruption in ImageCms.ImageCmsTransform.apply API. Pillow is a Python imaging library. Prior to 12.3.0, Pillow's ImageCms.ImageCmsTransform.apply(im, imOut) API can trigger controlled native heap corruption when the caller supplies an output image whose mode does not match the transform's declared output mode. This issue is fixed in version 12.3.0.

CVE-2026-59205, in 12.2.0, fixed in 12.3.0 — HIGH

Pillow: Controlled native heap corruption in ImageCms.ImageCmsTransform.apply API. Pillow is a Python imaging library. Prior to 12.3.0, Pillow's ImageCms.ImageCmsTransform.apply(im, imOut) API can trigger controlled native heap corruption when the caller supplies an output image whose mode does not match the transform's declared output mode. This issue is fixed in version 12.3.0.

CVE-2026-96637, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via decompression bomb bypass in SPIDER images. Pillow is a Python imaging library. Prior to 13.0.0, SpiderImageFile.seek() in src/PIL/SpiderImagePlugin.py reparses a later SPIDER stack frame and replaces self.size without rerunning Image.decompressionbombcheck().

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-96637, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via decompression bomb bypass in SPIDER images. Pillow is a Python imaging library. Prior to 13.0.0, SpiderImageFile.seek() in src/PIL/SpiderImagePlugin.py reparses a later SPIDER stack frame and replaces self.size without rerunning Image.decompressionbombcheck().

CVE-2026-96640, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via duplicate page references in PDF files. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, PdfParser.linearizepagetree() in src/PIL/PdfParser.py treats a PDF /Pages graph as a tree without tracking duplicate indirect references.

CVE-2026-96640, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via duplicate page references in PDF files. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, PdfParser.linearizepagetree() in src/PIL/PdfParser.py treats a PDF /Pages graph as a tree without tracking duplicate indirect references.

CVE-2026-96642, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via negative archive member size in TarIO. Pillow is a Python imaging library. Prior to 13.0.0, the TarIO initializer in src/PIL/TarIO.py accepts a negative octal member size and computes a backward seek that returns to the same 512-byte header.

CVE-2026-96642, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via negative archive member size in TarIO. Pillow is a Python imaging library. Prior to 13.0.0, the TarIO initializer in src/PIL/TarIO.py accepts a negative octal member size and computes a backward seek that returns to the same 512-byte header.

CVE-2026-96643, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via repeated EXIF headers. Pillow is a Python imaging library. From 11.0.0 until 13.0.0, Exif.load() in src/PIL/Image.py repeatedly slices the remaining EXIF data while it begins with the six-byte Exif header.

CVE-2026-96644, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via out-of-bounds read in metafile parser. Pillow is a Python imaging library. Prior to 13.0.0 on Windows, src/PIL/WmfImagePlugin.py passes unchecked 32-bit WMF or EMF dimensions to the native drawwmf handler in src/display.c.

CVE-2026-96644, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via out-of-bounds read in metafile parser. Pillow is a Python imaging library. Prior to 13.0.0 on Windows, src/PIL/WmfImagePlugin.py passes unchecked 32-bit WMF or EMF dimensions to the native drawwmf handler in src/display.c.

CVE-2026-96778, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Arbitrary code execution via JPEG encoder buffer overflow. Pillow is a Python imaging library. From 9.4.0 until 13.0.0, ImagingJpegEncode() in src/libImaging/JpegEncode.c can call jpegwritemarker() for a JPEG COM comment when an ICC profile has exactly filled the 65536-byte encoder buffer.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-96778, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Arbitrary code execution via JPEG encoder buffer overflow. Pillow is a Python imaging library. From 9.4.0 until 13.0.0, ImagingJpegEncode() in src/libImaging/JpegEncode.c can call jpegwritemarker() for a JPEG COM comment when an ICC profile has exactly filled the 65536-byte encoder buffer.

GHSA-78g4-xqwv-q3g8, in 12.2.0, fixed in 13.0.0 — HIGH

Pillow: Bundled libopenjp2 2.5.4 in all wheels since 11.1.0 carries OSV-2025-219 heap-buffer-overflow write reachable from Image.open().load(). Every Pillow wheel from 11.1.0 onward bundles a libopenjp2 containing a heap-buffer-overflow write that is fixed upstream on master but has never appeared in an OpenJPEG release. See https://osv.dev/vulnerability/OSV-2025-219 Because the wheel bundles its own copy, a patched host OS does not help.

CVE-2026-112391, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via unbounded recursion in PDF parser. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow's PdfParser.getvalue() can recurse without a limit while reading nested PDF objects. The parser follows attacker-controlled arrays and dictionaries when an existing PDF is opened for append.

CVE-2026-112391, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via unbounded recursion in PDF parser. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow's PdfParser.getvalue() can recurse without a limit while reading nested PDF objects. The parser follows attacker-controlled arrays and dictionaries when an existing PDF is opened for append.

CVE-2026-112394, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via out-of-bounds read in raw decoders. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's P;2L and P;4L raw decoders can read past the end of an input buffer. ImagingRawDecode calculates a packed-pixel row size, while the unpackers read separately padded bit planes.

CVE-2026-112394, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via out-of-bounds read in raw decoders. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's P;2L and P;4L raw decoders can read past the end of an input buffer. ImagingRawDecode calculates a packed-pixel row size, while the unpackers read separately padded bit planes.

CVE-2026-112395, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via crafted tiled TIFF image. Pillow is a Python imaging library. From 8.2.0 until 13.0.0, Pillow's tiled-TIFF decoder can read past the tile buffer while copying four-byte pixels.

CVE-2026-112395, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via crafted tiled TIFF image. Pillow is a Python imaging library. From 8.2.0 until 13.0.0, Pillow's tiled-TIFF decoder can read past the tile buffer while copying four-byte pixels.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112396, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: arbitrary code execution via heap use-after-free during TIFF encoding. Pillow is a Python imaging library. From 11.3.0 until 13.0.0, Pillow has a heap use-after-free when libtiff rejects a tag while encoding TIFF data to an in-memory buffer.

CVE-2026-112401, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via crafted GIF comments. Pillow is a Python imaging library. From 5.4.0 until 13.0.0, Pillow performs quadratic copying while parsing GIF comments. GifImageFile.seek() repeatedly appends immutable bytes for comment sub-blocks and multiple comment extensions, and frame zero is parsed during Image.open().

CVE-2026-112401, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via crafted GIF comments. Pillow is a Python imaging library. From 5.4.0 until 13.0.0, Pillow performs quadratic copying while parsing GIF comments. GifImageFile.seek() repeatedly appends immutable bytes for comment sub-blocks and multiple comment extensions, and frame zero is parsed during Image.open().

CVE-2026-112891, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via large GIF comments. Pillow is a Python imaging library. From 9.2.0 until 13.0.0, Pillow performs quadratic copying when saving a GIF with a long comment. getglobalheader() repeatedly copies portions of comment data while assembling the global header, including comments retained from an untrusted input image.

CVE-2026-112891, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via large GIF comments. Pillow is a Python imaging library. From 9.2.0 until 13.0.0, Pillow performs quadratic copying when saving a GIF with a long comment. getglobalheader() repeatedly copies portions of comment data while assembling the global header, including comments retained from an untrusted input image.

CVE-2026-112898, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via empty palette quantization. Pillow is a Python imaging library. From 9.1.0 until 13.0.0, Pillow can disclose uninitialized stack memory when Image.quantize() uses an empty palette.

CVE-2026-112898, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via empty palette quantization. Pillow is a Python imaging library. From 9.1.0 until 13.0.0, Pillow can disclose uninitialized stack memory when Image.quantize() uses an empty palette.

CVE-2026-112899, in 10.3.0, fixed in 13.0.0 — MEDIUM

Pillow is a Python imaging library. In versions 2.3.0 through 12.3.0, . Pillow is a Python imaging library. In versions 2.3.0 through 12.3.0, EPS rendering does not validate the scaled image dimensions before invoking Ghostscript.

CVE-2026-112899, in 12.2.0, fixed in 13.0.0 — MEDIUM

Pillow is a Python imaging library. In versions 2.3.0 through 12.3.0, . Pillow is a Python imaging library. In versions 2.3.0 through 12.3.0, EPS rendering does not validate the scaled image dimensions before invoking Ghostscript.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112901, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via crafted XBM image header. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's XBM header parser is vulnerable to regular-expression denial of service.

CVE-2026-112901, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via crafted XBM image header. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's XBM header parser is vulnerable to regular-expression denial of service.

CVE-2026-114501, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via improper memory alignment during Arrow export. Pillow is a Python imaging library. From 11.2.1 until 13.0.0, Arrow export assumes that an image's rows are tightly contiguous and exports from im->blocks[0].ptr even when PILLOWALIGNMENT makes alignedlinesize include row padding or an aligned offset before the first row.

CVE-2026-42308, in 10.3.0, fixed in 12.2.0 — MEDIUM

Pillow: Denial of Service via integer overflow in font processing. Pillow is a Python imaging library. Prior to version 12.2.0, if a font advances for each glyph by an exceeding large amount, when Pillow keeps track of the current position, it may lead to an integer overflow. This issue has been patched in version 12.2.0.

CVE-2026-42310, in 10.3.0, fixed in 12.2.0 — MEDIUM

Pillow: Denial of Service via malicious PDF processing. Pillow is a Python imaging library. From version 4.2.0 to before version 12.2.0, an attacker can supply a malicious PDF that causes the process to hang indefinitely, consuming 100% CPU and making the application unresponsive. This issue has been patched in version 12.2.0.

CVE-2026-55798, in 10.3.0, fixed in 12.3.0 — MEDIUM

python-pillow: Pillow: Arbitrary command injection via shell metacharacters in file paths. Pillow is a Python imaging library. Prior to 12.3.0, WindowsViewer.getcommand() constructed a cmd.exe shell command by directly embedding a file path into an f-string without escaping and passed the result to subprocess.Popen(..., shell=True), allowing shell metacharacters in the file path to...

CVE-2026-55798, in 12.2.0, fixed in 12.3.0 — MEDIUM

python-pillow: Pillow: Arbitrary command injection via shell metacharacters in file paths. Pillow is a Python imaging library. Prior to 12.3.0, WindowsViewer.getcommand() constructed a cmd.exe shell command by directly embedding a file path into an f-string without escaping and passed the result to subprocess.Popen(..., shell=True), allowing shell metacharacters in the file path to...

CVE-2026-59198, in 10.3.0, fixed in 12.3.0 — MEDIUM

Pillow: Information disclosure via TGA RLE encoder out-of-bounds read. Pillow is a Python imaging library. From 5.2.0 until 12.3.0, Pillow's TGA RLE encoder reads past its packed row buffer when saving a mode 1 image with TGA RLE compression, allowing adjacent process heap bytes to be copied into the generated TGA file. This issue is fixed in version 12.3.0.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-59198, in 12.2.0, fixed in 12.3.0 — MEDIUM

Pillow: Information disclosure via TGA RLE encoder out-of-bounds read. Pillow is a Python imaging library. From 5.2.0 until 12.3.0, Pillow's TGA RLE encoder reads past its packed row buffer when saving a mode 1 image with TGA RLE compression, allowing adjacent process heap bytes to be copied into the generated TGA file. This issue is fixed in version 12.3.0.

CVE-2026-59203, in 12.2.0, fixed in 12.3.0 — MEDIUM

Pillow: Denial of Service via crafted EPS file. Pillow is a Python imaging library. From 12.0.0 through 12.2.0, Pillow's EPS parser in PIL/EpsImagePlugin.py accepts a negative byte count in the %%BeginBinary directive, allowing a crafted EPS file to cause Image.open() to seek backwards to the same directive and parse it repeatedly in an infinite...

CVE-2026-96636, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via decompression bomb check bypass in multi-frame images. Pillow is a Python imaging library. Prior to 13.0.0, MpoImageFile.seek() and DcxImageFile.seek() reparse later MPO or DCX frames and replace self.size without rerunning Image.decompressionbombcheck().

CVE-2026-96636, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via decompression bomb check bypass in multi-frame images. Pillow is a Python imaging library. Prior to 13.0.0, MpoImageFile.seek() and DcxImageFile.seek() reparse later MPO or DCX frames and replace self.size without rerunning Image.decompressionbombcheck().

CVE-2026-96638, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via crafted RLE BMP image. Pillow is a Python imaging library. From 9.1.0 until 13.0.0, BmpRleDecoder.decode() in src/PIL/BmpImagePlugin.py permits crafted RLE BMP delta escapes and absolute-mode runs to append beyond the remaining destlength without a per-branch cap.

CVE-2026-96638, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via crafted RLE BMP image. Pillow is a Python imaging library. From 9.1.0 until 13.0.0, BmpRleDecoder.decode() in src/PIL/BmpImagePlugin.py permits crafted RLE BMP delta escapes and absolute-mode runs to append beyond the remaining destlength without a per-branch cap.

CVE-2026-96641, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via integer overflow in text-width calculation. Pillow is a Python imaging library. Prior to 13.0.0, PILfont text-width accumulation in src/imaging.c checks positive glyph advances against INTMAX but does not check negative advances against INTMIN.

CVE-2026-96641, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via integer overflow in text-width calculation. Pillow is a Python imaging library. Prior to 13.0.0, PILfont text-width accumulation in src/imaging.c checks positive glyph advances against INTMAX but does not check negative advances against INTMIN.

SCANNER RESULTS, CONTINUED

handlebars 3 advisories in 4.7.9, dependency advisories

Bears on CC7.1 CRITICAL

Installed: 4.7.9, brought in by express-handlebars 8.0.6

RISK IF LEFT

A deny list misses a dangerous value, so it gets through the check meant to stop it.

The code doesn't handle an unusual input that looks valid, so a crafted value can crash the software or get past a check.

An attacker can make the application run code of their choosing.

The code doesn't escape output for where it lands, so crafted input can change what a browser or parser does.

THE FIX

Version 4.7.10 fixes all 3. handlebars 4.7.9 comes in through express-handlebars 8.0.6. Upgrade it to a release that uses handlebars 4.7.10 or later, and if none does yet, force it up with an override in package.json, "overrides": { "express-handlebars": { "handlebars": "^4.7.10" } }.

CVE-2026-106445, fixed in 4.7.10 CRITICAL

handlebars: JavaScript Injection via Own Property Check Bypass. Handlebars provides the power necessary to let users build semantic templates. From 3.0.0 until 4.7.10, Handlebars lookupProperty returns Function.prototype.constructor before applying the prototype-access deny list because constructor is an own property of Function.prototype.

CVE-2026-106446, fixed in 4.7.10 CRITICAL

handlebars: JavaScript Injection via AST Type Confusion in compile (Program.blockParams). Handlebars provides the power necessary to let users build semantic templates. From 4.0.0 until 4.7.10, Handlebars.compile() and Handlebars.precompile() accept pre-parsed AST objects while validating only selected PathExpression, NumberLiteral, and BooleanLiteral values.

CVE-2026-106444, fixed in 4.7.10 MEDIUM

handlebars: Cross-Site Scripting via unescaped closing script tags in precompiled templates. Handlebars provides the power necessary to let users build semantic templates. From 4.0.0 until 4.7.10, Handlebars.precompile() uses quotedString() in lib/handlebars/compiler/code-gen.js to emit static template text into generated JavaScript without escaping sequences that terminate an enclosing...

certifi 1 advisory in 2026.2.25, dependency advisories

Bears on CC7.1 CRITICAL

Installed: 2026.2.25, the repository's own dependency

THE FIX

Upgrade certifi from 2026.2.25 to 2026.10.18 to fix it.

GHSA-6q48-6c7w-9gw2, fixed in 2026.10.18 CRITICAL

certifi bundles emSign root CAs with compromised intermediate CA keys. Certifi versions before 2026.10.18 include the emSign ECC Root CA - G3 root certificate in their bundled CA store. Eight eMudhra intermediate CA certificates that chain to this root have compromised private keys and the CA has revoked them.

SCANNER RESULTS, CONTINUED

proxy-addr 1 advisory in 2.0.7, dependency advisories

Bears on CC7.1 CRITICAL

Installed: 2.0.7, brought in by express 4.22.2

THE FIX

Version 2.0.8 fixes it. proxy-addr 2.0.7 comes in through express 4.22.2. Upgrade it to a release that uses proxy-addr 2.0.8 or later, and if none does yet, force it up with an override in package.json, "overrides": { "express": { "proxy-addr": "^2.0.8" } }.

CVE-2026-90711, fixed in 2.0.8 CRITICAL

proxy-addr: proxy-addr vulnerable to IP spoofing via IPv4-mapped IPv6 trust subnet. proxy-addr is a Node.js module that determines a request's client address behind trusted reverse proxies, and it backs Express req.ip and req.ips.

urllib3 5 advisories in 2.6.3, dependency advisories

Bears on CC7.1 HIGH

Installed: 2.6.3, the repository's own dependency

RISK IF LEFT

Someone without permission can see information meant to stay private.

The code doesn't check a certificate properly, so someone can intercept or alter the traffic.

Nothing limits how much a request can allocate, so a crafted one can exhaust memory and stop the service.

A crafted input can send the code into a loop it never leaves, stalling the service.

THE FIX

Upgrade urllib3 from 2.6.3 to 2.8.0 to fix all 5.

CVE-2026-44431, fixed in 2.7.0 HIGH

urllib3: Information disclosure via cross-origin redirects forwarding sensitive headers. urllib3 is an HTTP client library for Python. From 1.23 to before 2.7.0, cross-origin redirects followed from the low-level API via ProxyManager.connectionfromurl().urlopen(..., assertsamehost=False) still forward these sensitive headers. This vulnerability is fixed in 2.7.0.

CVE-2026-44432, fixed in 2.7.0 HIGH

urllib3: Denial of Service due to excessive HTTP response decompression. urllib3 is an HTTP client library for Python. From 2.6.0 to before 2.7.0, urllib3 could decompress the whole response instead of the requested portion (1) during the second HTTPResponse.read(amt=N) call when the response was decompressed using the official Brotli library or (2) when...

CVE-2026-97687, fixed in 2.8.0 HIGH

urllib3: Traffic interception via HTTPS proxy TLS configuration override. urllib3 is an HTTP client library for Python. From 1.26.0 until 2.8.0, the proxysslcontext, proxyasserthostname, proxyassertfingerprint, sslcontext, certreqs, verifymode, useforwardingforhttps=True, and CERTNONE configuration paths fail to remain separated because target-server TLS settings are...

SCANNER RESULTS, URLLIB3, CONTINUED

CVE-2026-97689, fixed in 2.8.0 — HIGH

urllib3: Denial of Service via unbounded memory allocation in chunk parser. urllib3 is an HTTP client library for Python. From 1.10.3 until 2.8.0, the HTTPResponse.readchunked and HTTPResponse.stream methods can allocate unbounded memory because the streaming chunk parser buffers the chunk-size field until newline or EOF without a length bound.

CVE-2026-97688, fixed in 2.8.0 — MEDIUM

urllib3: Denial of Service via infinite loop during chunked Deflate decoding. urllib3 is an HTTP client library for Python. From 2.6.2 until 2.8.0, HTTPResponse.stream and HTTPResponse.readchunked can enter an infinite loop because the Deflate decoder retains trailing bytes as unconsumed input after reaching end-of-stream and repeatedly decodes them without progress.

soupsieve 4 advisories in 2.8.3, dependency advisories

Bears on CC7.1 — HIGH

Installed: 2.8.3, the repository's own dependency

RISK IF LEFT

A crafted request can use enough resources to slow or stop the service.

Nothing limits how much a request can allocate, so a crafted one can exhaust memory and stop the service.

A crafted input can make a pattern match run for a very long time, stalling the service.

THE FIX

Upgrade soupsieve from 2.8.3 to 2.9.0 to fix all 4.

CVE-2026-49476, fixed in 2.8.4, in 2 lockfiles — HIGH

python-soupsieve: Soupsieve: Denial of Service via crafted CSS selector string. Soup Sieve is a CSS selector library designed to be used with Beautiful Soup 4. Prior to 2.8.4, the CSS selector parser in soupsieve allocates unbounded memory when compiling large comma-separated selector lists, allowing an attacker who can supply a crafted selector string to soupsieve.compile()...

CVE-2026-49477, fixed in 2.8.4, in 2 lockfiles — HIGH

soupsieve: Denial of Service via crafted CSS selector strings. Soup Sieve is a CSS selector library designed to be used with Beautiful Soup 4. Prior to 2.8.4, the CSS selector parser in soupsieve contains a regular expression vulnerable to catastrophic backtracking when processing an attribute selector with an unterminated quoted value in...

CVE-2026-85999, fixed in 2.9.0, in 2 lockfiles — MEDIUM

soupsieve: Soup Sieve: Denial of Service via crafted CSS selectors. Soup Sieve is a CSS selector library designed to be used with Beautiful Soup 4. Prior to 2.9, selectoriter in src/soupsieve/cssparser.py trims the raw selector with REWSEND, an end-anchored WSC whitespace-and-comment expression used with search(), so the regular expression engine retries a greedy...

CVE-2026-86000, fixed in 2.9.0, in 2 lockfiles — MEDIUM

soupsieve: Soup Sieve: Denial of Service via crafted CSS selectors. Soup Sieve is a CSS selector library designed to be used with Beautiful Soup 4. Prior to 2.9, the selector parser in src/soupsieve/cssparser.py defines IDENTIFIER with adjacent quantified groups over overlapping character classes, and VALUE embeds IDENTIFIER for attribute selectors.

SCANNER RESULTS, CONTINUED

body-parser **1 advisory in 1.20.6, dependency advisories** Bears on CC7.1 HIGH

Installed: 1.20.6, brought in by express 4.22.2

RISK IF LEFT

The code doesn't catch an unexpected error, so a crafted request can crash the service.

THE FIX

Version 1.20.9 fixes it. body-parser 1.20.6 comes in through express 4.22.2. Upgrade it to a release that uses body-parser 1.20.9 or later, and if none does yet, force it up with an override in package.json, "overrides": { "express": { "body-parser": "^1.20.9" } }.

CVE-2026-111181, fixed in 2.4.0, 1.20.9 HIGH

body-parser: Denial of Service via unhandled decompression stream error. body-parser is body parsing middleware for Node.js and Express. In versions before 1.20.9 and in versions from 2.0.0 before 2.4.0, a single request can crash any application using body-parser with default options.

sharp **1 advisory in 0.35.4, dependency advisories** Bears on CC7.1 HIGH

Installed: 0.35.4, the repository's own dependency

THE FIX

Upgrade sharp from 0.35.4 to 0.35.5 to fix it.

GHSA-wq5f-xc86-pv6w, fixed in 0.35.5 HIGH

sharp : Vulnerability in librsvg dependency CVE-2026-96889. A memory-related vulnerability has been discovered and fixed in the upstream librsvg dependency. When certain runtime-specific conditions apply, this vulnerability can lead to possible remote code execution (RCE) on glibc-based Linux. Most people rely on the prebuilt binaries provided by sharp.

var-in-href **426 places, static analysis** Bears on CC7.1 MEDIUM

Detected a template variable used in an anchor tag with the 'href' attribute. This allows a malicious actor to input the 'javascript:' URI and is subject to cross- site scripting (XSS) attacks. If using Flask, use 'url_for()' to safely generate a URL. If using Django, use the 'url' filter to safely generate a URL. If using Mustache, use a URL encoding library, or prepend a slash '/' to the variable for relative links (`href="/{{link}}"`). You may also consider setting the Content Security Policy (CSP) header.

RISK IF LEFT

An attacker can run script in a user's browser and act as that user, reading their session too.

THE FIX

Change the code at each of the 426 places listed. Escape the value for where it lands in the page, or clean it with a library such as DOMPurify before inserting it as HTML.

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/admin-roles/grant-confirm.hbs:26

src/views/admin/admin-roles/index.hbs:21

src/views/admin/admin-roles/revoke-confirm.hbs:22

src/views/admin/alarms/index.hbs:64

src/views/admin/alarms/index.hbs:65

src/views/admin/audit-log/index.hbs:45

src/views/admin/audit-log/index.hbs:49

src/views/admin/audit-log/index.hbs:56

src/views/admin/audit-log/index.hbs:57

src/views/admin/audit-log/index.hbs:65

src/views/admin/audit-log/index.hbs:66

src/views/admin/audit-log/summary.hbs:11

src/views/admin/broadcasts/detail.hbs:27

src/views/admin/broadcasts/index.hbs:24

src/views/admin/broadcasts/index.hbs:33

src/views/admin/broadcasts/index.hbs:34

src/views/admin/club-leadership/demote-confirm.hbs:13

src/views/admin/club-leadership/demote-confirm.hbs:26

src/views/admin/club-leadership/detail.hbs:66

src/views/admin/clubs/confirm.hbs:36

src/views/admin/clubs/index.hbs:30

src/views/admin/clubs/record.hbs:103

src/views/admin/clubs/record.hbs:108

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/clubs/record.hbs:17

src/views/admin/clubs/record.hbs:18

src/views/admin/clubs/record.hbs:36

src/views/admin/consecutive-record-delete-confirm.hbs:25

src/views/admin/consecutive-record-edit.hbs:81

src/views/admin/consecutive-record-edit.hbs:84

src/views/admin/consecutive-records.hbs:29

src/views/admin/curator/edit.hbs:13

src/views/admin/curator/edit.hbs:94

src/views/admin/curator/galleries/edit.hbs:17

src/views/admin/curator/galleries/edit.hbs:34

src/views/admin/curator/galleries/list.hbs:21

src/views/admin/curator/galleries/list.hbs:76

src/views/admin/curator/galleries/list.hbs:77

src/views/admin/curator/galleries/list.hbs:83

src/views/admin/curator/job-status.hbs:18

src/views/admin/curator/job-status.hbs:44

src/views/admin/curator/job-status.hbs:53

src/views/admin/curator/job-status.hbs:57

src/views/admin/curator/list.hbs:11

src/views/admin/curator/list.hbs:114

src/views/admin/curator/list.hbs:117

src/views/admin/curator/list.hbs:43

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/curator/list.hbs:52

src/views/admin/curator/list.hbs:62

src/views/admin/curator/list.hbs:65

src/views/admin/curator/list.hbs:69

src/views/admin/curator/list.hbs:97

src/views/admin/dashboard.hbs:15

src/views/admin/dashboard.hbs:31

src/views/admin/dashboard.hbs:43

src/views/admin/dashboard.hbs:67

src/views/admin/dashboard.hbs:84

src/views/admin/email-log/index.hbs:45

src/views/admin/email-log/index.hbs:78

src/views/admin/email-log/index.hbs:79

src/views/admin/email-templates/edit.hbs:55

src/views/admin/email-templates/index.hbs:13

src/views/admin/emerging-vocabulary.hbs:18

src/views/admin/event-organizers/detail.hbs:55

src/views/admin/event-organizers/queue.hbs:22

src/views/admin/event-results/confirm.hbs:33

src/views/admin/event-results/discipline.hbs:39

src/views/admin/event-results/entry.hbs:48

src/views/admin/event-results/event.hbs:14

src/views/admin/event-results/event.hbs:22

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/event-results/event.hbs:35

src/views/admin/event-results/event.hbs:44

src/views/admin/event-results/index.hbs:28

src/views/admin/freestyle-modifier-add-confirm.hbs:28

src/views/admin/freestyle-modifier-add-confirm.hbs:49

src/views/admin/freestyle-modifier-edit.hbs:35

src/views/admin/freestyle-modifiers.hbs:62

src/views/admin/freestyle-notation-author.hbs:124

src/views/admin/freestyle-notation-author.hbs:44

src/views/admin/freestyle-notation-backlog.hbs:21

src/views/admin/freestyle-notation-backlog.hbs:79

src/views/admin/freestyle-notation-backlog.hbs:84

src/views/admin/freestyle-notation-drafts.hbs:51

src/views/admin/freestyle-notation-drafts.hbs:52

src/views/admin/freestyle-notation-drafts.hbs:71

src/views/admin/freestyle-record-edit.hbs:98

src/views/admin/freestyle-records.hbs:55

src/views/admin/freestyle-trick-edit.hbs:25

src/views/admin/freestyle-trick-edit.hbs:26

src/views/admin/freestyle-trick-edit.hbs:272

src/views/admin/freestyle-trick-publish.hbs:137

src/views/admin/freestyle-tricks.hbs:61

src/views/admin/historical-records/confirm.hbs:38

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/historical-records/correction.hbs:45

src/views/admin/historical-records/index.hbs:35

src/views/admin/historical-records/index.hbs:38

src/views/admin/honor-grants/action-confirm.hbs:29

src/views/admin/honor-grants/grant-confirm.hbs:15

src/views/admin/honor-grants/grant-confirm.hbs:32

src/views/admin/mailing-lists/compose.hbs:37

src/views/admin/mailing-lists/detail.hbs:24

src/views/admin/mailing-lists/detail.hbs:26

src/views/admin/mailing-lists/detail.hbs:92

src/views/admin/mailing-lists/form.hbs:43

src/views/admin/mailing-lists/index.hbs:11

src/views/admin/mailing-lists/index.hbs:29

src/views/admin/media-flags/index.hbs:29

src/views/admin/media-flags/index.hbs:46

src/views/admin/media-flags/index.hbs:47

src/views/admin/media-flags/index.hbs:51

src/views/admin/media-flags/index.hbs:58

src/views/admin/members/confirm.hbs:43

src/views/admin/members/index.hbs:30

src/views/admin/members/record.hbs:22

src/views/admin/members/record.hbs:302

src/views/admin/members/record.hbs:307

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/payments/detail.hbs:31

src/views/admin/payments/detail.hbs:40

src/views/admin/payments/detail.hbs:98

src/views/admin/payments/health.hbs:154

src/views/admin/payments/health.hbs:156

src/views/admin/payments/health.hbs:158

src/views/admin/payments/index.hbs:10

src/views/admin/payments/index.hbs:115

src/views/admin/payments/index.hbs:128

src/views/admin/payments/index.hbs:145

src/views/admin/payments/index.hbs:152

src/views/admin/payments/index.hbs:163

src/views/admin/payments/index.hbs:174

src/views/admin/payments/index.hbs:175

src/views/admin/payments/index.hbs:73

src/views/admin/payments/reconciliation.hbs:27

src/views/admin/payments/reconciliation.hbs:28

src/views/admin/payments/reconciliation.hbs:29

src/views/admin/payments/reconciliation.hbs:65

src/views/admin/payments/reconciliation.hbs:93

src/views/admin/payments/reconciliation.hbs:94

src/views/admin/payments/report.hbs:11

src/views/admin/payments/report.hbs:12

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/payments/report.hbs:58

src/views/admin/payments/report.hbs:79

src/views/admin/payments/report.hbs:97

src/views/admin/payments/reports.hbs:47

src/views/admin/payments/reports.hbs:48

src/views/admin/payments/reports.hbs:49

src/views/admin/payments/reports.hbs:69

src/views/admin/payments/reports.hbs:87

src/views/admin/payments/reports.hbs:88

src/views/admin/system-health/index.hbs:186

src/views/admin/system-health/index.hbs:32

src/views/admin/system-health/index.hbs:64

src/views/admin/tags/confirm.hbs:31

src/views/admin/work-queue/dispute-revert-confirm.hbs:15

src/views/admin/work-queue/dispute-revert-confirm.hbs:42

src/views/admin/work-queue/index.hbs:221

src/views/admin/work-queue/index.hbs:240

src/views/admin/work-queue/index.hbs:294

src/views/admin/work-queue/index.hbs:68

src/views/admin/work-queue/index.hbs:71

src/views/admin/work-queue/index.hbs:82

src/views/admin/work-queue/link-help-confirm.hbs:19

src/views/admin/work-queue/link-help-confirm.hbs:38

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/clubs/country.hbs:54

src/views/clubs/country.hbs:6

src/views/clubs/create.hbs:131

src/views/clubs/create.hbs:19

src/views/clubs/create.hbs:24

src/views/clubs/detail.hbs:108

src/views/clubs/detail.hbs:123

src/views/clubs/detail.hbs:140

src/views/clubs/detail.hbs:170

src/views/clubs/detail.hbs:6

src/views/clubs/index.hbs:27

src/views/clubs/leave-confirm.hbs:24

src/views/clubs/leave-confirm.hbs:30

src/views/clubs/step-down-confirm.hbs:25

src/views/dev/persona-listing.hbs:75

src/views/dev/persona-listing.hbs:78

src/views/equipment/index.hbs:31

src/views/equipment/index.hbs:44

src/views/errors/error.hbs:13

src/views/events/index.hbs:16

src/views/events/index.hbs:23

src/views/events/index.hbs:34

src/views/events/year.hbs:17

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/events/year.hbs:23

src/views/freestyle/about.hbs:8

src/views/freestyle/add-analysis.hbs:14

src/views/freestyle/add-analysis.hbs:256

src/views/freestyle/by-the-numbers.hbs:12

src/views/freestyle/by-the-numbers.hbs:26

src/views/freestyle/combo-analysis.hbs:14

src/views/freestyle/combo-analysis.hbs:157

src/views/freestyle/competition.hbs:105

src/views/freestyle/competition.hbs:71

src/views/freestyle/competition.hbs:8

src/views/freestyle/concepts.hbs:103

src/views/freestyle/concepts.hbs:295

src/views/freestyle/concepts.hbs:300

src/views/freestyle/concepts.hbs:852

src/views/freestyle/concepts.hbs:857

src/views/freestyle/concepts.hbs:9

src/views/freestyle/concepts.hbs:910

src/views/freestyle/family-detail.hbs:12

src/views/freestyle/family-detail.hbs:26

src/views/freestyle/family-detail.hbs:66

src/views/freestyle/family-detail.hbs:68

src/views/freestyle/family-detail.hbs:72

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/freestyle/family-detail.hbs:98

src/views/freestyle/glossary.hbs:10

src/views/freestyle/glossary.hbs:26

src/views/freestyle/glossary.hbs:28

src/views/freestyle/glossary.hbs:30

src/views/freestyle/glossary.hbs:34

src/views/freestyle/glossary.hbs:46

src/views/freestyle/history.hbs:43

src/views/freestyle/history.hbs:57

src/views/freestyle/history.hbs:74

src/views/freestyle/history.hbs:8

src/views/freestyle/history.hbs:86

src/views/freestyle/jobs-notation-article.hbs:8

src/views/freestyle/leaders.hbs:37

src/views/freestyle/leaders.hbs:8

src/views/freestyle/media.hbs:24

src/views/freestyle/modifier-family.hbs:18

src/views/freestyle/modifier-family.hbs:39

src/views/freestyle/modifier-family.hbs:63

src/views/freestyle/modifier-family.hbs:80

src/views/freestyle/modifier-family.hbs:94

src/views/freestyle/modifier-stub.hbs:12

src/views/freestyle/modifier-stub.hbs:33

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/freestyle/modifier-stub.hbs:60

src/views/freestyle/modifier-stub.hbs:68

src/views/freestyle/observational.hbs:165

src/views/freestyle/observational.hbs:20

src/views/freestyle/operators.hbs:15

src/views/freestyle/operators.hbs:59

src/views/freestyle/partnerships.hbs:47

src/views/freestyle/partnerships.hbs:8

src/views/freestyle/partnerships.hbs:83

src/views/freestyle/records.hbs:65

src/views/freestyle/records.hbs:8

src/views/freestyle/records.hbs:83

src/views/freestyle/records.hbs:97

src/views/freestyle/search.hbs:46

src/views/freestyle/search.hbs:63

src/views/freestyle/search.hbs:8

src/views/freestyle/set-detail.hbs:123

src/views/freestyle/set-detail.hbs:134

src/views/freestyle/set-detail.hbs:136

src/views/freestyle/set-detail.hbs:161

src/views/freestyle/set-detail.hbs:167

src/views/freestyle/set-detail.hbs:17

src/views/freestyle/set-detail.hbs:60

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/freestyle/set-detail.hbs:76

src/views/freestyle/sets-encyclopedia.hbs:163

src/views/freestyle/sets-encyclopedia.hbs:176

src/views/freestyle/sets-encyclopedia.hbs:185

src/views/freestyle/sets-encyclopedia.hbs:194

src/views/freestyle/sets-encyclopedia.hbs:203

src/views/freestyle/sets-encyclopedia.hbs:213

src/views/freestyle/sets-encyclopedia.hbs:37

src/views/freestyle/sets-encyclopedia.hbs:52

src/views/freestyle/start.hbs:12

src/views/freestyle/start.hbs:161

src/views/freestyle/trick-shell.hbs:47

src/views/freestyle/tricks.hbs:103

src/views/freestyle/tricks.hbs:157

src/views/freestyle/tricks.hbs:163

src/views/freestyle/tricks.hbs:170

src/views/freestyle/tricks.hbs:235

src/views/freestyle/tricks.hbs:248

src/views/freestyle/tricks.hbs:275

src/views/freestyle/tricks.hbs:309

src/views/freestyle/tricks.hbs:349

src/views/freestyle/tricks.hbs:354

src/views/freestyle/tricks.hbs:367

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/freestyle/tricks.hbs:378

src/views/freestyle/tricks.hbs:386

src/views/freestyle/tricks.hbs:40

src/views/freestyle/tricks.hbs:413

src/views/freestyle/tricks.hbs:66

src/views/freestyle/tricks.hbs:8

src/views/history/claim-hp-confirm.hbs:54

src/views/history/claim-hp-conflict.hbs:28

src/views/history/claim-unavailable.hbs:41

src/views/history/detail.hbs:57

src/views/history/detail.hbs:71

src/views/ifpa/index.hbs:30

src/views/ifpa/index.hbs:32

src/views/ifpa/roster.hbs:36

src/views/ifpa/roster.hbs:41

src/views/ifpa/roster.hbs:68

src/views/ifpa/roster.hbs:96

src/views/ifpa/roster.hbs:97

src/views/layouts/main.hbs:75

src/views/layouts/main.hbs:81

src/views/media/browse.hbs:43

src/views/media/browse.hbs:56

src/views/media/browse.hbs:67

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/media/gallery-item.hbs:12

src/views/media/gallery-item.hbs:13

src/views/media/gallery-item.hbs:14

src/views/media/gallery-item.hbs:17

src/views/media/gallery-item.hbs:57

src/views/media/gallery-item.hbs:65

src/views/media/gallery-item.hbs:69

src/views/media/gallery-item.hbs:73

src/views/media/gallery-item.hbs:79

src/views/media/gallery-item.hbs:87

src/views/media/index.hbs:19

src/views/media/member-galleries.hbs:16

src/views/media/member-galleries.hbs:17

src/views/media/member-galleries.hbs:19

src/views/members/contact-admin.hbs:40

src/views/members/delete-account-done.hbs:22

src/views/members/delete-account.hbs:22

src/views/members/delete-account.hbs:23

src/views/members/delete-account.hbs:58

src/views/members/galleries/edit.hbs:13

src/views/members/galleries/list.hbs:15

src/views/members/galleries/list.hbs:71

src/views/members/galleries/list.hbs:81

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/members/media/delete-confirm.hbs:24

src/views/members/media/edit.hbs:102

src/views/members/media/edit.hbs:90

src/views/members/payment-history.hbs:43

src/views/members/payment-history.hbs:96

src/views/members/profile-edit.hbs:30

src/views/members/profile.hbs:17

src/views/members/public-profile.hbs:40

src/views/members/questions.hbs:82

src/views/members/recurring-donation-cancel-confirm.hbs:28

src/views/net/index.hbs:48

src/views/partials/_gallery-current-items.hbs:40

src/views/partials/_gallery-tile.hbs:16

src/views/partials/_gallery-tile.hbs:22

src/views/partials/_gallery-tile.hbs:7

src/views/partials/_pager.hbs:16

src/views/partials/_pager.hbs:20

src/views/partials/_pager.hbs:8

src/views/partials/_set-empty-state.hbs:12

src/views/partials/_set-header.hbs:11

src/views/partials/_set-header.hbs:17

src/views/partials/_teaching-empty-state.hbs:16

src/views/partials/_teaching-empty-state.hbs:26

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/partials/_teaching-empty-state.hbs:46

src/views/partials/_tier-benefit-notice.hbs:15

src/views/partials/back-link.hbs:5

src/views/partials/dictionary-trick-row.hbs:54

src/views/partials/dictionary-trick-row.hbs:60

src/views/partials/dictionary-trick-row.hbs:65

src/views/partials/dictionary-trick-row.hbs:68

src/views/partials/entity-media.hbs:6

src/views/partials/freestyle-modifier-advanced-reference.hbs:125

src/views/partials/freestyle-modifier-reference.hbs:103

src/views/partials/freestyle-modifier-reference.hbs:85

src/views/partials/gallery-edit-form.hbs:178

src/views/partials/glossary-family-card.hbs:72

src/views/partials/media-line.hbs:13

src/views/partials/media-line.hbs:14

src/views/partials/member-block-actions.hbs:22

src/views/partials/member-block-actions.hbs:43

src/views/partials/member-block-identity.hbs:24

src/views/partials/member-block-media.hbs:20

src/views/partials/member-block-media.hbs:21

src/views/partials/member-block-media.hbs:36

src/views/partials/member-block-media.hbs:37

src/views/partials/member-block-media.hbs:38

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/partials/member-block-my-clubs.hbs:58

src/views/partials/member-block-my-clubs.hbs:67

src/views/partials/member-block-my-clubs.hbs:70

src/views/partials/member-block-my-clubs.hbs:9

src/views/partials/member-block-quick-actions.hbs:5

src/views/partials/member-block-search.hbs:47

src/views/partials/nav-links.hbs:6

src/views/partials/player-results.hbs:29

src/views/partials/player-results.hbs:35

src/views/partials/result-section.hbs:29

src/views/partials/set-detail-cross-links.hbs:11

src/views/partials/set-detail-cross-links.hbs:6

src/views/partials/set-detail-cross-links.hbs:8

src/views/partials/share-media-form.hbs:283

src/views/partials/simulated-email-card.hbs:33

src/views/partials/sport-section.hbs:21

src/views/partials/sport-section.hbs:46

src/views/partials/symbolic-related-topology.hbs:11

src/views/partials/trick-about.hbs:57

src/views/partials/trick-about.hbs:94

src/views/partials/trick-equivalent-readings.hbs:21

src/views/partials/trick-family.hbs:22

src/views/partials/trick-family.hbs:32

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/partials/trick-family.hbs:46

src/views/partials/trick-hero.hbs:21

src/views/partials/trick-pathways.hbs:24

src/views/partials/trick-pathways.hbs:36

src/views/partials/trick-pathways.hbs:48

src/views/partials/trick-progression.hbs:27

src/views/partials/trick-progression.hbs:43

src/views/partials/trick-quantity-ladder.hbs:19

src/views/partials/trick-records.hbs:25

src/views/partials/trick-records.hbs:41

src/views/partials/trick-related.hbs:19

src/views/partials/trick-related.hbs:21

src/views/partials/trick-relative-side.hbs:15

src/views/partials/trick-relative-side.hbs:25

src/views/partials/trick-similar.hbs:17

src/views/partials/trick-structural-facts.hbs:19

src/views/partials/trick-structural-facts.hbs:24

src/views/partials/trick-terminal-derived.hbs:21

src/views/partials/trick-terminal-derived.hbs:29

src/views/partials/trick-transform.hbs:29

src/views/partials/video-facade.hbs:13

src/views/payments/cancel.hbs:19

src/views/payments/donate.hbs:15

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/payments/donate.hbs:92

src/views/payments/success.hbs:19

src/views/public/bap.hbs:22

src/views/public/hof.hbs:22

src/views/public/home.hbs:20

src/views/register/wizard/club-affiliations.hbs:20

src/views/register/wizard/complete.hbs:12

src/views/register/wizard/complete.hbs:21

src/views/register/wizard/legacy-claim.hbs:111

src/views/register/wizard/legacy-claim.hbs:50

src/views/rules/index.hbs:19

src/views/rules/index.hbs:28

unquoted-attribute-var **128 places, static analysis** Bears on CC7.1 **MEDIUM**

Detected a unquoted template variable as an attribute. If unquoted, a malicious actor could inject custom JavaScript handlers. To fix this, add quotes around the template expression, like this: "{{ expr }}".

RISK IF LEFT

An attacker can run script in a user's browser and act as that user, reading their session too.

THE FIX

Change the code at each of the 128 places listed. Escape the value for where it lands in the page, or clean it with a library such as DOMPurify before inserting it as HTML.

src/views/admin/audit-log/index.hbs:20

src/views/admin/audit-log/index.hbs:28

src/views/admin/audit-log/index.hbs:36

src/views/admin/club-cleanup.hbs:16

SCANNER RESULTS, UNQUOTED-ATTRIBUTE-VAR, CONTINUED

src/views/admin/club-cleanup.hbs:23

src/views/admin/curator/list.hbs:61

src/views/admin/curator/list.hbs:64

src/views/admin/curator/list.hbs:68

src/views/admin/email-log/index.hbs:18

src/views/admin/email-log/index.hbs:26

src/views/admin/email-templates/edit.hbs:38

src/views/admin/email-templates/edit.hbs:42

src/views/admin/emerging-vocabulary.hbs:62

src/views/admin/emerging-vocabulary.hbs:84

src/views/admin/event-results/discipline.hbs:21

src/views/admin/event-results/discipline.hbs:28

src/views/admin/event-results/discipline.hbs:29

src/views/admin/event-results/entry.hbs:30

src/views/admin/freestyle-modifier-edit.hbs:25

src/views/admin/freestyle-modifiers.hbs:34

src/views/admin/freestyle-notation-author.hbs:72

src/views/admin/freestyle-notation-author.hbs:83

src/views/admin/freestyle-notation-author.hbs:94

src/views/admin/freestyle-record-edit.hbs:25

src/views/admin/freestyle-record-edit.hbs:63

src/views/admin/freestyle-record-edit.hbs:73

src/views/admin/freestyle-records.hbs:22

SCANNER RESULTS, UNQUOTED-ATTRIBUTE-VAR, CONTINUED

src/views/admin/freestyle-sources.hbs:26

src/views/admin/freestyle-trick-edit.hbs:125

src/views/admin/freestyle-trick-edit.hbs:129

src/views/admin/freestyle-trick-edit.hbs:144

src/views/admin/freestyle-trick-edit.hbs:173

src/views/admin/freestyle-trick-edit.hbs:181

src/views/admin/freestyle-trick-edit.hbs:218

src/views/admin/freestyle-trick-edit.hbs:259

src/views/admin/freestyle-trick-edit.hbs:62

src/views/admin/freestyle-trick-edit.hbs:66

src/views/admin/freestyle-trick-edit.hbs:75

src/views/admin/freestyle-trick-publish.hbs:103

src/views/admin/freestyle-trick-publish.hbs:84

src/views/admin/freestyle-tricks.hbs:20

src/views/admin/freestyle-tricks.hbs:28

src/views/admin/historical-records/correction.hbs:26

src/views/admin/mailing-lists/form.hbs:33

src/views/admin/members/record.hbs:124

src/views/admin/members/record.hbs:184

src/views/admin/members/record.hbs:204

src/views/admin/members/record.hbs:210

src/views/admin/members/record.hbs:214

src/views/admin/members/record.hbs:218

SCANNER RESULTS, UNQUOTED-ATTRIBUTE-VAR, CONTINUED

src/views/admin/members/record.hbs:222

src/views/admin/members/record.hbs:226

src/views/admin/members/record.hbs:230

src/views/admin/payments/index.hbs:126

src/views/admin/payments/index.hbs:18

src/views/admin/payments/index.hbs:28

src/views/admin/payments/index.hbs:49

src/views/admin/payments/reconciliation.hbs:37

src/views/admin/system-parameters/index.hbs:45

src/views/admin/work-queue/index.hbs:128

src/views/admin/work-queue/index.hbs:136

src/views/admin/work-queue/index.hbs:259

src/views/admin/work-queue/index.hbs:261

src/views/admin/work-queue/index.hbs:268

src/views/clubs/country.hbs:45

src/views/clubs/create.hbs:102

src/views/events/index.hbs:16

src/views/events/index.hbs:23

src/views/events/index.hbs:34

src/views/ifpa/roster.hbs:41

src/views/layouts/main.hbs:48

src/views/layouts/main.hbs:52

src/views/media/gallery-item.hbs:57

SCANNER RESULTS, UNQUOTED-ATTRIBUTE-VAR, CONTINUED

src/views/media/gallery-item.hbs:9

src/views/members/contact-admin.hbs:24

src/views/members/contact-admin.hbs:26

src/views/members/profile-edit.hbs:112

src/views/members/profile-edit.hbs:139

src/views/members/profile-edit.hbs:164

src/views/members/profile-edit.hbs:181

src/views/members/profile-edit.hbs:185

src/views/members/profile-edit.hbs:189

src/views/members/profile-edit.hbs:196

src/views/members/profile-edit.hbs:222

src/views/members/profile-edit.hbs:241

src/views/members/profile-edit.hbs:248

src/views/members/profile-edit.hbs:249

src/views/members/profile-edit.hbs:250

src/views/members/profile-edit.hbs:260

src/views/members/profile-edit.hbs:99

src/views/members/questions.hbs:39

src/views/members/questions.hbs:43

src/views/members/questions.hbs:59

src/views/partials/_gallery-current-items.hbs:30

src/views/partials/_gallery-current-items.hbs:55

src/views/partials/_pager.hbs:16

SCANNER RESULTS, UNQUOTED-ATTRIBUTE-VAR, CONTINUED

src/views/partials/_tag-filter-bar.hbs:51

src/views/partials/demo-video.hbs:6

src/views/partials/gallery-edit-form.hbs:105

src/views/partials/gallery-edit-form.hbs:88

src/views/partials/gallery-edit-form.hbs:95

src/views/partials/gallery-edit-form.hbs:96

src/views/partials/gallery-edit-form.hbs:97

src/views/partials/media-line.hbs:11

src/views/partials/nav-links.hbs:6

src/views/partials/region-picker.hbs:11

src/views/partials/region-picker.hbs:13

src/views/partials/region-picker.hbs:16

src/views/partials/region-picker.hbs:21

src/views/partials/share-media-form.hbs:131

src/views/partials/share-media-form.hbs:15

src/views/partials/share-media-form.hbs:19

src/views/partials/share-media-form.hbs:20

src/views/partials/share-media-form.hbs:22

src/views/partials/share-media-form.hbs:231

src/views/partials/share-media-form.hbs:240

src/views/partials/share-media-form.hbs:254

src/views/partials/share-media-form.hbs:65

src/views/partials/sport-section.hbs:46

SCANNER RESULTS, UNQUOTED-ATTRIBUTE-VAR, CONTINUED

src/views/partials/video-facade.hbs:16

src/views/partials/video-facade.hbs:17

src/views/partials/wizard-birth-date-correction.hbs:21

src/views/register/wizard/personal-details.hbs:27

src/views/register/wizard/personal-details.hbs:50

src/views/register/wizard/personal-details.hbs:67

src/views/register/wizard/personal-details.hbs:71

src/views/register/wizard/personal-details.hbs:75

src/views/register/wizard/personal-details.hbs:92

insecure-hash-algorithm-sha1 **19 places, static analysis** Bears on CC7.1 **MEDIUM**

Detected SHA1 hash algorithm which is considered insecure. SHA1 is not collision resistant and is therefore not suitable as a cryptographic signature. Use SHA256 or SHA3 instead.

THE FIX

Change the code at each of the 19 places listed. Replace the weak algorithm with a current one, such as AES-GCM for encryption or SHA-256 for hashing.

freestyle/loaders/22_qc_trick_dictionary.py:157

legacy_data/clubs/scripts/01_build_club_person_universe.py:25

legacy_data/clubs/scripts/06_cutover_pre_populated_clubs.py:203

legacy_data/clubs/scripts/07_load_bootstrap_leaders.py:113

legacy_data/clubs/scripts/07a_load_bootstrap_leader_signals.py:103

legacy_data/event_results/scripts/08_load_mvfp_seed_full_to_sqlite.py:44

legacy_data/event_results/scripts/09_load_enrichment_to_sqlite.py:61

legacy_data/legacy_mirror/create_mirror_footbag_org.py:3219

legacy_data/legacy_mirror/create_mirror_footbag_org.py:3297

SCANNER RESULTS, INSECURE-HASH-ALGORITHM-SHA1, CONTINUED

legacy_data/persons/provisional/scripts/01_build_provisional_persons_master.py:24

legacy_data/persons/provisional/scripts/02_build_provisional_identity_candidates.py:25

legacy_data/persons/scripts/05_build_persons_master.py:46

legacy_data/scripts/load_club_members_seed.py:40

legacy_data/scripts/load_clubs_seed.py:91

scripts/promote_snippet_candidates.py:231

scripts/seed_email_templates.py:67

scripts/seed_fh_curator.py:152

scripts/seed_fh_curator.py:162

scripts/seed_fh_curator.py:694

dynamic-urllib-use-detected **5 places, static analysis**

Bears on CC7.1 **MEDIUM**

Detected a dynamic value being used with urllib. urllib supports 'file://' schemes, so a dynamic value controlled by a malicious actor may allow them to read arbitrary files. Audit uses of urllib calls to ensure user data cannot control the URLs, or consider using the 'requests' library instead.

THE FIX

Change the code at each of the 5 places listed so the dynamic-urllib-use-detected rule no longer finds it.

freestyle/scripts/18_scrape_footbag_org_moves.py:189

legacy_data/member_data_scripts/diff_live_honor_rosters.py:84

legacy_data/scripts/generate_world_map_svg.py:58

scripts/acquire_footbag_org_demos.py:85

scripts/acquire_footbag_org_demos.py:93

SCANNER RESULTS, CONTINUED

`requests` 3 advisories in 2.31.0, dependency advisories

Bears on CC7.1 **MEDIUM**

Installed: 2.31.0, the repository's own dependency

THE FIX

Upgrade requests from 2.31.0 to 2.33.0 to fix all 3.

CVE-2024-35195, fixed in 2.32.0 — MEDIUM

requests: subsequent requests to the same host ignore cert verification. Requests is a HTTP library. Prior to 2.32.0, when making requests through a Requests Session, if the first request is made with verify=False to disable cert verification, all subsequent requests to the same host will continue to ignore cert verification regardless of changes to the value of verify.

CVE-2024-47081, fixed in 2.32.4 — MEDIUM

requests: Requests vulnerable to .netrc credentials leak via malicious URLs. Requests is a HTTP library. Due to a URL parsing issue, Requests releases prior to 2.32.4 may leak .netrc credentials to third parties for specific maliciously-crafted URLs. Users should upgrade to version 2.32.4 to receive a fix.

CVE-2026-25645, fixed in 2.33.0 — MEDIUM

requests: Security bypass due to predictable temporary file creation. Requests is a HTTP library. Prior to version 2.33.0, the requests.utils.extractzippedpaths() utility function uses a predictable filename when extracting files from zip archives into the system temporary directory. If the target file already exists, it is reused without validation.

`var-in-script-tag` 2 places, static analysis

Bears on CC7.1 **MEDIUM**

Detected a template variable used in a script tag. Although template variables are HTML escaped, HTML escaping does not always prevent cross-site scripting (XSS) attacks when used directly in JavaScript. If you need this data on the rendered page, consider placing it in the HTML portion (outside of a script tag). Alternatively, use a JavaScript-specific encoder, such as the one available in OWASP ESAPI. For Django, you may also consider using the 'json_script' template tag and retrieving the data in your script by using the element ID (e.g., `document.getElementById`).

RISK IF LEFT

An attacker can run script in a user's browser and act as that user, reading their session too.

THE FIX

Change the code at each of the 2 places listed. Escape the value for where it lands in the page, or clean it with a library such as DOMPurify before inserting it as HTML.

`src/views/clubs/index.hbs:8`

`src/views/partials/share-media-form.hbs:286`

SCANNER RESULTS, CONTINUED

glob 1 advisory in 13.0.6, dependency advisories

Bears on CC7.1 MEDIUM

Installed: 13.0.6, brought in by express-handlebars 8.0.6

RISK IF LEFT

A crafted request can use enough resources to slow or stop the service.

THE FIX

Version 14.0.2 fixes it. glob 13.0.6 comes in through express-handlebars 8.0.6. Upgrade it to a release that uses glob 14.0.2 or later, and if none does yet, force it up with an override in package.json, "overrides": { "express-handlebars": { "glob": "^14.0.2" } }. Moving from 13.0.6 to 14.0.2 is a breaking step under semantic versioning, so forcing it can break express-handlebars. Test before shipping.

CVE-2026-118773, fixed in 14.0.2 MEDIUM

glob: Denial of Service (DoS) via incomplete traversal cancellation. Glob matches files using patterns the shell uses. From 9.0.0 until 14.0.2, abort branches in src/walker.ts, including GlobUtil.walkCB(), GlobUtil.walkCB2(), GlobUtil.walkCBSync(), and GlobUtil.walkCB2Sync(), invoke the callbacks without returning.

idna 1 advisory in 3.11, dependency advisories

Bears on CC7.1 MEDIUM

Installed: 3.11, the repository's own dependency

RISK IF LEFT

A crafted input can make a pattern match run for a very long time, stalling the service.

THE FIX

Upgrade idna from 3.11 to 3.15 to fix it.

CVE-2026-45409, fixed in 3.15 MEDIUM

python-idna: idna: Denial of Service via specially crafted long inputs. Internationalized Domain Names in Applications (IDNA) for Python provides support for Internationalized Domain Names in Applications (IDNA) and Unicode IDNA Compatibility Processing.

minimatch 1 advisory in 10.2.5, dependency advisories

Bears on CC7.1 MEDIUM

Installed: 10.2.5, brought in by express-handlebars 8.0.6

THE FIX

Version 11.0.1 fixes it. minimatch 10.2.5 comes in through express-handlebars 8.0.6. Upgrade it to a release that uses minimatch 11.0.1 or later, and if none does yet, force it up with an override in package.json, "overrides": { "express-handlebars": { "minimatch": "^11.0.1" } }. Moving from 10.2.5 to 11.0.1 is a breaking step under semantic versioning, so forcing it can break express-handlebars. Test before shipping.

SCANNER RESULTS, MINIMATCH, CONTINUED

CVE-2026-118764, fixed in 11.0.1 — MEDIUM

minimatch: Denial of Service via crafted glob pattern expansion. minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Starting in 7.0.0 and prior to 11.0.1, src/index.ts implements firstPhasePreProcess() so that, at optimizationLevel 2 or higher, it repeatedly expands attacker-controlled /..

pytest 1 advisory in 8.3.3, dependency advisories

Bears on CC7.1 — MEDIUM

Installed: 8.3.3, the repository's own dependency

THE FIX

Upgrade pytest from 8.3.3 to 9.0.3 to fix it. Moving from 8.3.3 to 9.0.3 is a breaking step under semantic versioning, so check the release notes before shipping it.

CVE-2025-71176, fixed in 9.0.3 — MEDIUM

pytest: Denial of Service or Privilege Escalation via insecure temporary directory handling. pytest through 9.0.2 on UNIX relies on directories with the /tmp/pytest-of-{user} name pattern, which allows local users to cause a denial of service or possibly gain privileges.

qs 1 advisory in 6.16.0, dependency advisories

Bears on CC7.1 — MEDIUM

Installed: 6.16.0, brought in by express 4.22.2

RISK IF LEFT

The code doesn't catch an unexpected error, so a crafted request can crash the service.

THE FIX

Version 6.16.1 fixes it. qs 6.16.0 comes in through express 4.22.2. Upgrade it to a release that uses qs 6.16.1 or later, and if none does yet, force it up with an override in package.json, "overrides": { "express": { "qs": "^6.16.1" } }.

CVE-2026-110816, fixed in 6.16.1 — MEDIUM

qs: Denial of Service via unhandled exception during array serialization. qs.stringify with arrayFormat: 'comma' throws TypeError: Cannot convert object to primitive value when an array element cannot be coerced to a string, such as an object with an own non-callable toString ({ "toString": "x" }) or a null-prototype object.